

Amazon Web Services

SCS-C03

SCS-C03 - AWS Certified Security – Specialty

[Total Questions: 179]

Category Breakdown

Category	Number of Questions
Detection	44
Identity and Access Management	25
Incident Response	30
Security Foundations and Governance	24
Infrastructure Security	24
Data Protection	32
TOTAL	179

Question #:1 - [Detection]

A company runs workloads in an AWS account. A security engineer observes some unusual findings in Amazon GuardDuty. The security engineer wants to investigate a specific IAM role and generate an investigation report. The report must contain details about anomalous behavior and any indicators of compromise.

Which solution will meet these requirements?

- A. Use Amazon Detective to perform an investigation on the IAM role.
- B. Use AWS Audit Manager to create an assessment. Specify the IAM role. Run an assessment report.
- C. Use Amazon Inspector to create an assessment. Specify the IAM role. Run an assessment report.
- D. Use Amazon Inspector to run an on-demand scan of the IAM role.

Answer: A

Explanation

Amazon Detective is a purpose-built AWS service designed to analyze, investigate, and visualize security data to help identify the root cause of suspicious or malicious activity. According to the AWS Certified Security – Specialty Official Study Guide, Amazon Detective directly integrates with Amazon GuardDuty findings, AWS CloudTrail logs, Amazon VPC Flow Logs, and Amazon EKS audit logs to automatically create behavior graphs and timelines.

When GuardDuty generates findings related to anomalous activity, Amazon Detective enables security engineers to pivot directly to an investigation focused on a specific IAM role, user, or resource. Detective automatically correlates historical activity, identifies deviations from baseline behavior, and highlights indicators of compromise, such as unusual API calls, credential misuse, or suspicious network activity.

AWS Audit Manager (Option B) is designed for compliance and audit evidence collection, not threat investigation. Amazon Inspector (Options C and D) is focused on vulnerability scanning of compute resources and does not analyze IAM behavior or GuardDuty findings.

AWS documentation explicitly states that Amazon Detective is the recommended service for deep-dive investigations following GuardDuty alerts, providing enriched context and investigation reports for security incidents.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon Detective User Guide
- ▶ Amazon GuardDuty Integration Documentation

Question #:2 - [Identity and Access Management]

A company that uses AWS Organizations is using AWS IAM Identity Center to administer access to AWS accounts. A security engineer is creating a custom permission set in IAM Identity Center. The company will use the permission set across multiple accounts. An AWS managed policy and a customer managed policy are attached to the permission set. The security engineer has full administrative permissions and is operating in the management account.

When the security engineer attempts to assign the permission set to an IAM Identity Center user who has access to multiple accounts, the assignment fails.

What should the security engineer do to resolve this failure?

- A. Create the customer managed policy in every account where the permission set is assigned. Give the customer managed policy the same name and same permissions in each account.
- B. Remove either the AWS managed policy or the customer managed policy from the permission set. Create a second permission set that includes the removed policy. Apply the permission sets separately to the user.
- C. Evaluate the logic of the AWS managed policy and the customer managed policy. Resolve any policy conflicts in the permission set before deployment.
- D. Do not add the new permission set to the user. Instead, edit the user's existing permission set to include the AWS managed policy and the customer managed policy.

Answer: A

Explanation

In IAM Identity Center, a permission set that includes a customer managed policy does not “carry” that policy into each target account automatically unless the policy exists there. When you attach a customer managed policy by name to a permission set, IAM Identity Center expects that policy to be present in each account where the permission set is provisioned. If the policy is missing in any account (common when assigning across multiple accounts), provisioning/assignment can fail because Identity Center cannot attach a non-existent policy to the role it creates in that account.

The correct fix is to create the customer managed policy in every target account, ensuring it has the same name and the intended permissions in each account. Once the policy exists consistently across accounts, IAM

Identity Center can successfully provision the permission set in each account and complete the user assignment.

Options B and D are workarounds that increase complexity and do not address the underlying requirement to use the customer managed policy across accounts. Option C is not the issue here; policy “conflicts” typically do not prevent provisioning—missing referenced customer managed policies do. Therefore, ensuring the customer managed policy exists in each assigned account resolves the failure with the intended multi-account design.

Question #:3 - [Incident Response]

A company uses Amazon EC2 instances to host frontend services behind an Application Load Balancer. Amazon Elastic Block Store (Amazon EBS) volumes are attached to the EC2 instances. The company uses Amazon S3 buckets to store large files for images and music. The company has implemented a security architecture on AWS to prevent, identify, and isolate potential ransomware attacks. The company now wants to further reduce risk. A security engineer must develop a disaster recovery solution that can recover to normal operations if an attacker bypasses preventive and detective controls. The solution must meet an RPO of 1 hour.

Which solution will meet these requirements?

- A. Use AWS Backup to create backups of the EC2 instances and S3 buckets every hour. Create AWS CloudFormation templates that replicate existing architecture components. Use a Git repository to store the CloudFormation templates alongside application configuration code.
- B. Use AWS Backup to create backups of the EBS volumes and S3 objects every day. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response.
- C. Use Amazon Security Lake to create a centralized data lake for AWS CloudTrail logs and VPC flow logs. Use the logs for automated response. Enable AWS Security Hub to establish a single location for recovery procedures. Create AWS CloudFormation templates that replicate existing architecture components. Use a Git repository to store the CloudFormation templates alongside application configuration code.
- D. Create EBS snapshots every 4 hours. Enable Amazon GuardDuty Malware Protection. Create automation to immediately restore the most recent snapshot for any EC2 instances that produce an Execution:EC2/MaliciousFile finding in GuardDuty.

Answer: A

Explanation

An RPO of 1 hour means the company must be able to restore data with at most 60 minutes of loss. Option A directly meets this by using AWS Backup to take hourly backups of both the compute layer (EC2) and the data layer (S3). AWS Backup provides centralized policy-based scheduling, retention, and (when configured) immutable protections such as Backup Vault Lock to help defend backups from tampering—important in ransomware recovery scenarios. Backing up the S3 buckets hourly also addresses recovery of critical objects such as images and music that users rely on.

In addition, recovery to “normal operations” is not only about data restoration; it also requires rapidly re-creating infrastructure reliably. Using AWS CloudFormation templates stored in a version-controlled Git repository supports consistent, repeatable rebuilds of the ALB, EC2 fleet configuration, IAM roles, security groups, and related components. This infrastructure-as-code approach reduces human error under incident pressure and accelerates disaster recovery execution.

Option B fails the RPO because daily backups can lose up to 24 hours of data. Option C focuses on logging/governance rather than backups and does not establish a 1-hour recovery point. Option D also fails the RPO (4-hour snapshots) and is reactive to a specific finding type rather than a comprehensive DR plan for EC2 and S3.

Question #:4 - [Security Foundations and Governance]

A company uses AWS Config rules to identify Amazon S3 buckets that are not compliant with the company's data protection policy. The S3 buckets are hosted in several AWS Regions and several AWS accounts. The accounts are in an organization in AWS Organizations. The company needs a solution to remediate the organization's existing noncompliant S3 buckets and any noncompliant S3 buckets that are created in the future.

Which solution will meet these requirements?

- A. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.
- B. Deploy an AWS Config aggregator with organization-wide resource data aggregation. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.
- C. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an AWS Lambda function that responds to AWS Config findings of noncompliant S3 buckets by deleting or reconfiguring the S3 buckets.
- D. Deploy an AWS Config aggregator that scopes only the accounts and Regions that the company currently uses. Create an SCP that contains a Deny statement that prevents the creation of new noncompliant S3 buckets. Apply the SCP to all OUs in the organization.

Answer: A

Explanation

The requirement includes remediating existing noncompliant buckets and also handling future noncompliant buckets across multiple accounts and Regions. An organization-wide AWS Config aggregator provides centralized visibility into compliance status across all member accounts/Regions. To remediate, AWS Config can trigger automation (commonly via EventBridge/SNS) that invokes an AWS Lambda function (or SSM Automation) to take corrective action—such as enabling default encryption, blocking public access, or applying required bucket policies—whenever a bucket is evaluated as noncompliant. This addresses both existing findings (by running remediation on current noncompliant resources) and new ones (by automatically reacting when new buckets appear or configurations drift).

Options C and D are insufficient because they scope only to “accounts and Regions the company currently uses,” which fails the multi-Region/multi-account organization requirement and would miss future expansion. Option B helps prevent creation of new noncompliant resources but does not remediate existing buckets, which is explicitly required. Therefore, the combination of an org-wide aggregator plus automated remediation on Config noncompliance is the best fit.

Question #:5 - [Detection]

A company has decided to move its fleet of Linux-based web server instances to an Amazon EC2 Auto Scaling group. Currently, the instances are static and are launched manually. When an administrator needs to view log files, the administrator uses SSH to establish a connection to the instances and retrieves the logs manually.

The company often needs to query the logs to produce results about application sessions and user issues. The company does not want its new automatically scaling architecture to result in the loss of any log files when instances are scaled in.

Which combination of steps should a security engineer take to meet these requirements MOST cost-effectively? (Select TWO.)

- A. Configure a cron job on the instances to forward the log files to Amazon S3 periodically.
- B. Configure AWS Glue and Amazon Athena to query the log files.
- C. Configure the Amazon CloudWatch agent on the instances to forward the logs to Amazon CloudWatch Logs.
- D. Configure Amazon CloudWatch Logs Insights to query the log files.
- E. Configure the instances to write the logs to an Amazon Elastic File System (Amazon EFS) volume.

Answer: C D

Explanation

Amazon CloudWatch Logs is designed to collect, store, and analyze log data from ephemeral compute resources such as EC2 instances in Auto Scaling groups. According to the AWS Certified Security – Specialty Study Guide, using the CloudWatch agent to stream logs off instances ensures log durability even when instances are terminated during scale-in events.

CloudWatch Logs Insights provides a fully managed, serverless query engine that enables ad hoc querying, filtering, and aggregation of log data without requiring additional infrastructure. This directly satisfies the requirement to query logs for application sessions and user troubleshooting.

Option A introduces operational risk because logs could be lost between cron executions. Option B requires additional services and data pipelines, increasing cost and complexity. Option E adds storage cost and management overhead and is not necessary for log analytics.

AWS best practices recommend CloudWatch Logs and Logs Insights as the most cost-effective and scalable solution for centralized log retention and analysis in Auto Scaling environments.



Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon CloudWatch Logs and Logs Insights

AWS Logging Best Practices

Question #:6 - [Infrastructure Security]

A company has several Amazon S3 buckets that do not enforce encryption in transit. A security engineer must implement a solution that enforces encryption in transit for all the company 's existing and future S3 buckets.

Which solution will meet these requirements?

- A. Enable AWS Config. Create a proactive AWS Config Custom Policy rule. Create a Guard clause to evaluate the S3 bucket policies to check for a value of True for the aws:SecureTransport condition key. If the AWS Config rule evaluates to NON_COMPLIANT, block resource creation.
- B. Enable AWS Config. Configure the s3-bucket-ssl-requests-only AWS Config managed rule and set the rule trigger type to Hybrid. Create an AWS Systems Manager Automation runbook that applies a bucket policy to deny requests when the value of the aws:SecureTransport condition key is False. Configure automatic remediation. Set the runbook as the target of the rule.
- C. Enable Amazon Inspector. Create a custom AWS Lambda rule. Create a Lambda function that applies a bucket policy to deny requests when the value of the aws:SecureTransport condition key is False. Set the Lambda function as the target of the rule.
- D. Create an AWS CloudTrail trail. Enable S3 data events on the trail. Create an AWS Lambda function that applies a bucket policy to deny requests when the value of the aws:SecureTransport condition key is False. Configure the CloudTrail trail to invoke the Lambda function.

Answer: B

Explanation

To enforce encryption in transit for Amazon S3, AWS best practice is to require HTTPS (TLS) by using a bucket policy condition that denies any request where aws:SecureTransport is false. The requirement includes both existing buckets and future buckets, so the control must continuously evaluate configuration drift and automatically remediate. AWS Config is the service intended for continuous configuration compliance monitoring across resources, and AWS Config managed rules provide standardized checks with low operational overhead. The s3-bucket-ssl-requests-only managed rule evaluates whether S3 buckets enforce SSL-only requests, aligning directly with enforcing encryption in transit. Setting the trigger type to Hybrid ensures evaluation both on configuration changes and periodically. Automatic remediation with an AWS Systems Manager Automation runbook allows the organization to apply or correct the bucket policy consistently at scale without manual work. This approach also supports governance by maintaining a measurable compliance status while actively fixing noncompliance. Option A is not the best fit because a “proactive” custom policy rule does not by itself remediate existing buckets and “block resource creation” is not how AWS Config enforces controls. Option C is incorrect because Amazon Inspector is a vulnerability

management service and does not govern S3 bucket transport policies. Option D is inefficient and indirect because CloudTrail data events are not a compliance engine and would require custom processing.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Config Managed Rules for S3 Compliance

Amazon S3 Security Best Practices for SSL-only Access

Question #:7 - [Identity and Access Management]

A company uses AWS IAM Identity Center with SAML 2.0 federation. The company decides to change its federation source from one identity provider (IdP) to another. The underlying directory for both IdPs is Active Directory.

Which solution will meet this requirement?

- A. Disable all existing users and groups within IAM Identity Center that were part of the federation with the original IdP.
- B. Modify the attribute mappings within the IAM Identity Center trust relationship to match information that the new IdP sends.
- C. Reconfigure all existing IAM roles in the company's AWS accounts to explicitly trust the new IdP as the principal.
- D. Confirm that the Network Time Protocol (NTP) clock skew is correctly set between IAM Identity Center and the new IdP endpoints.

Answer: B

Explanation

AWS IAM Identity Center relies on SAML assertions and attribute mappings to associate federated users with identities, groups, and permission sets. According to the AWS Certified Security – Specialty documentation, when changing identity providers while maintaining the same underlying directory, existing users and group identities can be preserved by updating attribute mappings to align with the new IdP's SAML assertions.

By modifying the attribute mappings, IAM Identity Center can correctly interpret usernames, group memberships, and unique identifiers sent by the new IdP without requiring changes to AWS account roles or permission sets. This approach minimizes operational effort and avoids disruption to access management.

Option A unnecessarily disables identities and causes access outages. Option C is incorrect because IAM Identity Center abstracts role trust relationships, and roles do not directly trust the IdP. Option D is unrelated to federation source configuration and only affects authentication timing issues.

AWS best practices recommend updating attribute mappings when switching IdPs that share the same directory source.



Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Identity Center SAML Federation

AWS Identity Federation Best Practices

Question #:8 - [Detection]

A company experienced a security incident caused by a vulnerable container image that was pushed from an external CI/CD pipeline into Amazon ECR.

Which solution will prevent vulnerable images from being pushed?

- A. Enable ECR enhanced scanning with Lambda blocking.
- B. Use Amazon Inspector with EventBridge and Lambda.
- C. Integrate Amazon Inspector into the CI/CD pipeline using SBOM generation and fail the pipeline on critical findings.
- D. Enable basic continuous ECR scanning.

Answer: C

Explanation

Amazon Inspector provides native CI/CD integration capabilities that allow security checks to occur before container images are pushed to Amazon ECR. According to AWS Certified Security – Specialty documentation, Inspector does not block image pushes automatically. Instead, prevention must occur inside the CI/CD pipeline itself.

By generating a Software Bill of Materials (SBOM) using the Amazon Inspector SBOM generator and submitting it to Inspector for scanning, the pipeline can detect critical vulnerabilities before the image is uploaded. If vulnerabilities exceed policy thresholds, the pipeline fails, preventing deployment.

Post-push scanning solutions only detect vulnerabilities after exposure. Event-driven blocking does not prevent the initial risk.

AWS best practices require “shift-left” security controls to prevent vulnerable artifacts from entering production.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Inspector CI/CD Integration

Question #:9 - [Detection]

A company needs to detect unauthenticated access to its Amazon Elastic Kubernetes Service (Amazon EKS) clusters. The solution must require no additional configuration of the existing EKS deployment.

Which solution will meet these requirements with the LEAST operational effort?

- A. Install a third-party security add-on.
- B. Enable AWS Security Hub and monitor Kubernetes findings.
- C. Monitor CloudWatch Container Insights metrics for EKS.
- D. Enable Amazon GuardDuty and use EKS Audit Log Monitoring.

Answer: D

Explanation

Amazon GuardDuty provides managed threat detection and supports EKS protection features that analyze Kubernetes audit logs to detect suspicious activity, including unauthorized or unauthenticated access attempts. AWS Certified Security – Specialty documentation recommends GuardDuty for low-overhead detection because it is fully managed and does not require deploying agents or modifying application code. EKS Audit Log Monitoring is designed to consume and analyze relevant control plane audit events to identify anomalous or unauthorized actions against the cluster. Compared to third-party add-ons, GuardDuty reduces operational burden and remains fully within AWS managed services. Security Hub aggregates findings from services like GuardDuty but does not itself perform the detection. CloudWatch Container Insights focuses on performance and operational metrics, not authentication security detections. Therefore, enabling GuardDuty with EKS Audit Log Monitoring provides the required detection with the least operational effort and without requiring additional configuration to the existing EKS workload beyond enabling the feature.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty EKS Protection and Audit Log Monitoring

AWS Threat Detection Best Practices for Kubernetes on AWS

Question #:10 - [Detection]

A security engineer needs to implement a solution to identify any sensitive data that is stored in an Amazon S3 bucket. The solution must report on sensitive data in the S3 bucket by using an existing Amazon Simple Notification Service (Amazon SNS) topic.

Which solution will meet these requirements with the LEAST implementation effort?

- A. Enable AWS Config. Configure AWS Config to monitor for sensitive data in the S3 bucket and to send notifications to the SNS topic.

- B. Create an AWS Lambda function to scan the S3 bucket for sensitive data that matches a pattern. Program the Lambda function to send notifications to the SNS topic.
- C. Configure Amazon Macie to use managed data identifiers to identify and categorize sensitive data. Create an Amazon EventBridge rule to send notifications to the SNS topic.
- D. Enable Amazon GuardDuty. Configure AWS CloudTrail S3 data events. Create an Amazon CloudWatch alarm that reacts to GuardDuty findings and sends notifications to the SNS topic.

Answer: C

Explanation

Amazon Macie is the AWS service designed specifically to discover, classify, and report sensitive data stored in Amazon S3. According to the AWS Certified Security – Specialty Study Guide, Macie uses machine learning and managed data identifiers to automatically detect sensitive data types such as PII and financial information.

Macie integrates natively with Amazon EventBridge, allowing findings to be routed to other services such as Amazon SNS with minimal configuration. Creating an EventBridge rule to forward Macie findings to an existing SNS topic satisfies the notification requirement without custom code.

Option A is invalid because AWS Config does not inspect object contents. Option B requires custom development and ongoing maintenance. Option D is incorrect because Amazon GuardDuty focuses on threat detection, not sensitive data discovery.

AWS documentation emphasizes Macie as the lowest-effort and most accurate solution for sensitive data identification in S3.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Macie Sensitive Data Discovery

Amazon EventBridge Integration with Security Services

Question #:11 - [Data Protection]

A security engineer needs to control access to data that is encrypted with an AWS Key Management Service (AWS KMS) customer managed key. The security engineer also needs to use additional authenticated data (AAD) to prevent tampering with ciphertext.

Which solution will meet these requirements?

- A. Pass the key alias to AWS KMS when calling the Encrypt and Decrypt API actions.
- B. Use IAM policies to restrict access to the Encrypt and Decrypt API actions.

- C. Use the kms:EncryptionContext condition key when defining IAM policies for the customer managed key.
- D. Use key policies to restrict access to the appropriate IAM groups.

Answer: C

Explanation

AWS KMS supports additional authenticated data (AAD) through the use of encryption context. According to the AWS Certified Security – Specialty documentation, encryption context is a set of key-value pairs that is cryptographically bound to the ciphertext. Any attempt to decrypt the data must include the same encryption context, or decryption will fail. This mechanism protects against ciphertext tampering and unauthorized reuse.

The kms:EncryptionContext condition key allows security engineers to enforce the use of specific encryption context values in IAM or key policies. By defining conditions that require particular encryption context attributes, access to encrypted data can be tightly controlled and bound to specific applications, environments, or workflows.

Option A does not provide integrity protection. Option B controls access but does not enforce the use of AAD. Option D restricts administrative access but does not address encryption context enforcement.

AWS documentation explicitly states that encryption context combined with policy conditions is the recommended method to implement authenticated encryption and fine-grained access control with KMS.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Encryption Context

AWS KMS Policy Condition Keys

Question #:12 - [Incident Response]

A company has a large fleet of Amazon Linux 2 Amazon EC2 instances that run an application processing sensitive data. Compliance requirements include no exposed management ports, full session logging, and authentication through AWS IAM Identity Center. DevOps engineers occasionally need access for troubleshooting.

Which solution will provide remote access while meeting these requirements?

- A. Grant access to the EC2 serial console and allow IAM role access.
- B. Enable EC2 Instance Connect and configure security groups accordingly.
- C. Assign an EC2 instance role that allows access to AWS Systems Manager. Create an IAM policy that grants access to Systems Manager Session Manager and assign it to an IAM Identity Center role.

D. Use Systems Manager Automation to temporarily open remote access ports.

Answer: C

Explanation

AWS Systems Manager Session Manager provides secure, auditable shell access to EC2 instances without opening inbound ports. According to AWS Certified Security – Specialty guidance, Session Manager records all session activity to CloudWatch Logs or Amazon S3 and integrates with IAM Identity Center for centralized authentication.

This solution meets all requirements: no exposed ports, full audit logging, and identity-based access control. EC2 Instance Connect and serial console access do not integrate with Identity Center and may expose management paths.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Systems Manager Session Manager

AWS IAM Identity Center Integration

Question #:13 - [Incident Response]

A security engineer is responding to an incident that is affecting an AWS account. The ID of the account is 123456789012. The attack created workloads that are distributed across multiple AWS Regions.

The security engineer contains the attack and removes all compute and storage resources from all affected Regions. However, the attacker also created an AWS KMS key. The key policy on the KMS key explicitly allows IAM principal kms:* permissions.

The key was scheduled to be deleted the previous day. However, the key is still enabled and usable. The key has an ARN of

arn:aws:kms:us-east-2:123456789012:key/mrk-0bb0212cd9864fdea0dcamzo26efb5670.

The security engineer must delete the key as quickly as possible.

Which solution will meet this requirement?

- A. Log in to the account by using the account root user credentials. Re-issue the deletion request for the KMS key with a waiting period of 7 days.
- B. Identify the other Regions where the KMS key ID is present and schedule the key for deletion in 7 days.
- C. Update the IAM principal to allow kms:* permissions on the KMS key ARN. Re-issue the deletion request for the KMS key with a waiting period of 7 days.

D. Disable the KMS key. Re-issue the deletion request for the KMS key in 30 days.

Answer: A

Explanation

AWS KMS enforces a mandatory minimum waiting period of 7 days before a customer managed key can be deleted. According to AWS Certified Security – Specialty incident response guidance, no method exists to immediately delete a KMS key. The fastest possible deletion is achieved by scheduling deletion with the minimum 7-day waiting period.

In this scenario, although deletion was previously scheduled, the key remains enabled and usable. The most authoritative and reliable method to regain control and reissue deletion immediately is to use the AWS account root user, which has implicit permissions to manage KMS keys regardless of compromised IAM principals.

Option B is incorrect because KMS keys are regional resources; multi-Region keys require coordinated deletion but do not shorten the waiting period. Option C is unnecessary because the key policy already allows kms:*. Option D increases the deletion waiting period to 30 days, which violates the requirement to delete the key as quickly as possible.

AWS documentation clearly states that root user access is the ultimate authority for KMS key management and that 7 days is the minimum deletion window, making this the fastest valid option.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Key Management Service Developer Guide
- ▶ AWS Incident Response Best Practices

Question #:14 - [Identity and Access Management]

A company stores infrastructure and application code in web-based, third-party, Git-compatible code repositories outside of AWS. The company wants to give the code repositories the ability to securely authenticate and assume an existing IAM role within the company's AWS account by using OpenID Connect (OIDC).

Which solution will meet these requirements?

- A. Create an OIDC identity provider (IdP) by using AWS Identity and Access Management (IAM) federation. Modify the trust policy of the IAM role to allow the code repositories to assume the IAM role.
- B. Use AWS Identity and Access Management (IAM) Roles Anywhere to create a trust anchor that uses OIDC. Modify the trust policy of the IAM role to allow the code repositories to assume the IAM role.
- C. Set up an account instance of AWS IAM Identity Center. Configure access to the code repositories as a customer managed OIDC application. Grant the application access to the IAM role.

- D. Use AWS Resource Access Manager (AWS RAM) to create a new resource share that uses OIDC. Limit the resource share to the specified code repositories. Grant the IAM role access to the resource share.

Answer: A

Explanation

AWS IAM supports identity federation by allowing external identity providers that use OpenID Connect (OIDC) to authenticate and assume IAM roles. According to the AWS Certified Security – Specialty documentation, IAM OIDC identity providers are the recommended approach for enabling third-party systems, such as external CI/CD pipelines or Git-based repositories, to securely obtain temporary AWS credentials without using long-term access keys.

By creating an OIDC identity provider in IAM and configuring the IAM role trust policy to trust the external IdP, the company enables secure, token-based authentication. The trust policy can include conditions that restrict which repositories, branches, or workflows are allowed to assume the role, enforcing least privilege. AWS Security Specialty guidance emphasizes that this method eliminates static credentials and relies on short-lived tokens issued by the OIDC provider.

Option B is incorrect because IAM Roles Anywhere is designed for workloads running outside AWS that use X.509 certificates, not OIDC. Option C is intended for workforce identity federation, not machine-to-machine authentication. Option D is invalid because AWS RAM does not provide identity federation or authentication capabilities.

This solution aligns with AWS best practices for secure, scalable, and low-overhead authentication for external workloads.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM OIDC Identity Providers

AWS IAM Role Trust Policies

Question #:15 - [Data Protection]

A company is using AWS to run a long-running analysis process on data that is stored in Amazon S3 buckets. The process runs on a fleet of Amazon EC2 instances in an Auto Scaling group. The EC2 instances are deployed in a private subnet that does not have internet access.

The EC2 instances access Amazon S3 through an S3 gateway endpoint that has the default access policy. Each EC2 instance uses an instance profile role that allows s3:GetObject and s3:PutObject only for required S3 buckets.

The company learns that one or more EC2 instances are compromised and are exfiltrating data to an S3 bucket that is outside the company's AWS Organization. The processing job must continue to function.

Which solution will meet these requirements?

- A. Update the policy on the S3 gateway endpoint to allow S3 actions only if aws:ResourceOrgId and aws:PrincipalOrgId match the company's organization.
- B. Update the instance profile role policy to require aws:ResourceOrgId.
- C. Add a network ACL rule to block outbound traffic on port 443.
- D. Apply an SCP that restricts S3 actions using organization condition keys.

Answer: A

Explanation

Amazon S3 gateway endpoints support endpoint policies that can restrict which S3 resources are accessible through the endpoint. According to AWS Certified Security – Specialty documentation, endpoint policies are evaluated in addition to IAM policies and are ideal for enforcing data exfiltration controls without breaking legitimate workloads.

By updating the S3 gateway endpoint policy to require both aws:ResourceOrgId and aws:PrincipalOrgId to match the company's AWS Organization, the security engineer ensures that EC2 instances can access only S3 buckets that belong to the organization. This immediately blocks exfiltration to external S3 buckets while allowing legitimate internal data access to continue uninterrupted.

Option B is insufficient because IAM policies alone cannot prevent access when the endpoint allows it. Option C would break all S3 access and stop the processing job. Option D applies too broadly and can impact unrelated services across the account.

AWS documentation highlights S3 VPC endpoint policies with organization condition keys as a best practice for preventing S3 data exfiltration in private VPC environments.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon S3 VPC Endpoint Policy Documentation
- ▶ AWS Organizations Condition Keys Documentation

Question #:16 - [Data Protection]

A company has enabled AWS Config for its organization in AWS Organizations. The company has deployed hundreds of Amazon S3 buckets across the organization. A security engineer needs to identify any S3 buckets that are not encrypted with AWS Key Management Service (AWS KMS). The security engineer also must prevent objects that are not encrypted with AWS KMS from being uploaded to the S3 buckets.

Which solution will meet these requirements?

- A. Use the s3-default-encryption-kms AWS Config managed rule to identify unencrypted S3 buckets. Create an SCP to allow s3:PutObject action only when the object is encrypted with AWS KMS.

- B. Use `thes3-default-encryption-kms` AWS Config managed rule to identify unencrypted S3 buckets. Create bucket policies for each S3 bucket to deny `thes3:PutObject` action only when the object has server-side encryption with S3 managed keys (SSE-S3).
- C. Use `thes3-bucket-ssl-requests-only` AWS Config managed rule to identify unencrypted S3 buckets. Create an SCP to allow `thes3:PutObject` action only when the object is encrypted with AWS KMS.
- D. Use `thes3-bucket-ssl-requests-only` AWS Config managed rule to identify unencrypted S3 buckets. Create bucket policies for each S3 bucket to allow `thes3:PutObject` action only when the object is encrypted with AWS KMS.

Answer: A

Explanation

The correct Config rule for finding buckets that are not using SSE-KMS by default is `thes3-default-encryption-kms`. It evaluates the bucket's default encryption settings and flags buckets that do not have KMS default encryption enabled. The `s3-bucket-ssl-requests-only` rule focuses on enforcing HTTPS-only requests and does not validate encryption-at-rest settings, so it cannot satisfy the "identify not encrypted with KMS" requirement.

For preventing uploads of objects that are not encrypted with KMS, an organization-wide control is needed. An SCP can restrict `s3:PutObject` so that uploads succeed only when the request specifies SSE-KMS (and optionally a specific KMS key). This provides broad, low-touch enforcement across many accounts and buckets. While bucket policies can also enforce SSE-KMS, managing and verifying hundreds of bucket policies is more operationally heavy than a centrally managed SCP guardrail.

Option B enforces SSE-S3, which does not meet the requirement for KMS encryption. Option D uses the wrong Config rule and relies on an "allow-only" pattern rather than explicit deny logic, making it an unreliable fit for the stated goal. Therefore, A is the best answer.

Question #:17 - [Data Protection]

A company's application team needs a new AWS Key Management Service (AWS KMS) customer managed key to use with Amazon S3. The company's security policy requires separate keys for different AWS services to limit security exposure.

How can a security engineer limit the KMS customer managed key to work with only Amazon S3?

- A. Configure the key policy to allow only Amazon S3 to perform the `kms:Encrypt` action.
- B. Configure the key policy to allow KMS actions only when the value for the `kms:ViaService` condition key matches the Amazon S3 service name.
- C. Configure the application's IAM role policy to allow Amazon S3 to perform the `iam:PassRole` action.
- D. Configure the application's IAM role policy to allow only S3 operations when the operations are combined with the KMS customer managed key.

Answer: B

Explanation

AWS KMS provides condition keys that can be used to tightly scope how and where a customer managed key can be used. According to the AWS Certified Security – Specialty Study Guide, the `kms:ViaService` condition key is specifically designed to restrict key usage to requests that originate from a particular AWS service in a specific Region.

By configuring the key policy to allow KMS cryptographic operations only when `kms:ViaService` equals `s3.<region>.amazonaws.com`, the security engineer ensures that the key can be used exclusively by Amazon S3. Even if other IAM principals have permissions to use the key, the key cannot be used by other services such as Amazon EC2, Amazon RDS, or AWS Lambda.

Option A is incorrect because AWS services do not assume identities in key policies. Options C and D modify IAM role policies, which do not control how a KMS key is used by AWS services. AWS documentation clearly states that service-level restrictions must be enforced at the KMS key policy level using condition keys.

This approach enforces strong separation of duties and limits blast radius, which aligns with AWS security best practices.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Key Policy Condition Keys

AWS KMS Best Practices

Question #:18 - [Detection]

A company runs a public web application on Amazon EKS behind Amazon CloudFront and an Application Load Balancer (ALB). A security engineer must send a notification to an existing Amazon SNS topic when the application receives 10,000 requests from the same end-user IP address within any 5-minute period.

Which solution will meet these requirements?

- A. Configure CloudFront standard logging and CloudWatch Logs metric filters.
- B. Configure VPC Flow Logs and CloudWatch Logs metric filters.
- C. Configure an AWS WAF web ACL with an ASN match rule and CloudWatch alarms.
- D. Configure an AWS WAF web ACL with a rate-based rule. Associate it with CloudFront. Create a CloudWatch alarm to notify SNS.

Answer: D

Explanation



AWS WAF rate-based rules are designed specifically to track the number of requests from a single IP address over a configurable time window. According to AWS Certified Security – Specialty guidance, rate-based rules integrate natively with CloudFront and emit CloudWatch metrics that can trigger alarms.

CloudFront logs and VPC Flow Logs are not real-time detection tools. ASN match rules do not count request rates.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS WAF Rate-Based Rules

CloudFront and AWS WAF Integration

Question #:19 - [Security Foundations and Governance]

A company is using AWS Organizations with nested OUs to manage AWS accounts. The company has a custom compliance monitoring service for the accounts. The monitoring service runs as an AWS Lambda function and is invoked by Amazon EventBridge Scheduler.

The company needs to deploy the monitoring service in all existing and future accounts in the organization. The company must avoid using the organization 's management account when the management account is not required.

Which solution will meet these requirements?

- A. Create a CloudFormation stack set in the organization 's management account and manually add new accounts.
- B. Configure a delegated administrator account for AWS CloudFormation. Create a CloudFormation StackSet in the delegated administrator account targeting the organization root with automatic deployment enabled.
- C. Use Systems Manager delegated administration and Automation to deploy the Lambda function and schedule.
- D. Create a Systems Manager Automation runbook in the management account and share it to accounts.

Answer: B

Explanation

AWS Organizations and CloudFormation StackSets provide an organizational deployment mechanism for consistent infrastructure across accounts. AWS Certified Security – Specialty guidance emphasizes minimizing use of the management account and using delegated administrator capabilities where available for centralized governance while reducing blast radius. By configuring a delegated administrator account for AWS CloudFormation, the company can create and manage StackSets without performing day-to-day deployment operations from the management account. Targeting the organization root ensures the StackSet deploys to all existing accounts. Enabling automatic deployment ensures that any future accounts that join the

organization (or move into targeted OUs, depending on configuration) automatically receive the monitoring service without manual intervention. This directly meets the requirement to deploy to all existing and future accounts with minimal effort. Option A requires ongoing manual updates when accounts are added, increasing operational overhead. Options C and D rely on Systems Manager Automation, which can work but introduces additional operational complexity and is not the standard AWS mechanism for organization-wide infrastructure rollout compared to StackSets with auto-deployment. StackSets also provide consistent change control, drift detection, and centralized update mechanisms, which align with governance expectations for compliance tooling.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Organizations Delegated Administration

AWS CloudFormation StackSets for Multi-Account Governance

Question #:20 - [Detection]

A security engineer needs to protect a public web application that runs in a VPC. The VPC hosts the origin for an Amazon CloudFront distribution. The application has experienced multiple layer 7 DDoS attacks. An AWS WAF web ACL is associated with the CloudFront distribution. The web ACL contains one AWS managed rule to protect against known IP addresses that have bad reputations.

The security engineer must configure an automated solution that detects and mitigates layer 7 DDoS attacks in real time with no manual effort.

Which solution will meet these requirements?

- A. Enable AWS Shield Advanced on the CloudFront distribution. Configure alerts in Amazon CloudWatch for DDoS indicators.
- B. Enable AWS Shield Advanced and configure proactive engagement with the AWS DDoS Response Team (DRT).
- C. Deploy AWS Network Firewall in the VPC. Create security policies that detect DDoS indicators. Create an AWS Lambda function to automatically update the web ACL rules during an attack.
- D. Add a rate-based rule to the web ACL. Enable AWS Shield Advanced. Enable automatic application layer DDoS mitigation on the CloudFront distribution.

Answer: D

Explanation

Option D is the correct solution because it provides fully automated, real-time detection and mitigation of application-layer (Layer 7) DDoS attacks with no manual intervention. AWS Shield Advanced includes automatic application layer DDoS mitigation when it is enabled for supported resources such as Amazon CloudFront distributions. This feature continuously monitors traffic patterns and, when an attack is detected, automatically deploys AWS WAF rules to mitigate malicious requests.

Adding a rate-based rule to the AWS WAF web ACL further strengthens protection by automatically blocking IP addresses that exceed a defined request threshold, which is a common characteristic of Layer 7 DDoS attacks. This combination aligns directly with AWS best practices for protecting web applications against volumetric and application-layer threats.

Option A only provides alerting and visibility but does not ensure automated mitigation. Option B includes proactive engagement with the AWS DDoS Response Team, which is valuable for complex or large-scale attacks but still involves human interaction and therefore does not meet the “no manual effort” requirement. Option C introduces unnecessary complexity and is not recommended for protecting CloudFront-based applications against Layer 7 DDoS attacks.

AWS Security Specialty documentation explicitly recommends AWS Shield Advanced with automatic application layer DDoS mitigation and AWS WAF rate-based rules for fully automated, real-time protection of public web applications.

Question #:21 - [Incident Response]

A company operates an Amazon EC2 instance that is registered as a target of a Network Load Balancer (NLB). The NLB is associated with a security group. The security group allows inbound TCP traffic on port 22 from 10.0.0.0/23.

The company maps the NLB to two subnets that share the same network ACL and route table. The route table has a route for 0.0.0.0/0 to an internet gateway. The network ACL has one inbound rule that has a priority of 20 and that allows TCP traffic on port 22 from 10.0.0.0/16.

A security engineer receives an alert that there is an unauthorized SSH session on the EC2 instance. The unauthorized session originates from 10.0.1.5. The company's incident response procedure requires unauthorized SSH sessions to be immediately interrupted. The instance must remain running, and its memory must remain intact.

Which solution will meet these requirements?

- A. Restart the EC2 instance from either the AWS Management Console or the AWS CLI.
- B. Add a new inbound rule that has a priority of 10 to the network ACL to deny TCP traffic on port 22 from 10.0.1.5.
- C. Remove the security group rule that allows inbound TCP traffic on port 22 from 10.0.0.0/16.
- D. Update the route table to remove the route to the internet gateway.

Answer: B

Explanation

Network ACLs are stateless and are evaluated in order based on rule number, with lower rule numbers taking precedence. According to AWS Certified Security – Specialty incident response guidance, network ACLs can be used to immediately block traffic at the subnet level without restarting instances or modifying their runtime state.

By adding a deny rule with a lower priority number (10) that explicitly denies TCP traffic on port 22 from the offending IP address (10.0.1.5), the unauthorized SSH session is immediately interrupted. This approach satisfies the requirement to keep the instance running and to preserve memory for forensic analysis.

Option A violates the requirement because restarting the instance clears memory. Option C would disrupt all legitimate SSH access, not just the unauthorized session. Option D would block all internet access and could cause widespread service disruption.

AWS documentation emphasizes using network ACL deny rules for rapid, targeted containment when immediate interruption is required without altering instance state.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon VPC Network ACL Documentation
- ▶ AWS Incident Response Best Practices

Question #:22 - [Identity and Access Management]

A company has contracted with a third party to audit several AWS accounts. To enable the audit, cross-account IAM roles have been created in each account targeted for audit. The auditor is having trouble accessing some of the accounts.

Which of the following may be causing this problem? (Select THREE.)

- A. The external ID used by the auditor is missing or incorrect.
- B. The auditor is using the incorrect password.
- C. The auditor has not been granted `sts:AssumeRole` for the role in the destination account.
- D. The Amazon EC2 role used by the auditor must be set to the destination account role.
- E. The secret key used by the auditor is missing or incorrect.
- F. The role ARN used by the auditor is missing or incorrect.

Answer: A C F

Explanation

Cross-account access for an external auditor typically uses STS `AssumeRole` into a role that exists in each target account. Three common failure points are: (1) the role ARN being wrong or missing, (2) the auditor lacking permission to call `sts:AssumeRole` on that role, and (3) an external ID mismatch when the role trust policy requires it. The external ID is a best practice for third-party access to mitigate the confused-deputy problem; if the trust policy includes an `sts:ExternalId` condition, the auditor must supply the exact expected value. If it's absent or incorrect, `AssumeRole` will be denied.

The auditor must also be authorized on their side (IAM user/role policy) to call sts:AssumeRole (permission), and the destination role's trust policy must trust the auditor principal. If either side is misconfigured, the assume operation fails. Finally, the auditor must reference the correct role ARN for each account; using an incorrect ARN (wrong account ID/role name/path) is a frequent reason only "some accounts" fail.

Incorrect password (B) is irrelevant if the auditor is using API/STS federation rather than console password auth, and EC2 instance roles (D) are not required for an external auditor. Missing/incorrect secret key (E) is possible for API auth, but the question centers on cross-account role access issues; the canonical causes are external ID, AssumeRole permission, and role ARN.

Question #:23 - [Data Protection]

A company needs to deploy AWS CloudFormation templates that configure sensitive database credentials. The company already uses AWS Key Management Service (AWS KMS) and AWS Secrets Manager.

Which solution will meet the requirements?

- A. Use a dynamic reference in the CloudFormation template to reference the database credentials in Secrets Manager.
- B. Use encrypted parameters in the CloudFormation template.
- C. Use SecureString parameters to reference Secrets Manager.
- D. Use SecureString parameters encrypted by AWS KMS.

Answer: A

Explanation

AWS CloudFormation supports dynamic references to AWS Secrets Manager, which allow sensitive values to be retrieved securely at stack runtime. According to AWS Certified Security – Specialty guidance, dynamic references prevent secrets from being stored in plaintext in templates, stack metadata, or logs.

Using dynamic references ensures that secrets remain encrypted at rest and are accessed only when required. CloudFormation does not support SecureString parameters for Secrets Manager references, and encrypting templates does not prevent exposure during execution.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS CloudFormation Dynamic References

AWS Secrets Manager Best Practices

Question #:24 - [Detection]

A company is planning to deploy a new log analysis environment. The company needs to analyze logs from multiple AWS services in near real time. The solution must provide the ability to search the logs and must send alerts to an existing Amazon Simple Notification Service (Amazon SNS) topic when specific logs match detection rules.

Which solution will meet these requirements?

- A. Analyze the logs by using Amazon OpenSearch Service. Search the logs from the OpenSearch API. Use OpenSearch Service Security Analytics to match logs with detection rules and to send alerts to the SNS topic.
- B. Analyze the logs by using AWS Security Hub. Search the logs from the Findings page in Security Hub. Create custom actions to match logs with detection rules and to send alerts to the SNS topic.
- C. Analyze the logs by using Amazon CloudWatch Logs. Use a subscription filter to match logs with detection rules and to send alerts to the SNS topic. Search the logs manually by using CloudWatch Logs Insights.
- D. Analyze the logs by using Amazon QuickSight. Search the logs by listing the query results in a dashboard. Run queries to match logs with detection rules and to send alerts to the SNS topic.

Answer: A

Explanation

Amazon OpenSearch Service is designed for near real-time log ingestion, indexing, and search across large volumes of data. According to the AWS Certified Security – Specialty Study Guide, OpenSearch supports advanced log analytics use cases and integrates with OpenSearch Security Analytics, which provides prebuilt and custom detection rules.

Security Analytics can continuously evaluate incoming logs from multiple AWS services and generate alerts when detection rules are matched. These alerts can be forwarded to Amazon SNS with minimal configuration. OpenSearch also provides powerful search and query capabilities through APIs and dashboards.

Option C supports detection but lacks advanced correlation and scalable search capabilities. Option B is not a log analytics service. Option D is a visualization service and does not support real-time detection.

AWS guidance recommends OpenSearch Service for centralized, near real-time log analysis and alerting.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon OpenSearch Service Security Analytics

AWS Logging and Monitoring Architecture

Question #:25 - [Incident Response]

A company runs a web application on a fleet of Amazon EC2 instances that are in an Auto Scaling group. The EC2 instances are in the same VPC subnet as other workloads.

A security engineer deploys Amazon GuardDuty and integrates it with AWS Security Hub. The security engineer needs to implement an automated solution to detect and respond to anomalous traffic patterns. The solution must follow AWS best practices for initial incident response and must minimize disruption to the web application.

Which solution will meet these requirements?

- A. Disable the instance profile access keys by using AWS Lambda.
- B. Remove the affected instance from the Auto Scaling group and isolate it with a restricted security group by using AWS Lambda.
- C. Update the network ACL to block the detected traffic source.
- D. Send GuardDuty findings to Amazon SNS for email notification.

Answer: B

Explanation

AWS incident response best practices emphasize containment with minimal blast radius while preserving business continuity. According to the AWS Certified Security – Specialty Official Study Guide, isolating a compromised resource while allowing the application to continue operating is the recommended initial response.

By creating an Amazon EventBridge rule that reacts to GuardDuty anomalous traffic findings and invokes an AWS Lambda function, the security engineer can automatically remove the affected EC2 instance from the Auto Scaling group and attach a restricted security group. This immediately stops malicious activity while allowing Auto Scaling to replace the instance and keep the application available.

Option A is inappropriate because EC2 instance profiles do not use long-term access keys. Option C applies subnet-wide changes that could disrupt unrelated workloads. Option D provides notification only and does not meet the automated response requirement.

AWS documentation explicitly identifies instance isolation via security groups as a preferred containment technique that preserves application availability and forensic integrity.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon GuardDuty User Guide
- ▶ AWS Incident Response Best Practices

An IAM user receives an Access Denied message when the user attempts to access objects in an Amazon S3 bucket. The user and the S3 bucket are in the same AWS account. The S3 bucket is configured to use server-side encryption with AWS KMS keys (SSE-KMS) to encrypt all of its objects at rest by using a customer managed key from the same AWS account. The S3 bucket has no bucket policy defined. The IAM user has been granted permissions through an IAM policy that allows the `kms:Decrypt` permission to the customer managed key. The IAM policy also allows the `s3:List*` and `s3:Get*` permissions for the S3 bucket and its objects.

Which of the following is a possible reason that the IAM user cannot access the objects in the S3 bucket?

- A. The IAM policy needs to allow the `kms:DescribeKey` permission.
- B. The S3 bucket has been changed to use the AWS managed key to encrypt objects at rest.
- C. An S3 bucket policy needs to be added to allow the IAM user to access the objects.
- D. The KMS key policy has been edited to remove the ability for the AWS account to have full access to the key.

Answer: D

Explanation

With SSE-KMS, authorization is a two-part check: the caller must have S3 permissions to read the object and the caller must be allowed to use the KMS key for decryption. Even if an IAM policy grants `kms:Decrypt`, the request will still fail if the KMS key policy does not allow the principal (or does not allow the account to delegate use of the key). KMS key policies are authoritative: they can prevent key usage even when IAM policies appear to allow it.

A common misconfiguration is editing the key policy and removing the statement that grants the AWS account (or key administrators) the ability to manage and delegate permissions for the key—often described as removing “Enable IAM user permissions” or otherwise blocking the account from using IAM policies to authorize key usage. In that case, the IAM user’s `kms:Decrypt` permission in IAM is not sufficient because the key policy no longer permits it, resulting in Access Denied when S3 attempts to call KMS on the user’s behalf during `GetObject`.

Option A is not required for decrypting data (`DescribeKey` is useful for discovery but not necessary for `GetObject`). Option B would not inherently cause access denied if permissions align. Option C is incorrect because same-account S3 access can be granted purely via IAM without a bucket policy. Therefore, the key policy change is a valid reason.

Question #:27 - [Identity and Access Management]

A company runs an application on an Amazon EC2 instance. The application generates invoices and stores them in an Amazon S3 bucket. The instance profile that is attached to the instance has appropriate access to the S3 bucket. The company needs to share each invoice with multiple clients that do not have AWS credentials. Each client must be able to download only the client's own invoices. Clients must download their invoices within 1 hour of invoice creation. Clients must use only temporary credentials to access the company's AWS resources.

Which additional step will meet these requirements?

- A. Update the S3 bucket policy to ensure that clients that use pre-signed URLs have the S3:Get* permission and the S3:List* permission to access S3 objects in the bucket.
- B. Add a StringEquals condition to the IAM role policy for the EC2 instance profile. Configure the policy condition to restrict access based on the s3:ResourceTag/ClientId tag of each invoice. Tag each generated invoice with the ID of its corresponding client.
- C. Update the script to use AWS Security Token Service (AWS STS) to obtain new credentials each time the script runs by assuming a new role that has S3:GetObject permissions. Use the credentials to generate the pre-signed URLs.
- D. Generate an access key and a secret key for an IAM user that has S3:GetObject permissions on the S3 bucket. Embed the keys into the script. Use the keys to generate the pre-signed URLs.

Answer: B

Explanation

Amazon S3 pre-signed URLs grant temporary access based on the permissions of the principal that generates them. AWS Certified Security – Specialty documentation explains that fine-grained authorization can be enforced by combining pre-signed URLs with IAM policy conditions.

By tagging each invoice object with a client identifier and adding a condition to the EC2 instance role policy using s3:ResourceTag/ClientId, the role can generate pre-signed URLs only for objects associated with a specific client. This ensures that each client can access only their own invoices, even though the URLs are temporary and unauthenticated.

Option A over-permissions clients. Option C is unnecessary because instance profiles already use temporary credentials. Option D violates AWS best practices by using long-term credentials.

AWS recommends resource tagging with IAM policy conditions for scalable, secure access control.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Pre-Signed URLs

IAM Policy Conditions and Resource Tags

Question #:28 - [Infrastructure Security]

A company has two AWS accounts: Account A and Account B. Each account has a VPC. An application that runs in the VPC in Account A needs to write to an Amazon S3 bucket in Account B. The application in Account A already has permission to write to the S3 bucket in Account B. The application and the S3 bucket are in the same AWS Region. The company cannot send network traffic over the public internet.

Which solution will meet these requirements?

- A. In both accounts, create a transit gateway and VPC attachments in a subnet in each Availability Zone. Update the VPC route tables.
- B. Deploy a software VPN appliance in Account A. Create a VPN connection between the software VPN appliance and a virtual private gateway in Account B.
- C. Create a VPC peering connection between the VPC in Account A and the VPC in Account B. Update the VPC route tables, network ACLs, and security groups to allow network traffic between the peered IP ranges.
- D. In Account A, create a gateway VPC endpoint for Amazon S3. Update the VPC route table in Account A.

Answer: D

Explanation

To keep S3 access off the public internet, the standard AWS approach is to use an Amazon S3 gateway VPC endpoint (AWS PrivateLink for S3 is not used; S3 uses gateway endpoints). A gateway endpoint adds routes in the VPC route tables so traffic destined for S3 stays on the AWS backbone network rather than traversing an internet gateway, NAT gateway, or public IP paths. This satisfies the “cannot send traffic over the public internet” requirement while allowing the application in Account A to reach S3 in the same Region.

Cross-account bucket access is controlled by IAM and the S3 bucket policy, not by networking between the two accounts’ VPCs. The bucket resides in S3 (a regional service), not inside Account B’s VPC, so connecting VPC-to-VPC (peering, transit gateway, VPN) does not inherently provide private access to S3. Those options would add complexity and still typically require internet/NAT unless S3 endpoints are used.

With the gateway endpoint in Account A, the application can privately reach S3, and because permissions are already granted to write to the bucket in Account B, the write operations will succeed without public internet routing.

Question #:29 - [Infrastructure Security]

A company runs ECS services behind an internet-facing ALB that is the origin for CloudFront. An AWS WAF web ACL is associated with CloudFront, but clients can bypass it by accessing the ALB directly.

Which solution will prevent direct access to the ALB?

- A. Use AWS PrivateLink with the ALB.
- B. Replace the ALB with an internal ALB.
- C. Restrict ALB listener rules to CloudFront IP ranges.
- D. Require a custom header from CloudFront and validate it at the ALB.

Answer: D



Explanation

AWS best practices recommend using a shared secret header between CloudFront and ALB origins to prevent direct access. CloudFront injects a custom header, and the ALB listener rules validate its presence.

IP-based controls are brittle due to CloudFront IP changes. PrivateLink and internal ALBs are not supported as CloudFront origins. Header validation is the most reliable and widely recommended pattern.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

CloudFront Origin Protection

AWS WAF and ALB Integration

Question #:30 - [Data Protection]

A company uses AWS Organizations. The company has teams that use an AWS CloudHSM hardware security module (HSM) that is hosted in a central AWS account. One of the teams creates its own new dedicated AWS account and wants to use the HSM that is hosted in the central account.

How should a security engineer share the HSM that is hosted in the central account with the new dedicated account?

- A. Use AWS Resource Access Manager (AWS RAM) to share the VPC subnet ID of the HSM that is hosted in the central account with the new dedicated account. Configure the CloudHSM security group to accept inbound traffic from the private IP addresses of client instances in the new dedicated account.
- B. Use AWS Identity and Access Management (IAM) to create a cross-account role to access the CloudHSM cluster that is in the central account. Create a new IAM user in the new dedicated account. Assign the cross-account role to the new IAM user.
- C. Use AWS IAM Identity Center to create an AWS Security Token Service (AWS STS) token to authenticate from the new dedicated account to the central account. Use the cross-account permissions that are assigned to the STS token to invoke an operation on the HSM in the central account.
- D. Use AWS Resource Access Manager (AWS RAM) to share the ID of the HSM that is hosted in the central account with the new dedicated account. Configure the CloudHSM security group to accept inbound traffic from the private IP addresses of client instances in the new dedicated account.

Answer: D

Explanation

AWS CloudHSM is a VPC-scoped service: the HSMs (and the CloudHSM cluster) live inside a VPC in the central account, and clients connect over the network to perform cryptographic operations. When another account needs to use a centrally managed CloudHSM cluster, the right approach is to share the CloudHSM cluster with that account and allow network connectivity from the consuming account's clients. AWS provides

cross-account resource sharing through AWS Resource Access Manager (AWS RAM) for supported resources, including CloudHSM clusters. Sharing the cluster/HSM identifier is what grants the consuming account visibility/ability to create client configurations against that shared cluster.

After sharing, the consuming account's EC2 instances (CloudHSM clients) still must be able to reach the HSM ENIs over the network, so the CloudHSM security group in the central account must allow inbound connections from the client sources (typically by security group referencing via VPC connectivity, or by allowing the relevant IP range/ports as appropriate).

Option A is incorrect because sharing a subnet ID does not share the CloudHSM resource itself. Options B and C misuse IAM/STS: CloudHSM cryptographic operations are not granted via assuming an IAM role into the central account; access is based on cluster sharing + network connectivity + CloudHSM user authentication at the HSM level.

Question #:31 - [Incident Response]

A company's security engineer receives an abuse notification from AWS indicating that malware is being hosted from the company's AWS account. The security engineer discovers that an IAM user created a new Amazon S3 bucket without authorization.

Which combination of steps should the security engineer take to MINIMIZE the consequences of this compromise? (Select THREE.)

- A. Encrypt all AWS CloudTrail logs.
- B. Turn on Amazon GuardDuty.
- C. Change the password for all IAM users.
- D. Rotate or delete all AWS access keys.
- E. Take snapshots of all Amazon Elastic Block Store (Amazon EBS) volumes.
- F. Delete any resources that are unrecognized or unauthorized.

Answer: B D F

Explanation

AWS incident response guidance emphasizes immediate containment, credential invalidation, and removal of malicious resources. According to the AWS Certified Security – Specialty documentation, compromised credentials must be rotated or deleted immediately to prevent further unauthorized actions. Rotating or deleting access keys directly mitigates ongoing abuse.

Deleting unrecognized or unauthorized resources, such as the malicious S3 bucket, removes the active threat and limits further damage. Enabling Amazon GuardDuty provides continuous monitoring and helps identify additional compromised resources or malicious behavior that may not yet be visible.

Changing passwords for all IAM users is disruptive and unnecessary if compromise scope is limited. Encrypting CloudTrail logs does not reduce active impact. Taking EBS snapshots is primarily for forensic investigation, not immediate consequence minimization.

AWS best practices recommend GuardDuty activation, credential rotation, and removal of malicious resources as first-response actions.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Incident Response Best Practices

Amazon GuardDuty Threat Detection

Question #:32 - [Data Protection]

A company is using Amazon Elastic Container Service (Amazon ECS) to deploy an application that deals with sensitive data. During a recent security audit, the company identified a security issue in which Amazon RDS credentials were stored with the application code in the company 's source code repository. A security engineer needs to develop a solution to ensure that database credentials are stored securely and rotated periodically. The credentials should be accessible to the application only. The engineer also needs to prevent database administrators from sharing database credentials as plaintext with other teammates. The solution must also minimize administrative overhead.

Which solution meets these requirements?

- A. Use the AWS Systems Manager Parameter Store to generate database credentials. Use an IAM profile for ECS tasks to restrict access to database credentials to specific containers only.
- B. Use AWS Secrets Manager to store database credentials. Use an IAM inline policy for ECS tasks to restrict access to database credentials to specific containers only.
- C. Use the AWS Systems Manager Parameter Store to store database credentials. Use IAM roles for ECS tasks to restrict access to database credentials to specific containers only.
- D. Use AWS Secrets Manager to store database credentials. Use IAM roles for ECS tasks to restrict access to database credentials to specific containers only.

Answer: D

Explanation

AWS Secrets Manager is the AWS service designed to store secrets securely and to support automatic rotation on a schedule—commonly used for Amazon RDS credentials. Storing credentials in Secrets Manager removes them from source code, enables fine-grained access control, and supports auditability of secret retrieval through CloudTrail. Rotation can be configured to periodically change the database password and update the stored secret automatically, minimizing operational overhead compared to manual rotation processes.

To ensure the credentials are accessible only to the application, the correct ECS pattern is to use IAM roles for tasks. A task role can be scoped to allow only `secretsmanager:GetSecretValue` (and related actions if needed) for the specific secret ARN. Only tasks running with that role can retrieve the secret at runtime, which prevents broad access. This also helps reduce the risk of database administrators sharing plaintext credentials, because the recommended operational model is that humans should not need direct access; the application retrieves the secret programmatically, and access can be limited to break-glass workflows if required.

Systems Manager Parameter Store can store encrypted parameters, but Secrets Manager provides stronger native secret lifecycle features (notably rotation) for databases. Inline policies (Option B) are not necessary; managed or attached policies on the task role achieve the same goal with cleaner administration.

Question #:33 - [Identity and Access Management]

A company has multiple accounts in the AWS Cloud. Users in the developer account need to have access to specific resources in the production account.

What is the MOST secure way to provide this access?

- A. Create one IAM user in the production account. Grant the appropriate permissions to the resources that are needed. Share the password only with the users that need access.
- B. Create cross-account access with an IAM role in the developer account. Grant the appropriate permissions to this role. Allow users in the developer account to assume this role to access the production resources.
- C. Create cross-account access with an IAM user account in the production account. Grant the appropriate permissions to this user account. Allow users in the developer account to use this user account to access the production resources.
- D. Create cross-account access with an IAM role in the production account. Grant the appropriate permissions to this role. Allow users in the developer account to assume this role to access the production resources.

Answer: D

Explanation

The most secure and AWS-recommended pattern for cross-account access is to create an IAM role in the target account (production) and allow trusted principals from the source account (developer) to assume the role by using AWS STS. This avoids long-term credentials in the production account, supports short-lived session credentials, and enables strong controls such as MFA requirements, session duration limits, and precise least-privilege permissions attached to the role. It also centralizes ownership of production permissions in the production account, which is important for separation of duties and governance.

Option A is insecure because it requires password sharing and uses a long-lived IAM user credential, which is against AWS best practices. Option C is also poor because it relies on a long-lived IAM user in the production account and encourages credential sharing/duplication. Option B places the role in the developer account;

while you can attach permissions there, access to production resources is governed by the production account. The standard approach is a production-account role with a trust policy that names the developer account principals (or a role) as allowed to assume it. Therefore, Option D is the most secure solution.

Question #:34 - [Identity and Access Management]

A company allows users to download its mobile app onto their phones. The app is MQTT based and connects to AWS IoT Core to subscribe to specific client-related topics. Recently, the company discovered that some malicious attackers have been trying to get a Trojan horse onto legitimate mobile phones. The Trojan horse poses as the authentic application and uses a client ID with injected special characters to gain access to topics outside the client ' s privilege scope.

Which combination of actions should the company take to prevent this threat? (Select TWO.)

- A. In the application, use an IoT thing name as the client ID to connect the device to AWS IoT Core.
- B. In the application, add a client ID check. Disconnect from the server if any special character is detected.
- C. Apply an AWS IoT Core policy that allows " AWSIoTWirelessDataAccess " with the principal set to " client/\${iot:Connection.Thing.ThingName} " .
- D. Apply an AWS IoT Core policy to the device to allow " iot:Connect " with the resource set to " client /\${iot:ClientId} " .
- E. Apply an AWS IoT Core policy to the device to allow " iot:Connect " with the resource set to " client /\${iot:Connection.Thing.ThingName} " .

Answer: A E

Explanation

The threat is client ID manipulation to break authorization boundaries. The strongest control is to bind the MQTT client identity to the authenticated device identity(the Thing) rather than trusting arbitrary client IDs provided by the client. Using the Thing name as the client ID(Option A) removes ambiguity and makes the identifier predictable and tied to a registered identity.

On the authorization side, AWS IoT Core policies can use policy variables. Allowing iot:Connect only when the resource matches client/\${iot:Connection.Thing.ThingName} (Option E) ensures the connection is permitted only if the client ID exactly equals the authenticated Thing name from the TLS certificate/Thing principal context. This prevents attackers from injecting special characters or choosing a different client ID to escalate access, because the policy evaluation ties the allowed client resource to the Thing identity, not the attacker-controlled string.

Option D is weaker because it effectively allows whatever client ID is presented (it matches the same value the client supplies), so it does not prevent crafted client IDs from being used. Option C is unrelated to the described MQTT connect authorization (and references an action not aligned with the scenario). Option B is an application-side check and can be bypassed by a malicious client; enforcement must be at AWS IoT Core policy level.

Question #:35 - [Security Foundations and Governance]

A company needs to build a code-signing solution using an AWS KMS asymmetric key and must store immutable evidence of key creation and usage for compliance and audit purposes.

Which solution meets these requirements?

- A. Create an Amazon S3 bucket with S3 Object Lock enabled. Create an AWS CloudTrail trail with log file validation enabled for KMS events. Store logs in the bucket and grant auditors access.
- B. Log application events to Amazon CloudWatch Logs and export them.
- C. Capture KMS API calls using EventBridge and store them in DynamoDB.
- D. Track KMS usage with CloudWatch metrics and dashboards.

Answer: A

Explanation

AWS CloudTrail provides authoritative records of KMS key creation, origin, and usage. Enabling log file validation ensures tamper detection. S3 Object Lock in compliance mode enforces immutability, which is a core audit requirement cited in AWS Certified Security – Specialty materials.

CloudWatch and DynamoDB do not provide immutable storage guarantees suitable for compliance evidence.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS CloudTrail Log File Validation

Amazon S3 Object Lock

Question #:36 - [Identity and Access Management]

A company's developers are using AWS Lambda function URLs to invoke functions directly. The company must ensure that developers cannot configure or deploy unauthenticated functions in production accounts. The company wants to meet this requirement by using AWS Organizations. The solution must not require additional work for the developers.

Which solution will meet these requirements?

- A. Require the developers to configure all function URLs to support cross-origin resource sharing (CORS) when the functions are called from a different domain.
- B. Use an AWS WAF delegated administrator account to view and block unauthenticated access to function URLs in production accounts, based on the OU of accounts that are using the functions.

- C. Use SCPs to allow all `lambda:CreateFunctionUrlConfig` and `lambda:UpdateFunctionUrlConfig` actions that have a `lambda:FunctionUrlAuthType` condition key value of `AWS_IAM`.
- D. Use SCPs to deny all `lambda:CreateFunctionUrlConfig` and `lambda:UpdateFunctionUrlConfig` actions that have a `lambda:FunctionUrlAuthType` condition key value of `NONE`.

Answer: D

Explanation

AWS Organizations service control policies (SCPs) are designed to enforce preventive guardrails across accounts without requiring application-level changes. According to the AWS Certified Security – Specialty documentation, SCPs can restrict specific API actions or require certain condition keys to enforce security standards centrally. AWS Lambda function URLs support two authentication modes: `AWS_IAM` and `NONE`. When the authentication type is set to `NONE`, the function URL becomes publicly accessible, which introduces a significant security risk in production environments.

By using an SCP that explicitly denies the `lambda:CreateFunctionUrlConfig` and `lambda:UpdateFunctionUrlConfig` actions when the `lambda:FunctionUrlAuthType` condition key equals `NONE`, the organization ensures that unauthenticated function URLs cannot be created or modified in production accounts. This enforcement occurs at the AWS Organizations level and applies automatically to all accounts within the specified organizational units (OUs). Developers are not required to change their workflows or add additional controls, satisfying the requirement of no additional developer effort.

Option A relates to browser-based access controls and does not provide authentication or authorization enforcement. Option B is not valid because AWS WAF cannot be attached directly to AWS Lambda function URLs. Option C is incorrect because SCPs do not grant permissions; they only limit permissions. AWS documentation clearly states that SCPs define maximum available permissions and are evaluated before IAM policies.

This approach aligns with AWS best practices for centralized governance, least privilege, and preventive security controls.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Organizations Service Control Policies Documentation

AWS Lambda Security and Function URL Authentication Overview

Question #:37 - [Infrastructure Security]

A security engineer has designed a VPC to segment private traffic from public traffic. The VPC includes two Availability Zones. Each Availability Zone contains one public subnet and one private subnet. Three route tables exist: one for the public subnets and one for each private subnet.

The security engineer discovers that all four subnets are routing traffic through the internet gateway that is attached to the VPC.

Which combination of steps should the security engineer take to remediate this scenario? (Select TWO.)

- A. Verify that a NAT gateway has been provisioned in the public subnet in each Availability Zone.
- B. Verify that a NAT gateway has been provisioned in the private subnet in each Availability Zone.
- C. Modify the route tables for the public subnets to add a local route to the VPC CIDR range.
- D. Modify the route tables for the private subnets to route 0.0.0.0/0 to the NAT gateway in the public subnet of the same Availability Zone.
- E. Modify the route tables for the private subnets to route 0.0.0.0/0 to the internet gateway.

Answer: A D

Explanation

AWS networking best practices require private subnets to access the internet only through NAT gateways located in public subnets. According to the AWS Certified Security – Specialty Study Guide, NAT gateways must be provisioned in public subnets and used as the default route for outbound traffic from private subnets.

Verifying NAT gateways in each Availability Zone ensures high availability and fault tolerance. Updating the private subnet route tables to send 0.0.0.0/0 traffic to the NAT gateway prevents direct internet access while allowing outbound connectivity.

Routing private subnet traffic directly to an internet gateway violates subnet isolation principles. NAT gateways must never be placed in private subnets.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon VPC Routing and NAT Gateways

AWS Network Segmentation Best Practices

Question #:38 - [Security Foundations and Governance]

A company has AWS accounts in an organization in AWS Organizations. The organization includes a dedicated security account.

All AWS account activity across all member accounts must be logged and reported to the dedicated security account. The company must retain all the activity logs in a secure storage location within the dedicated security account for 2 years. No changes or deletions of the logs are allowed.

Which combination of steps will meet these requirements with the LEAST operational overhead? (Select TWO.)

- A. In the dedicated security account, create an Amazon S3 bucket. Configure S3 Object Lock in compliance mode with a retention period of 2 years. Set the bucket policy to allow the organization's management account to write to the S3 bucket.
- B. In the dedicated security account, create an Amazon S3 bucket. Configure S3 Object Lock in compliance mode with a retention period of 2 years. Set the bucket policy to allow the organization's member accounts to write to the S3 bucket.
- C. In the dedicated security account, create an Amazon S3 bucket with an S3 Lifecycle configuration that expires objects after 2 years. Allow member accounts to write to the bucket.
- D. Create an AWS CloudTrail organization trail. Configure logs to be delivered to the Amazon S3 bucket in the dedicated security account.
- E. Turn on AWS CloudTrail in each account and forward logs to the dedicated security account by using AWS Lambda and Amazon Data Firehose.

Answer: A D

Explanation

AWS CloudTrail organization trails are specifically designed to provide centralized, organization-wide logging with minimal operational effort. According to the AWS Certified Security – Specialty Official Study Guide, an organization trail records all management events for all member accounts and delivers them to a single Amazon S3 bucket.

To ensure that logs cannot be altered or deleted, Amazon S3 Object Lock in compliance mode must be used. Compliance mode enforces write-once-read-many (WORM) protection, meaning no user, including the root user, can delete or modify objects before the retention period expires. This directly satisfies the requirement that no changes or deletions are allowed for 2 years.

The S3 bucket must reside in the dedicated security account to provide isolation and strong security boundaries. Granting write permissions to the organization's management account (Option A) aligns with AWS best practices, because the management account owns and manages the organization trail and centrally delivers logs on behalf of all member accounts.

Option B increases attack surface by allowing all member accounts to write directly. Option C does not meet immutability requirements because lifecycle policies do not prevent deletion. Option E introduces unnecessary services and operational complexity.

AWS documentation explicitly identifies the combination of CloudTrail organization trails + S3 Object Lock (compliance mode) as the recommended, lowest-overhead solution for long-term, immutable audit log retention.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS CloudTrail Organization Trail Documentation

- ▶ Amazon S3 Object Lock Documentation
- ▶ AWS Well-Architected Framework – Security Pillar

Question #:39 - [Data Protection]

A company has an encrypted Amazon Aurora DB cluster in the us-east-1 Region that uses an AWS KMS customer managed key. The company must copy a DB snapshot to the us-west-1 Region but cannot access the encryption key across Regions.

What should the company do to properly encrypt the snapshot in us-west-1?

- A. Store the customer managed key in AWS Secrets Manager in us-west-1.
- B. Create a new customer managed key in us-west-1 and use it to encrypt the snapshot.
- C. Create an IAM policy to allow access to the key in us-east-1 from us-west-1.
- D. Create an IAM policy that allows RDS in us-west-1 to access the key in us-east-1.

Answer: B

Explanation

AWS KMS keys are strictly regional resources. According to AWS Certified Security – Specialty documentation, a KMS key created in one Region cannot be used to encrypt or decrypt data in another Region. This includes encrypted RDS and Aurora snapshots.

When copying an encrypted snapshot to a different Region, the destination Region must have its own KMS key. AWS automatically re-encrypts the snapshot using the specified KMS key in the destination Region during the copy operation.

Options C and D are invalid because IAM policies cannot extend a KMS key's scope across Regions. Option A is incorrect because Secrets Manager does not store or manage KMS keys themselves.

AWS best practices require creating a new customer managed key in the target Region and using it during the snapshot copy process.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Regional Key Limitations

Amazon RDS Encrypted Snapshot Copy

Question #:40 - [Infrastructure Security]

A company uses an organization in AWS Organizations to manage multiple AWS accounts. A security engineer creates a WAF policy in AWS Firewall Manager in the us-east-1 Region. The security engineer sets the policy scope to apply to resources that are tagged with WAF-protected:true in one of the member accounts in the organization. The security engineer sets up a configuration to automatically remediate any noncompliant resources.

In a member account, the security engineer attempts to protect an Amazon API Gateway REST API in the us-east-1 Region by using a web ACL. However, after several minutes, the REST API is still not associated with the web ACL.

What is the likely cause of this issue?

- A. Web ACLs cannot be applied to REST APIs.
- B. The REST API is missing a tag that includes the WAF-protected key and a value of true.
- C. The web ACL is already associated with another REST API.
- D. The web ACL is already associated with an Amazon CloudFront distribution.

Answer: B

Explanation

AWS Firewall Manager applies and enforces AWS WAF protections based on the policy scope you define. In this scenario, the policy is explicitly scoped to only those resources that have the tag key WAF-protected with a value of true. If the API Gateway REST API does not have that exact tag (correct key, correct value, correct spelling/case), Firewall Manager will treat the resource as out of scope. Out-of-scope resources are not evaluated for compliance and are not remediated, so the expected automatic association of the web ACL will never occur.

This is the most common reason for “nothing happens” when Firewall Manager is configured with tag-based scoping: the resource is missing the tag, the value is different (for example “True” vs “true”), or the tag was applied to a different resource than the one Firewall Manager evaluates.

Option A is incorrect because AWS WAF web ACLs can protect API Gateway REST APIs (regional). Option C is not a blocker because a web ACL can generally be associated with multiple resources (within the supported scope). Option D is irrelevant to preventing association here; CloudFront uses a global scope and does not inherently block regional associations.

Question #:41 - [Detection]

A company recently set up Amazon GuardDuty and is receiving a high number of findings from IP addresses within the company. A security engineer has verified that these IP addresses are trusted and allowed.

Which combination of steps should the security engineer take to configure GuardDuty so that it does not produce findings for these IP addresses? (Select TWO.)

- A. Create a plaintext configuration file that contains the trusted IP addresses.

- B. Create a JSON configuration file that contains the trusted IP addresses.
- C. Upload the configuration file directly to GuardDuty.
- D. Upload the configuration file to Amazon S3. Add a new trusted IP list to GuardDuty that points to the file.
- E. Manually copy and paste the configuration file data into the trusted IP list in GuardDuty.

Answer: A D

Explanation

GuardDuty supports “Trusted IP lists” to suppress findings that would otherwise be generated for activity originating from known safe IP addresses (for example, corporate NAT egress IPs, security scanners, or monitoring systems). To use a trusted IP list, you create a plaintext file that contains the IP addresses (typically one per line or in supported list form) and store it in Amazon S3. You then configure GuardDuty to reference that S3 object as a trusted IP list. GuardDuty periodically retrieves the file from S3 and uses it to adjust finding generation accordingly.

That maps directly to Option A (create a plaintext file) and Option D (upload to S3 and create a trusted IP list in GuardDuty pointing to the file).

Options B and E are incorrect because GuardDuty trusted IP lists are not configured by pasting JSON into the console; they are sourced from an S3-hosted text list. Option C is not supported because GuardDuty does not accept direct file uploads into the service as the configuration source; S3 is the expected integration point for IP lists and threat intel lists.

Question #:42 - [Security Foundations and Governance]

A company is expanding its group of stores. On the day that each new store opens, the company wants to launch a customized web application for that store. Each store's application will have a non-production environment and a production environment. Each environment will be deployed in a separate AWS account. The company uses AWS Organizations and has an OU that is used only for these accounts.

The company distributes most of the development work to third-party development teams. A security engineer needs to ensure that each team follows the company's deployment plan for AWS resources. The security engineer also must limit access to the deployment plan to only the developers who need access. The security engineer already has created an AWS CloudFormation template that implements the deployment plan.

What should the security engineer do next to meet the requirements in the MOST secure way?

- A. Create an AWS Service Catalog portfolio in the organization's management account. Upload the CloudFormation template. Add the template to the portfolio's product list. Share the portfolio with the OU.
- B. Use the CloudFormation CLI to create a module from the CloudFormation template. Register the module as a private extension in the CloudFormation registry. Publish the extension. In the OU, create an SCP that allows access to the extension.

- C. Create an AWS Service Catalog portfolio in the organization 's management account. Upload the CloudFormation template. Add the template to the portfolio 's product list. Create an IAM role that has a trust policy that allows cross-account access to the portfolio for users in the OU accounts. Attach the AWSServiceCatalogEndUserFullAccess managed policy to the role.
- D. Use the CloudFormation CLI to create a module from the CloudFormation template. Register the module as a private extension in the CloudFormation registry. Publish the extension. Share the extension with the OU.

Answer: A

Explanation

AWS Service Catalog is designed to allow organizations to create and manage approved sets of CloudFormation templates, known as products, and make them available to specific accounts or organizational units (OUs). According to the AWS Certified Security – Specialty Study Guide, Service Catalog is the preferred governance mechanism for enforcing standardized infrastructure deployments while maintaining strong access controls.

By creating a Service Catalog portfolio in the management account and sharing it with a specific OU, the security engineer ensures that only accounts within that OU can deploy the approved CloudFormation template. This guarantees that third-party developers can deploy infrastructure only in accordance with the company's predefined deployment plan, without modifying or directly accessing the template itself.

Option B and D use CloudFormation modules, which are intended for reusable resource definitions but do not provide the same level of deployment governance, access control, and lifecycle management as Service Catalog. Option C introduces unnecessary cross-account IAM roles, increasing the attack surface and operational complexity, which violates the "most secure" requirement.

AWS documentation explicitly states that Service Catalog is the recommended service for distributing standardized CloudFormation templates across AWS Organizations, while controlling who can deploy them and where.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Service Catalog Administrator Guide
- ▶ AWS Organizations Best Practices
- ▶ AWS Well-Architected Framework – Security Pillar

Question #:43 - [Detection]

A company runs several applications on Amazon Elastic Kubernetes Service (Amazon EKS). The company needs a solution to detect any Kubernetes security risks by monitoring Amazon EKS audit logs in addition to operating system, networking, and file events. The solution must send email alerts for any identified risks to a mailing list that is associated with a security team.

Which solution will meet these requirements?



- A. Deploy AWS Security Hub and enable security standards that contain EKS controls. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant Security Hub events to the SNS topic.
- B. Enable Amazon Inspector container image scanning. Configure Amazon Detective to analyze EKS security logs. Create Amazon CloudWatch log groups for EKS audit logs. Use an AWS Lambda function to process the logs and to send email alerts to the security team.
- C. Enable Amazon GuardDuty. Enable EKS Protection and Runtime Monitoring for Amazon EKS in GuardDuty. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant GuardDuty events to the SNS topic.
- D. Install the AWS Systems Manager Agent (SSM Agent) on all EKS nodes. Configure Amazon CloudWatch Logs to collect EKS audit logs. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team's mailing list as a subscriber. Configure a CloudWatch alarm to publish a message to the SNS topic when new audit logs are generated.

Answer: C

Explanation

Option C is the best fit because Amazon GuardDuty provides managed threat detection for EKS by analyzing EKS control plane audit logs (EKS Protection) and correlating those signals with runtime telemetry (Runtime Monitoring) that includes process/OS activity, network connections, and file activity on the worker nodes. This directly matches the requirement to monitor EKS audit logs in addition to operating system, networking, and file events to detect Kubernetes security risks.

GuardDuty produces security findings for suspicious Kubernetes behavior and runtime indicators (for example, unexpected API calls, anomalous container activity, or known malicious behaviors). To notify the security team, an Amazon EventBridge rule can match GuardDuty findings and forward them to an SNS topic. SNS supports email subscriptions, so the team's mailing list can receive near-real-time alerts without building a custom log parsing pipeline.

Option A (Security Hub) aggregates findings and maps to controls/standards but does not itself provide the combined audit-log + runtime event detection described. Option B combines unrelated services and still requires custom processing. Option D only alarms on "new audit logs generated," which does not detect "security risks" and does not include OS/network/file threat detections.

Question #:44 - [Detection]

A company needs to scan all AWS Lambda functions for code vulnerabilities.

- A. Use Amazon Macie.
- B. Enable Amazon Inspector Lambda scanning.
- C. Use GuardDuty and Security Hub.
- D. Use GuardDuty Lambda Protection.

Answer: B

Explanation

Amazon Inspector provides native Lambda code vulnerability scanning. GuardDuty focuses on runtime threats, not static code analysis.

Question #:45 - [Data Protection]

A security administrator is setting up a new AWS account. The security administrator wants to secure the data that a company stores in an Amazon S3 bucket. The security administrator also wants to reduce the chance of unintended data exposure and the potential for misconfiguration of objects that are in the S3 bucket.

Which solution will meet these requirements with the LEAST operational overhead?

- A. Configure the S3 Block Public Access feature for the AWS account.
- B. Configure the S3 Block Public Access feature for all objects that are in the bucket.
- C. Deactivate ACLs for objects that are in the bucket.
- D. Use AWS PrivateLink for Amazon S3 to access the bucket.

Answer: A

Explanation

Amazon S3 Block Public Access configured at the AWS account level is the recommended and most effective approach to protect data stored in Amazon S3 while minimizing operational overhead. AWS Security Specialty documentation explains that S3 Block Public Access provides centralized, preventative controls designed to block public access to S3 buckets and objects regardless of individual bucket policies or object-level ACL configurations. When enabled at the account level, these controls automatically apply to all existing and newly created buckets, significantly reducing the risk of accidental exposure caused by misconfigured permissions.

The AWS Certified Security – Specialty Study Guide emphasizes that public access misconfiguration is a leading cause of data leaks in cloud environments. Account-level S3 Block Public Access acts as a guardrail by overriding any attempt to grant public permissions through bucket policies or ACLs. This eliminates the need to manage security settings on a per-bucket or per-object basis, thereby reducing administrative complexity and human error.

Configuring Block Public Access at the object level, as in option B, requires continuous monitoring and manual configuration, which increases operational overhead. Disabling ACLs alone, as described in option C, does not fully prevent public access because bucket policies can still allow public permissions. Using AWS PrivateLink, as in option D, controls network access but does not protect against public exposure through misconfigured S3 policies.

AWS security best practices explicitly recommend enabling S3 Block Public Access at the account level as the primary mechanism for preventing unintended public data exposure with minimal management effort.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Security Best Practices Documentation

Amazon S3 Block Public Access Overview

AWS Well-Architected Framework – Security Pillar

Question #:46 - [Incident Response]

A security engineer needs to prepare Amazon EC2 instances for quarantine during a security incident. AWS Systems Manager Agent (SSM Agent) is installed, and a script exists to install and update forensic tools.

Which solution will quarantine EC2 instances during a security incident?

- A. Track SSM Agent versions with AWS Config.
- B. Configure Session Manager to deny external connections.
- C. Store the script in Amazon S3 and grant read access.
- D. Configure IAM permissions for the SSM Agent to run the script as a Systems Manager Run Command document.

Answer: D

Explanation

AWS Systems Manager Run Command enables secure, remote execution of commands on EC2 instances without requiring network access or inbound ports. According to the AWS Certified Security – Specialty Study Guide, Run Command is a recommended mechanism for incident response actions such as installing forensic tools, collecting evidence, or applying quarantine controls.

By granting the SSM Agent permission to execute a predefined Run Command document, the security engineer can immediately run the quarantine script across affected instances. This approach supports automation, scalability, and auditability, all of which are critical during security incidents.

Options A, B, and C do not directly enforce quarantine or execute response actions. Tracking versions and storing scripts alone do not trigger incident response.

AWS documentation highlights Systems Manager Run Command as a core capability for automated containment and investigation.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Systems Manager Run Command

AWS Incident Response Automation

Question #:47 - [Incident Response]

A company runs critical workloads in an on-premises data center. The company wants to implement an AWS based disaster recovery (DR) solution that will achieve an RTO of less than 1 hour. The company needs to continuously replicate physical and virtual servers. The company must optimize costs for data storage and bandwidth usage. The DR solution must be automated.

Which solution will meet these requirements?

- A. Use AWS Backup to directly replicate the on-premises servers to AWS. Enable cross-Region backup copying and data vaulting. Configure recovery points to match the defined RTO. Use AWS Step Functions to automate recovery steps.
- B. Configure an AWS Storage Gateway Volume Gateway to use Amazon Elastic Block Store (Amazon EBS) snapshots for recovery. Configure AWS Backup to manage the snapshots. Create automated recovery procedures.
- C. Enable AWS Elastic Disaster Recovery. Configure replication agents to continuously replicate each on-premises server. Enable the default staging area subnet configuration.
- D. Create an AWS Direct Connect connection between the on-premises data center and AWS. Configure Amazon EventBridge to monitor for failures and to invoke AWS Lambda functions that launch preconfigured Amazon EC2 instances from AMIs in the event of an incident.

Answer: C

Explanation

AWS Elastic Disaster Recovery (AWS DRS) is purpose-built for continuously replicating physical and virtual servers into AWS with low RTO/RPO. It uses lightweight replication agents to stream block-level changes to a low-cost staging area in AWS, which helps optimize storage costs (only the staging resources run continuously) and reduces bandwidth usage through efficient replication mechanisms. In a disaster or test, AWS DRS can automatically launch recovery instances in AWS based on a defined blueprint (instance types, networking, security groups), enabling rapid failover workflows that commonly meet sub-hour RTO objectives.

Option A is not the intended service model: AWS Backup protects AWS-native resources and does not “directly replicate” arbitrary on-prem servers as a continuous replication DR system. Option B (Storage Gateway Volume Gateway) can support backups of certain storage use cases via snapshots, but it is not a general continuous replication solution for diverse physical/virtual servers and may not meet the RTO requirement as directly as AWS DRS. Option D (Direct Connect + custom automation) can help with connectivity, but it does not provide continuous server replication by itself and would require significant custom engineering and ongoing operational effort.

Therefore, enabling AWS Elastic Disaster Recovery and configuring replication agents is the best automated, cost-optimized solution.

Question #:48 - [Detection]

A company is developing an application that runs across a combination of Amazon EC2 On-Demand Instances and Spot Instances. A security engineer needs to provide a logging solution that makes logs for all instances available from a single location. The solution must allow only a specific set of users to analyze the logs for event patterns. The users must be able to use SQL queries on the logs to perform root cause analysis.

Which solution will meet these requirements?

- A. Configure the EC2 instances to send application logs to a single Amazon CloudWatch Logs log group. Allow only specific users to access the log group. Use CloudWatch Logs Insights to query the log group.
- B. Configure the EC2 instances to send application logs to a single Amazon S3 bucket. Allow only specific users to access the S3 bucket. Use Amazon CloudWatch Logs Insights to query the log files in the S3 bucket.
- C. Configure each EC2 instance to send its application logs to its own specific Amazon CloudWatch Logs log group. Allow only specific users to access the log groups. Use Amazon Athena to query all the log groups.
- D. Configure the EC2 instances to send application logs to a single Amazon CloudWatch Logs log group. Grant Amazon Detective access to the log group. Allow only specific users to use Detective to analyze the logs.

Answer: A

Explanation

Amazon CloudWatch Logs provides a centralized, scalable service for collecting and storing logs from Amazon EC2 instances, regardless of whether the instances are On-Demand or Spot Instances. According to the AWS Certified Security – Specialty Official Study Guide, CloudWatch Logs is the recommended service for centralized log aggregation and near-real-time analysis of application and system logs.

By configuring all EC2 instances to send logs to a single CloudWatch Logs log group, the security engineer ensures that logs from all instances are available in one centralized location. Access to the log group can be restricted by using IAM policies, ensuring that only authorized users can view and analyze the logs.

CloudWatch Logs Insights provides a powerful query language with SQL-like syntax, enabling users to search, filter, aggregate, and analyze log data efficiently. This directly satisfies the requirement for SQL-style queries to identify event patterns and perform root cause analysis without requiring data movement or additional services.

Option B is incorrect because CloudWatch Logs Insights cannot query log files stored in Amazon S3. Option C is inefficient and operationally complex, as Athena cannot directly query CloudWatch Logs log groups. Option D is invalid because Amazon Detective is designed for security investigations using GuardDuty findings, not for general application log analysis.

AWS documentation explicitly states that CloudWatch Logs combined with CloudWatch Logs Insights is the most efficient and secure approach for centralized log analysis in EC2-based architectures.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon CloudWatch Logs Documentation
- ▶ CloudWatch Logs Insights Query Guide

Question #:49 - [Incident Response]

An ecommerce website was down for 1 hour following a DDoS attack. Users were unable to connect to the website during the attack period. The ecommerce company 's security team is worried about future potential attacks and wants to prepare for such events. The company needs to minimize downtime in its response to similar attacks in the future.

Which steps would help achieve this? (Select TWO.)

- A. Enable Amazon GuardDuty to automatically monitor for malicious activity and block unauthorized access.
- B. Subscribe to AWS Shield Advanced and reach out to AWS Support in the event of an attack.
- C. Use VPC Flow Logs to monitor network traffic and an AWS Lambda function to automatically block an attacker's IP using security groups.
- D. Set up an Amazon EventBridge rule to monitor the AWS CloudTrail events in real time, use AWS Config rules to audit the configuration, and use AWS Systems Manager for remediation.
- E. Use AWS WAF to create rules to respond to such attacks.

Answer: B E

Explanation

To minimize downtime during future DDoS events, the company should use services that provide active DDoS protection and rapid mitigation at scale. AWS Shield Advanced (Option B) is designed for enhanced DDoS protection for internet-facing applications. It provides expanded detection and mitigation capabilities, cost protection in certain cases, and—critically—access to the AWS DDoS Response Team (DRT) through AWS Support so the company can engage experts during an attack to reduce impact and restore availability faster.

In addition, AWS WAF (Option E) helps mitigate application-layer (Layer 7) attacks that often accompany DDoS events (such as HTTP floods, bot-driven abuse, and known exploit patterns). WAF can block or challenge suspicious requests, apply rate-based controls, and use managed rule groups to reduce malicious traffic before it reaches the origin, improving resilience and availability.

Option A is incorrect because GuardDuty is a detection service; it does not automatically block traffic. Option C (Flow Logs + Lambda + SG blocks) is slow and brittle for DDoS because attackers are often distributed across many IPs and can change rapidly; security group updates are not an effective DDoS mitigation strategy. Option D is more about configuration governance and remediation, not real-time DDoS traffic mitigation.

Question #:50 - [Detection]

A company needs centralized log monitoring with automatic detection across hundreds of AWS accounts.

Which solution meets these requirements with the LEAST operational effort?

- A. Designate a GuardDuty administrator account and enable protections.
- B. Centralize CloudWatch logs and use Inspector.
- C. Centralize CloudTrail logs and query with Athena.
- D. Stream logs to Kinesis and process with Lambda.

Answer: A

Explanation

Amazon GuardDuty provides fully managed threat detection across accounts when configured with delegated administration. EKS and RDS protections enable workload-aware detection with minimal setup.

Other solutions require custom pipelines and higher operational overhead.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty Multi-Account Architecture

Question #:51 - [Infrastructure Security]

A security engineer recently rotated the host keys for an Amazon EC2 instance. The security engineer is trying to access the EC2 instance by using the EC2 Instance Connect feature. However, the security engineer receives an error for failed host key validation. Before the rotation of the host keys, EC2 Instance Connect worked correctly with this EC2 instance.

What should the security engineer do to resolve this error?

- A. Import the key material into AWS Key Management Service (AWS KMS).
- B. Manually upload the new host key to the AWS trusted host keys database.
- C. Ensure that the AmazonSSMManagedInstanceCore policy is attached to the EC2 instance profile.
- D. Create a new SSH key pair for the EC2 instance.

Answer: B

Explanation

EC2 Instance Connect can perform server/host authenticity checks by validating the instance's SSH host key against a trusted host key source. When you rotate the instance's host keys, the host presents a new fingerprint. If the trusted host keys source still contains the old host key, connections that enforce host key verification will fail with a host key validation error. The fix is to update the trusted host key record so the new host key fingerprint is recognized as valid. Therefore, the correct action is to upload the new host key to the trusted host keys database used for EC2 Instance Connect host key verification.

Option A is unrelated: AWS KMS does not store or manage SSH host keys for EC2 Instance Connect validation. Option C is for AWS Systems Manager managed instances and has no effect on SSH host key validation. Option D rotates user/client authentication keys (SSH key pair used to log in) but does not resolve a failure that occurs specifically because the server host key changed and is no longer trusted. Updating the trusted host keys database restores the expected trust chain and allows Instance Connect to work again with the rotated host keys.

Question #:52 - [Infrastructure Security]

A company is operating an open-source software platform that is internet facing. The legacy software platform no longer receives security updates. The software platform operates using Amazon Route 53 weighted load balancing to send traffic to two Amazon EC2 instances that connect to an Amazon RDS cluster. A recent report suggests this software platform is vulnerable to SQL injection attacks, with samples of attacks provided. The company's security engineer must secure this system against SQL injection attacks within 24 hours. The security engineer's solution must involve the least amount of effort and maintain normal operations during implementation.

What should the security engineer do to meet these requirements?

- A. Create an Application Load Balancer with the existing EC2 instances as a target group. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the ALB. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to the ALB. Update security groups on the EC2 instances to prevent direct access from the internet.
- B. Create an Amazon CloudFront distribution specifying one EC2 instance as an origin. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the distribution. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to CloudFront.
- C. Obtain the latest source code for the platform and make the necessary updates. Test the updated code to ensure that the vulnerability has been mitigated, then deploy the patched version of the platform to the EC2 instances.
- D. Update the security group that is attached to the EC2 instances, removing access from the internet to the TCP port used by the SQL database. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the EC2 instances. Test to ensure the vulnerability has been mitigated, then restore the security group to the original setting.

Answer: A

Explanation



The fastest, least-effort way to mitigate SQL injection at the edge—without modifying legacy application code—is to place the application behind a component that supports AWS WAF and apply managed SQL injection protections. An Application Load Balancer integrates directly with AWS WAF, allowing the security engineer to deploy a web ACL (including AWS Managed Rules for SQL injection and custom patterns based on the provided samples) and immediately start blocking malicious payloads before they reach the EC2 instances and the database.

Option A also preserves normal operations during rollout: you can create the ALB, register the existing EC2 instances as targets, validate health checks and traffic behavior, apply WAF protections, and then shift Route 53 weighted records to the ALB with minimal downtime. Finally, tightening the EC2 security groups to prevent direct internet access ensures all inbound web traffic is forced through the ALB + WAF inspection point, reducing exposure quickly.

Option B is risky because it uses only one EC2 origin (reducing availability) and adds CloudFront origin configuration complexity under a 24-hour deadline. Option C requires code changes on unsupported software and is unlikely to be safely delivered in time. Option D is invalid because AWS WAF cannot be attached directly to EC2 instances, and changing DB-port exposure doesn't address SQL injection on the web layer.

Question #:53 - [Infrastructure Security]

A security engineer needs to configure DDoS protection for a Network Load Balancer (NLB) with an Elastic IP address. The security engineer wants to set up an AWS WAF web ACL with a rate-based rule statement to protect the NLB.

The security engineer needs to determine a rate limit that will not block legitimate traffic. The security engineer has configured the rule statement to aggregate based on the source IP address.

How should the security engineer configure the rule to protect the NLB?

- A. Configure the rule to use the `Count` action.
- B. Configure the rule to use the `Block` action.
- C. Configure the rule to use the `Monitor` action.
- D. Configure the rule to use the `Allow` action.

Answer: A

Explanation

AWS WAF rate-based rules are designed to help protect applications and resources from traffic floods and application-layer DDoS attacks by tracking the number of requests from individual source IP addresses over a rolling time window. According to the AWS Certified Security – Specialty Official Study Guide and AWS WAF documentation, rate-based rules can be configured with different actions, including `Count`, `Block`, and `Allow`.

When a security engineer is determining an appropriate rate limit that will not block legitimate traffic, AWS best practices recommend initially configuring the rate-based rule with the `Count` action. The `Count` action allows AWS WAF to monitor and log requests that exceed the specified rate threshold without actively

blocking them. This provides visibility into traffic patterns and enables the security engineer to analyze how the rule would behave in production.

By using the Count action, the security engineer can safely evaluate whether legitimate users would be affected by the chosen rate limit. Once the engineer is confident that the threshold accurately distinguishes between normal traffic and malicious behavior, the action can later be changed to Block.

Option B is incorrect because immediately blocking traffic without validation risks denying service to legitimate users. Option C is invalid because AWS WAF does not have a Monitor action. Option D is incorrect because the Allow action does not enforce rate limiting.

AWS documentation explicitly recommends starting rate-based rules in Count mode to fine-tune thresholds before enforcing blocks, especially for DDoS protection scenarios.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Developer Guide – Rate-Based Rules
- ▶ AWS DDoS Resiliency Best Practices

Question #:54 - [Security Foundations and Governance]

A security engineer wants to evaluate configuration changes to a specific AWS resource to ensure that the resource meets compliance standards. However, the security engineer is concerned about a situation in which several configuration changes are made to the resource in quick succession. The security engineer wants to record only the latest configuration of that resource to indicate the cumulative impact of the set of changes.

Which solution will meet this requirement in the MOST operationally efficient way?

- A. Use AWS CloudTrail to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.
- B. Use AWS Config to detect the configuration changes and to record the latest configuration in case of multiple configuration changes.
- C. Use Amazon CloudWatch to detect the configuration changes by filtering API calls to monitor the changes. Use the most recent API call to indicate the cumulative impact of multiple calls.
- D. Use AWS Cloud Map to detect the configuration changes. Generate a report of configuration changes from AWS Cloud Map to track the latest state by using a sliding time window.

Answer: B

Explanation

AWS Config is purpose-built to record resource configuration state and track how that state changes over time. When multiple updates occur close together, AWS Config captures configuration items that represent the resource's current recorded configuration, which is exactly what a compliance engineer needs to evaluate the final (cumulative) state after a burst of changes. AWS Config also integrates directly with compliance evaluation through Config rules, which can continuously assess whether the latest configuration meets

required standards. This is the most operationally efficient approach because it avoids building custom log filtering, state reconstruction, or timing logic.

CloudTrail and CloudWatch-based approaches (Options A and C) capture API events, not authoritative “current configuration state.” Reconstructing the final configuration from a series of API calls can be error-prone, especially when changes are made by different services, via consoles, or through chained automation. CloudTrail is excellent for “who did what and when,” but AWS Config is the service that maintains the latest configuration snapshots suitable for compliance posture evaluation.

AWS Cloud Map (Option D) is for service discovery and naming, not compliance configuration history. Therefore, AWS Config is the correct and most efficient solution.

Question #:55 - [Identity and Access Management]

A company uses AWS IAM Identity Center to manage access to its AWS accounts. The accounts are in an organization in AWS Organizations. A security engineer needs to set up delegated administration of IAM Identity Center in the organization's management account.

Which combination of steps should the security engineer perform in IAM Identity Center before configuring delegated administration? (Select THREE.)

- A. Grant least privilege access to the organization's management account.
- B. Create a new IAM Identity Center directory in the organization's management account.
- C. Set up a second AWS Region in the organization's management account.
- D. Create permission sets for use only in the organization's management account.
- E. Create IAM users for use only in the organization's management account.
- F. Create user assignments only in the organization's management account.

Answer: A D F

Explanation

Delegated administration for IAM Identity Center allows the organization to designate an account (or administrators) to manage Identity Center tasks without giving broad control to everyone in the management account. Before configuring delegated administration, the organization should ensure that appropriate administrative access is set up following least privilege (Option A) so only the intended administrators can manage Identity Center configuration and assignments.

Next, IAM Identity Center relies on permission sets and assignments (users/groups to accounts/permission sets) to deliver access through the AWS access portal. Creating the required permission sets (Option D) and establishing the necessary user assignments (Option F) in the management account provides the baseline Identity Center configuration that will be administered and delegated. These are core Identity Center primitives and are commonly prepared as part of initial setup so delegated admins have clearly defined roles and scope to manage.

Option B is not required because IAM Identity Center uses an identity source (such as AWS Directory Service, an external IdP, or the Identity Center directory) that is configured once; you don't typically "create a new directory" as a prerequisite for delegated admin unless you are changing identity sources. Option C is irrelevant; delegated administration is not dependent on adding a second Region. Option E is incorrect because IAM Identity Center is intended to reduce reliance on IAM users for workforce access, not require creating new IAM users.

Question #:56 - [Detection]

A company's web application runs on Amazon EC2 instances behind an Application Load Balancer (ALB) in an Auto Scaling group. An AWS WAF web ACL is associated with the ALB. Instance logs are lost after reboots. The operations team suspects malicious activity targeting a specific PHP file.

Which set of actions will identify the suspect attacker's IP address for future occurrences?

- A. Configure VPC Flow Logs and search for PHP file activity.
- B. Install the CloudWatch agent on the ALB and export application logs.
- C. Export ALB access logs to Amazon OpenSearch Service and search them.
- D. Configure the web ACL to send logs to Amazon Kinesis Data Firehose. Deliver logs to Amazon S3 and query them with Amazon Athena.

Answer: D

Explanation

AWS WAF logs contain detailed request-level information, including source IP addresses, requested URIs, and rule matches. According to AWS Certified Security – Specialty guidance, enabling AWS WAF logging provides the most reliable and tamper-resistant method to investigate web-based attacks, especially when instance-level logs are unavailable.

By streaming WAF logs through Amazon Kinesis Data Firehose to Amazon S3, the company ensures durable, centralized log storage that is independent of EC2 lifecycle events. Amazon Athena can then query the logs efficiently to identify repeated requests to the new-user-creation.php endpoint and extract attacker IP addresses.

VPC Flow Logs do not capture HTTP-level details. ALB access logs alone may not capture blocked requests. WAF logs provide the best forensic visibility for future detection.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS WAF Logging and Monitoring

Amazon Athena Log Analysis

Question #:57 - [Incident Response]

A security engineer for a company needs to design an incident response plan that addresses compromised IAM user account credentials. The company uses an organization in AWS Organizations and AWS IAM Identity Center to manage user access. The company uses a delegated administrator account to implement AWS Security Hub. The delegated administrator account contains an organizational trail in AWS CloudTrail that logs all events to an Amazon S3 bucket. The company has also configured an organizational event data store that captures all events from the trail.

The incident response plan must provide steps that the security engineer can take to immediately disable any compromised IAM user when the security engineer receives a notification of a security incident. The plan must prevent the IAM user from being used in any AWS account. The plan must also collect all AWS actions that the compromised IAM user performed across all accounts in the previous 7 days.

Which solution will meet these requirements?

- A. Disable the compromised IAM user in the organization management account. Use Amazon Athena to query the organizational CloudTrail logs in the S3 bucket for actions that the IAM user performed in the previous 7 days.
- B. Remove all IAM policies that are attached to the IAM user in the organization management account. Use AWS Security Hub to query the CloudTrail logs for actions that the IAM user performed in the previous 7 days.
- C. Remove any permission sets that are assigned to the IAM user in IAM Identity Center. Use Amazon CloudWatch Logs Insights to query the CloudTrail logs in the S3 bucket for actions that the IAM user performed in the previous 7 days.
- D. Disable the IAM user's access in IAM Identity Center. Use AWS CloudTrail to query the organizational event data store for actions that the IAM user performed in the previous 7 days.

Answer: D

Explanation

When AWS IAM Identity Center is used to manage user access across an AWS Organization, Identity Center is the authoritative control plane for enabling and disabling user access. According to the AWS Certified Security – Specialty Official Study Guide, disabling a user in IAM Identity Center immediately prevents that user from accessing any AWS account or role that is assigned through permission sets, satisfying the requirement to stop access organization-wide.

Disabling an IAM user in a single account or removing attached policies (Options A and B) does not prevent access through IAM Identity Center–managed roles in other accounts. Option C is incomplete because removing permission sets does not immediately disable authentication and still requires querying logs from an unsupported source.

For investigation and evidence collection, AWS CloudTrail organizational event data stores provide centralized, queryable access to all management and data events across all accounts in the organization. CloudTrail Lake enables security engineers to run SQL-based queries directly against event data without exporting logs to other services. This allows rapid collection of all actions that the compromised user performed during the last 7 days.

AWS documentation explicitly identifies the combination of IAM Identity Center for access revocation and CloudTrail Lake for organization-wide investigation as a best practice for identity-related incident response.

AWS Certified Security – Specialty Official Study Guide

AWS IAM Identity Center Documentation

AWS CloudTrail Lake User Guide

AWS Incident Response Best Practices

Question #:58 - [Detection]

A company runs several applications on Amazon Elastic Kubernetes Service (Amazon EKS). The company needs a solution to detect any Kubernetes security risks by monitoring Amazon EKS audit logs in addition to operating system, networking, and file events. The solution must send email alerts for any identified risks to a mailing list that is associated with a security team.

Which solution will meet these requirements?

- A. Deploy AWS Security Hub and enable security standards that contain EKS controls. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team 's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant Security Hub events to the SNS topic.
- B. Enable Amazon Inspector container image scanning. Configure Amazon Detective to analyze EKS security logs. Create Amazon CloudWatch log groups for EKS audit logs. Use an AWS Lambda function to process the logs and to send email alerts to the security team.
- C. Enable Amazon GuardDuty. Enable EKS Protection and Runtime Monitoring for Amazon EKS in GuardDuty. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team 's mailing list as a subscriber. Use an Amazon EventBridge rule to send relevant GuardDuty events to the SNS topic.
- D. Install the AWS Systems Manager Agent (SSM Agent) on all EKS nodes. Configure Amazon CloudWatch Logs to collect EKS audit logs. Create an Amazon Simple Notification Service (Amazon SNS) topic and set the security team 's mailing list as a subscriber. Configure a CloudWatch alarm to publish a message to the SNS topic when new audit logs are generated.

Answer: C

Explanation

Option C best meets the requirements because Amazon GuardDuty provides Kubernetes-focused threat detection for Amazon EKS by analyzing EKS control plane audit logs (EKS Protection) and combining that signal with runtime telemetry from the worker nodes (Runtime Monitoring). EKS audit logs capture Kubernetes API activity and authorization decisions, allowing GuardDuty to detect suspicious cluster actions such as unusual API calls, unexpected access patterns, or indicators of compromise within the cluster.

Runtime Monitoring extends coverage to operating system/process activity, network connections, and file activity on the nodes, which directly aligns with the need to monitor OS, networking, and file events in addition to audit logs.

For notifications, GuardDuty generates findings that can be delivered through Amazon EventBridge rules. EventBridge can route relevant GuardDuty findings to an Amazon SNS topic, and SNS can send email alerts to the security team by subscribing the team's mailing list to the topic. This approach is fully managed, near real time, and avoids building custom log-parsing pipelines while still providing actionable alerts based on GuardDuty's curated EKS threat detections.

Question #:59 - [Data Protection]

A company's data scientists use Amazon SageMaker with datasets stored in Amazon S3. Data older than 45 days must be removed according to policy.

Which action should enforce this policy?

- A. Configure an S3 Lifecycle rule to delete objects after 45 days.
- B. Create a Lambda function triggered on object upload to delete old data.
- C. Create a scheduled Lambda function to delete old objects monthly.
- D. Configure S3 Intelligent-Tiering.

Answer: A

Explanation

Amazon S3 Lifecycle rules are the native and most efficient way to enforce data retention policies. AWS Certified Security – Specialty documentation recommends lifecycle rules over custom automation to reduce operational complexity and failure risk.

Lifecycle rules automatically and reliably delete objects after a specified age, ensuring compliance without additional compute services. Lambda-based solutions increase cost and management overhead. Intelligent-Tiering manages storage cost, not data deletion.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Lifecycle Management

Question #:60 - [Infrastructure Security]

A company is running a containerized application on an Amazon Elastic Container Service (Amazon ECS) cluster that uses AWS Fargate. The application runs as several ECS services. The ECS services are in individual target groups for an internet-facing Application Load Balancer (ALB). The ALB is the origin for an Amazon CloudFront distribution. An AWS WAF web ACL is associated with the CloudFront distribution.

Web clients access the ECS services through the CloudFront distribution. The company learns that the web clients can bypass the web ACL and can access the ALB directly.

Which solution will prevent the web clients from directly accessing the ALB?

- A. Create an AWS PrivateLink endpoint. Specify the existing ALB as the target. Update the CloudFront distribution by setting the PrivateLink endpoint as the origin.
- B. Create a new internal ALB. Move all the ECS services to the internal ALB. Delete the internet-facing ALB. Update the CloudFront distribution by setting the internal ALB as the origin.
- C. Modify the listener rules for the existing ALB. Add a condition to forward only the requests that come from IP addresses in the CloudFront origin prefix list.
- D. Update the CloudFront distribution by adding an X-Shared-Secret custom header for the origin. Modify the listener rules for the existing ALB to forward only the requests in which the X-Shared-Secret header has the correct value.

Answer: D

Explanation

The correct solution is option D because it effectively prevents direct access to the internet-facing ALB while allowing legitimate traffic that originates from Amazon CloudFront. By configuring CloudFront to include a custom HTTP header (such as X-Shared-Secret) in all origin requests, and then configuring ALB listener rules to only forward requests that contain the expected header value, the ALB will reject any requests that bypass CloudFront.

This approach is a documented AWS best practice when CloudFront is placed in front of an ALB and AWS WAF is associated with the CloudFront distribution. AWS WAF only evaluates traffic that flows through CloudFront; therefore, preventing direct access to the ALB is critical to ensure that all requests are inspected by the web ACL.

Option A is invalid because CloudFront does not support AWS PrivateLink endpoints as origins. Option B is incorrect because CloudFront cannot use an internal ALB as an origin; CloudFront requires a publicly reachable origin. Option C is not recommended because CloudFront IP ranges change frequently, making IP-based allow lists operationally complex and error-prone, and AWS does not provide a supported CloudFront prefix list for ALB listener rules.

AWS Security Specialty guidance explicitly recommends using custom origin headers to restrict ALB access to CloudFront-only traffic, making option D the correct and secure solution.

Question #:61 - [Data Protection]

A company has an encrypted Amazon Aurora DB cluster in the us-east-1 Region. The DB cluster is encrypted with an AWS Key Management Service (AWS KMS) customer managed key. To meet compliance requirements, the company needs to copy a DB snapshot to the us-west-1 Region. However, when the company tries to copy the snapshot to us-west-1, the company cannot access the key that was used to encrypt the original database.

What should the company do to set up the snapshot in us-west-1 with proper encryption?

- A. Use AWS Secrets Manager to store the customer managed key in us-west-1 as a secret. Use this secret to encrypt the snapshot in us-west-1.
- B. Create a new customer managed key in us-west-1. Use this new key to encrypt the snapshot in us-west-1.
- C. Create an IAM policy that allows access to the customer managed key in us-east-1. Specify `arn:aws:kms:us-west-1:*` as the principal.
- D. Create an IAM policy that allows access to the customer managed key in us-east-1. Specify `arn:aws:rds:us-west-1:*` as the principal.

Answer: B

Explanation

AWS Key Management Service (KMS) customer managed keys are regional resources. According to the AWS Certified Security – Specialty Official Study Guide and KMS documentation, a KMS key created in one AWS Region cannot be used directly in another Region. When copying an encrypted Amazon Aurora DB snapshot across Regions, the destination Region must have access to a KMS key that exists in that Region.

Because the original KMS key resides in us-east-1, it cannot be accessed or referenced in us-west-1. The correct and supported approach is to create a new customer managed KMS key in us-west-1 and specify that key when performing the cross-Region snapshot copy. Amazon RDS automatically decrypts the snapshot using the source Region key and re-encrypts it using the destination Region key during the copy process.

Option A is invalid because KMS keys cannot be stored or transferred through AWS Secrets Manager. Options C and D are incorrect because IAM policies cannot grant cross-Region usage of a KMS key; KMS enforces strict regional boundaries regardless of IAM permissions.

AWS documentation clearly states that cross-Region encrypted snapshot copies require a KMS key in the destination Region, making this approach mandatory for compliance and encryption continuity.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Key Management Service Developer Guide
- ▶ Amazon Aurora Security Documentation

Question #:62 - [Detection]

Notify when IAM roles are modified.

- A. Use Amazon Detective.
- B. Use EventBridge with CloudTrail events.

- C. Use CloudWatch metric filters.
- D. Use CloudWatch subscription filters.

Answer: B

Explanation

EventBridge natively consumes CloudTrail management events and provides near-real-time notifications.

Question #:63 - [Data Protection]

A company must inventory sensitive data across all Amazon S3 buckets in all accounts from a single security account.

- A. Delegate Amazon Macie and Security Hub administration.
- B. Use Amazon Inspector with Security Hub.
- C. Use Inspector with Trusted Advisor.
- D. Use Macie with Trusted Advisor.

Answer: A

Explanation

Amazon Macie is the AWS service designed to discover and classify sensitive data in S3. Delegated administration enables centralized visibility across an organization. Security Hub aggregates Macie findings for a single-pane-of-glass view.

Inspector does not scan S3 data. Trusted Advisor is not a sensitive data discovery tool.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Macie Multi-Account Architecture

Question #:64 - [Security Foundations and Governance]

A company uses AWS IAM Identity Center to manage access to its AWS accounts. The accounts are in an organization in AWS Organizations. A security engineer needs to set up delegated administration of IAM Identity Center in the organization's management account.

Which combination of steps should the security engineer perform in IAM Identity Center before configuring delegated administration? (Select THREE.)

- A. Grant least privilege access to the organization 's management account.



- B. Create a new IAM Identity Center directory in the organization ' s management account.
- C. Set up a second AWS Region in the organization's management account.
- D. Create permission sets for use only in the organization ' s management account.
- E. Create IAM users for use only in the organization ' s management account.
- F. Create user assignments only in the organization ' s management account.

Answer: B D F

Explanation

AWS IAM Identity Center delegated administration requires foundational configuration to be completed in the organization's management account before delegation. According to the AWS Certified Security – Specialty documentation, IAM Identity Center must be enabled with a directory in the management account before any delegation can occur.

Permission sets must be created in the management account because they define the permissions that will later be delegated to member accounts. Additionally, user assignments must initially exist in the management account to establish baseline access control before delegation is configured.

Option A is too generic and not a required prerequisite step. Option C is unrelated to Identity Center delegation. Option E is incorrect because IAM Identity Center uses identities from its directory or external IdPs, not IAM users.

AWS guidance clearly outlines directory creation, permission set definition, and initial user assignments as mandatory preparatory steps for delegated administration.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Identity Center Delegated Administration

AWS Organizations and Identity Center Integration

Question #:65 - [Detection]

A company runs an application on a fleet of Amazon EC2 instances. The application is accessible to users around the world. The company associates an AWS WAF web ACL with an Application Load Balancer (ALB) that routes traffic to the EC2 instances.

A security engineer is investigating a sudden increase in traffic to the application. The security engineer discovers a significant amount of potentially malicious requests coming from hundreds of IP addresses in two countries. The security engineer wants to quickly limit the potentially malicious requests. The security engineer does not want to prevent legitimate users from accessing the application.

Which solution will meet these requirements?

- A. Use AWS WAF to implement a rate-based rule for all incoming requests.
- B. Use AWS WAF to implement a geographical match rule to block all incoming traffic from the two countries.
- C. Edit the ALB security group to include a geographical match rule to block all incoming traffic from the two countries.
- D. Add deny rules to the ALB security group that prohibit incoming requests from the IP addresses.

Answer: A

Explanation

A rate-based rule in AWS WAF is designed to quickly mitigate spikes and potential layer 7 floods by tracking request rates per originating IP and temporarily blocking (or counting/challenging, depending on configuration) IPs that exceed a defined threshold within a 5-minute rolling window. In this scenario, the malicious traffic is distributed across hundreds of IPs in two countries, and the application still needs to remain available globally for legitimate users. A rate-based rule provides fast, targeted throttling that reduces abusive request patterns without permanently blocking entire geographies. This aligns with “quickly limit” while minimizing collateral impact.

Blocking both countries with a geo match rule (Option B) would likely block legitimate users located in those countries, which violates the requirement. Security groups (Options C and D) cannot natively enforce geographic filtering, and they are not well suited for large, rapidly changing sets of public source IPs at the application layer. Additionally, WAF operates at layer 7 with richer matching (rate limiting, URI/header patterns, bot controls), which is the appropriate control point when the ALB already has a web ACL associated. Therefore, implementing an AWS WAF rate-based rule is the most effective and least disruptive immediate mitigation.

Question #:66 - [Data Protection]

A security team manages a company's AWS Key Management Service (AWS KMS) customer managed keys. Only members of the security team can administer the KMS keys. The company's application team has a software process that needs temporary access to the keys occasionally. The security team needs to provide the application team's software process with access to the keys.

Which solution will meet these requirements with the LEAST operational overhead?

- A. Export the KMS key material to an on-premises hardware security module (HSM). Give the application team access to the key material.
- B. Edit the key policy that grants the security team access to the KMS keys by adding the application team as principals. Revert this change when the application team no longer needs access.
- C. Create a key grant to allow the application team to use the KMS keys. Revoke the grant when the application team no longer needs access.

- D. Create a new KMS key by generating key material on premises. Import the key material to AWS KMS whenever the application team needs access. Grant the application team permissions to use the key.

Answer: C

Explanation

AWS KMS key grants are specifically designed to provide temporary, granular permissions to use customer managed keys without modifying key policies. According to the AWS Certified Security – Specialty Study Guide, grants are the preferred mechanism for delegating key usage permissions to AWS principals for short-term or programmatic access scenarios. Grants allow permissions such as Encrypt, Decrypt, or GenerateDataKey and can be created and revoked dynamically.

Using a key grant avoids the operational risk and overhead of editing key policies, which are long-term control mechanisms and should remain stable. AWS documentation emphasizes that frequent key policy changes increase the risk of misconfiguration and accidental privilege escalation. Grants can be revoked immediately when access is no longer required, ensuring strong adherence to the principle of least privilege.

Options A and D violate AWS security best practices because AWS KMS does not allow direct export of key material unless the key was explicitly created as an importable key, and exporting key material increases exposure risk. Option B requires manual policy changes and rollback, which introduces operational overhead and audit complexity.

AWS recommends key grants as the most efficient and secure way to provide temporary access to KMS keys for applications.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Key Policies and Grants Documentation

AWS KMS Best Practices

Question #:67 - [Identity and Access Management]

A company runs an online game on AWS. When players sign up for the game, their username and password credentials are stored in an Amazon Aurora database.

The number of users has grown to hundreds of thousands of players. The number of requests for password resets and login assistance has become a burden for the company 's customer service team.

The company needs to implement a solution to give players another way to log in to the game. The solution must remove the burden of password resets and login assistance while securely protecting each player 's credentials.

Which solution will meet these requirements?

- A. When a new player signs up, use an AWS Lambda function to automatically create an IAM access key and a secret access key.

- B. Migrate the player credentials from the Aurora database to AWS Secrets Manager.
- C. Configure Amazon Cognito user pools to federate access to the game with third-party identity providers (IdPs), such as social IdPs. Migrate the game 's authentication mechanism to Cognito.
- D. Issue API keys to new and existing players and use Amazon API Gateway for authentication.

Answer: C

Explanation

Amazon Cognito is a fully managed identity service that provides user authentication, authorization, and user management for web and mobile applications. According to AWS Certified Security – Specialty documentation, Cognito user pools are specifically designed to offload authentication responsibilities from applications while maintaining strong security controls.

By federating authentication with third-party identity providers (such as social IdPs), Cognito eliminates the need for the company to manage user passwords directly. This dramatically reduces password reset requests and customer service overhead, while also improving security through industry-standard authentication mechanisms, including MFA and token-based access.

Option A is insecure and incorrect because IAM access keys are not intended for end users. Option B simply relocates password storage and does not reduce operational burden. Option D uses API keys, which are not designed for user authentication and provide no identity verification.

AWS guidance clearly states that Amazon Cognito is the recommended service for scalable, secure user authentication, especially when reducing password management complexity is a requirement.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon Cognito User Pools Documentation
- ▶ AWS IAM Security Best Practices

Question #:68 - [Detection]

A security engineer needs to implement a logging solution that captures detailed information about objects in an Amazon S3 bucket. The solution must include details such as the IAM identity that makes the request and the time the object was accessed. The data must be structured and available in near real time.

Which solution meets these requirements?

- A. Enable Amazon S3 server access logging on the S3 bucket. Create a new S3 bucket to store the logs. Analyze the logs from the logging S3 bucket.
- B. Enable AWS CloudTrail data event logging. Create a new S3 bucket to store the logs. Analyze the logs from the logging S3 bucket.
- C. Configure AWS Config rules to log access to the objects stored in the S3 bucket.

D. Enable Amazon Macie to log access to the objects stored in the S3 bucket.

Answer: B

Explanation

AWS CloudTrail data event logging is the correct solution because it is specifically designed to capture detailed, structured, and near-real-time API activity for Amazon S3 object-level operations. When S3 data events are enabled, CloudTrail records actions such as GetObject, PutObject, and DeleteObject, along with critical context including the IAM principal, source IP address, event time, request parameters, and response elements. These logs are delivered in JSON format, making them highly structured and suitable for security analysis, SIEM integration, and automated detection workflows.

Amazon S3 server access logging (option A) provides basic request-level information but does not include full IAM identity context and is delivered with a significant delay, which does not meet the near-real-time requirement. AWS Config (option C) focuses on resource configuration changes and compliance evaluation; it does not log object-level access events. Amazon Macie (option D) is a data security service that uses machine learning to discover and classify sensitive data in S3 and generate findings for anomalous access patterns, but it is not a comprehensive access logging solution.

AWS Security Specialty documentation clearly states that CloudTrail data events are the authoritative mechanism for auditing S3 object-level access with identity attribution and precise timestamps, making option B the correct and best-practice answer

Question #:69 - [Detection]

A company 's public website consists of an Application Load Balancer (ALB), a set of Amazon EC2 instances that run a stateless application behind the ALB, and an Amazon DynamoDB table from which the application reads data. The company is concerned about malicious scanning and DDoS attacks. The company wants to impose a restriction in which each client IP address can read the data only 3 times in any 5-minute period.

Which solution will meet this requirement with the LEAST effort?

- A. Set up AWS WAF in front of the ALB. Create a rule that blocks requests that exceed the limit of 3 requests in any 5-minute period for each IP address.
- B. Create an AWS Lambda function based on an Amazon CloudWatch request. Configure the Lambda function to count the requests for each IP address in rolling 5-minute intervals and to provide notification if the count exceeds 3.
- C. Modify the EC2 application to count the source IP address of requests and calculate a rolling 5-minute sum. Return an error message if the count sum is greater than 3.
- D. Add source IP address and request time to the DynamoDB table. Add a 5-minute TTL setting based on request time. Change the read capacity of the DynamoDB table throughput to 3.

Answer: A

Explanation

This is a classic Layer 7 rate-limiting requirement tied to client IP and a time window, and AWS WAF provides this natively with rate-based rules. Placing AWS WAF in front of the ALB allows the company to count requests per source IP over a rolling window and take action (block, CAPTCHA/challenge, or count depending on configuration) once the threshold is exceeded. This approach mitigates scanning and application-layer request floods early, before requests consume EC2 or DynamoDB capacity, and it requires minimal custom code or operational work.

Options B and C require building and maintaining custom counting logic (either in Lambda or in the application), which increases complexity and risk of errors, and it also introduces operational overhead for scaling state tracking across many IPs. Option D is not appropriate: altering DynamoDB capacity does not enforce "per-IP reads," and storing per-request metadata in the same table is an anti-pattern that increases write load and complexity.

Therefore, using AWS WAF rate-based protection at the ALB is the least-effort, most effective solution.

Question #:70 - [Data Protection]

A company wants to establish separate AWS Key Management Service (AWS KMS) keys to use for different AWS services. The company's security engineer created the following key policy to allow the infrastructure deployment team to create encrypted Amazon Elastic Block Store (Amazon EBS) volumes by assuming the InfrastructureDeployment IAM role:

```
{
  "Version": "2012-10-17",
  "Id": "key-policy-ebs",
  "Statement": [
    {
      "Sid": "Enable IAM User Permissions",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456789012:root"
      },
      "Action": "kms:*",
      "Resource": "*"
    }
  ],
```

```
{  
  "Sid" : "Allow use of the key",  
  "Effect" : "Allow",  
  "Principal" : {  
    "AWS" : "arn:aws:iam::123456789012:role/aws-reserved/sso.amazonaws.com/InfrastructureDeployment"  
  },  
  "Action" : [  
    "kms:Encrypt",  
    "kms:Decrypt",  
    "kms:ReEncrypt*",  
    "kms:GenerateDataKey*",  
    "kms:DescribeKey",  
    "kms:CreateGrant",  
    "kms:ListGrants",  
    "kms:RevokeGrant"  
  ],  
  "Resource" : "*",  
  "Condition" : {  
    "StringEquals" : {  
      "kms:ViaService" : "ec2.us-west-2.amazonaws.com"  
    }  
  }  
}
```



The security engineer recently discovered that IAM roles other than the Infrastructure Deployment role used this key for other services.

Which change to the policy should the security engineer make to resolve these issues?

- A. In the statement block that contains the Sid " Allow use of the key " , under the Condition block, change StringEquals to StringLike.
- B. In the policy document, remove the statement block that contains the Sid " Enable IAM User Permissions " . Add key management policies to the KMS policy.
- C. In the statement block that contains the Sid " Allow use of the key " , under the Condition block, change the kms:ViaService value to ec2.us-east-1.amazonaws.com.
- D. In the policy document, add a new statement block that grants the kms:Disable* permission to the security engineer ' s IAM role.

Answer: A

Explanation

AWS KMS key policies can restrict how and when a key is used by applying conditions such as kms:ViaService, which limits usage to requests that originate from a specific AWS service. According to the AWS Certified Security – Specialty Official Study Guide and AWS KMS documentation, the kms:ViaService condition is evaluated against the service that calls KMS on behalf of the principal.

Using StringEquals with kms:ViaService restricts usage to exactly one service endpoint. However, AWS services can invoke KMS through service variants, internal endpoints, or additional service integrations. When StringEquals is used, these variations can unintentionally bypass the condition, allowing the key to be used by other services through different internal service paths.

Changing the condition operator from StringEquals to StringLike ensures that only EC2-related service calls that match the intended service pattern are allowed, while still preventing use by unrelated AWS services. This aligns with AWS guidance to use StringLike when service invocation patterns may vary.

Option B is incorrect because the root principal statement is required to retain administrative control over the key. Option C is invalid because changing Regions does not address unauthorized service usage. Option D does not restrict key usage and does not mitigate the issue.

AWS documentation explicitly recommends tightening condition operators in KMS key policies to prevent unintended service access while maintaining required functionality.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Key Management Service Developer Guide
- ▶ AWS KMS Key Policy Best Practices

AWS Config cannot deliver configuration snapshots to Amazon S3.

Which TWO actions will remediate this issue?

- A. Verify the S3 bucket policy allows config.amazonaws.com.
- B. Verify the IAM role has s3:GetBucketAcl and s3:PutObject permissions.
- C. Verify the S3 bucket can assume the IAM role.
- D. Verify IAM policy allows AWS Config to write logs.
- E. Modify AWS Config API permissions.

Answer: A B

Explanation

AWS Config requires permissions at two levels to deliver configuration data: the AWS Config service role and the S3 bucket policy. The AWS Certified Security – Specialty Study Guide states that the S3 bucket policy must explicitly allow the config.amazonaws.com service principal to write objects. Additionally, the IAM role used by AWS Config must allow s3:GetBucketAcl and s3:PutObject.

If either permission is missing, AWS Config cannot deliver snapshots and will log delivery errors in CloudTrail. This dual-permission model ensures least privilege while maintaining secure delivery of compliance data.

Other options reference incorrect principals or irrelevant permissions.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Config Prerequisites

Question #:72 - [Detection]

A company has hundreds of AWS accounts in an organization in AWS Organizations. The company operates out of a single AWS Region. The company has a dedicated security tooling AWS account in the organization. The security tooling account is configured as the organization's delegated administrator for Amazon GuardDuty and AWS Security Hub. The company has configured the environment to automatically enable GuardDuty and Security Hub for existing AWS accounts and new AWS accounts.

The company is performing control tests on specific GuardDuty findings to make sure that the company's security team can detect and respond to security events. The security team launched an Amazon EC2 instance and attempted to run DNS requests against a test domain, example.com, to generate a DNS finding. However, the GuardDuty finding was never created in the Security Hub delegated administrator account.

Why was the finding not created in the Security Hub delegated administrator account?

- A. VPC flow logs were not turned on for the VPC where the EC2 instance was launched.
- B. The VPC where the EC2 instance was launched had the DHCP option configured for a custom OpenDNS resolver.
- C. The GuardDuty integration with Security Hub was never activated in the AWS account where the finding was generated.
- D. Cross-Region aggregation in Security Hub was not configured.

Answer: B

Explanation

GuardDuty's DNS-related detections depend on GuardDuty being able to observe DNS query behavior through AWS-provided DNS resolution paths in the VPC. If a VPC is configured to use a custom DNS resolver via DHCP options (for example, an OpenDNS resolver) instead of the AmazonProvidedDNS resolver, DNS queries may bypass the visibility path GuardDuty relies on for DNS analysis and pattern detection. In that case, the test traffic (queries to example.com) might not be evaluated by GuardDuty's DNS finding logic, so no DNS finding is generated—and therefore nothing is forwarded into Security Hub.

Option A is incorrect because VPC flow logs are not a prerequisite for GuardDuty to produce DNS findings; GuardDuty uses native telemetry sources and does not require customer-managed flow logs to be enabled. Option D is irrelevant because the company operates in a single Region, and cross-Region aggregation would not be required for the delegated administrator to see findings from the same Region. Option C is less likely given the setup explicitly states GuardDuty and Security Hub are automatically enabled across accounts; also, even if enabled, the specific lack of a DNS finding points to DNS visibility/configuration rather than a downstream integration toggle.

Question #:73 - [Infrastructure Security]

A company has AWS accounts in an organization in AWS Organizations. An Amazon S3 bucket in one account is publicly accessible. A security engineer must remove public access and ensure the bucket cannot be made public again.

Which solution will meet these requirements?

- A. Enforce KMS encryption and deny s3:GetObject by SCP.
- B. Enable PublicAccessBlock and deny s3:GetObject by SCP.
- C. Enable PublicAccessBlock and deny s3:PutPublicAccessBlock by SCP.
- D. Enable Object Lock governance and deny s3:PutPublicAccessBlock by SCP.

Answer: C

Explanation

Amazon S3 Block Public Access provides centralized controls to prevent public access through bucket policies and ACLs. AWS Certified Security – Specialty guidance recommends enabling Block Public Access to reduce accidental exposure and to enforce guardrails that override public grants. Enabling Block Public Access on the bucket removes current public exposure when combined with correcting policies/ACLs and prevents future misconfiguration. To ensure the bucket cannot be made public again, the security engineer must prevent principals from disabling Block Public Access. An SCP that denies s3:PutPublicAccessBlock prevents changes that would remove or weaken the PublicAccessBlock configuration, enforcing the guardrail across the OU or account. Options A and D do not directly address public exposure control. Option B denies object reads but does not ensure public access cannot be re-enabled; it also does not address the root misconfiguration pathways and could disrupt legitimate access patterns. Option C specifically combines the correct preventive control (PublicAccessBlock) with organizational enforcement to stop future reversal.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Block Public Access

AWS Organizations SCP Guardrails for S3 Controls

Question #:74 - [Identity and Access Management]

A consultant agency needs to perform a security audit for a company 's production AWS account. Several consultants need access to the account. The consultant agency already has its own AWS account. The company requires multi-factor authentication (MFA) for all access to its production account. The company also forbids the use of long-term credentials.

Which solution will provide the consultant agency with access that meets these requirements?

- A. Create an IAM group. Create an IAM user for each consultant. Add each user to the group. Turn on MFA for each consultant.
- B. Configure Amazon Cognito on the company's production account to authenticate against the consultant agency 's identity provider (IdP). Add MFA to a Cognito user pool.
- C. Create an IAM role in the consultant agency 's AWS account. Define a trust policy that requires MFA. In the trust policy, specify the company 's production account as the principal. Attach the trust policy to the role.
- D. Create an IAM role in the company's production account. Define a trust policy that requires MFA. In the trust policy, specify the consultant agency 's AWS account as the principal. Attach the trust policy to the role.

Answer: D

Explanation

AWS best practices strongly discourage the use of long-term credentials and recommend cross-account IAM roles with temporary credentials for third-party access. According to the AWS Certified Security – Specialty Study Guide, creating an IAM role in the resource-owning account and allowing a trusted external AWS account to assume that role is the recommended pattern for external access.

By creating the IAM role in the company's production account and specifying the consultant agency's AWS account as the trusted principal, the company retains full control over permissions. The trust policy can enforce MFA by using the `aws:MultiFactorAuthPresent` condition key, ensuring that all access requires MFA. Access is granted through AWS Security Token Service (STS), which issues short-lived credentials.

Option A violates the requirement to avoid long-term credentials. Option B is designed for application user authentication, not AWS account access. Option C incorrectly places the role in the consultant's account, reducing the company's control over access.

This solution satisfies MFA enforcement, eliminates long-term credentials, and aligns with AWS third-party access best practices.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Cross-Account Access

AWS STS and MFA Enforcement

Question #:75 - [Identity and Access Management]

A company has a web application that reads from and writes to an Amazon S3 bucket. The company needs to use AWS credentials to authenticate all S3 API calls to the S3 bucket.

Which solution will provide the application with AWS credentials to make S3 API calls?

- A. Integrate with Cognito identity pools and use GetId to obtain AWS credentials.
- B. Integrate with Cognito identity pools and use AssumeRoleWithWebIdentity to obtain AWS credentials.
- C. Integrate with Cognito user pools and use the ID token to obtain AWS credentials.
- D. Integrate with Cognito user pools and use the access token to obtain AWS credentials.

Answer: B

Explanation

Amazon Cognito identity pools are designed to provide temporary AWS credentials for applications by exchanging an authenticated identity token for AWS Security Token Service (STS) credentials. AWS Certified Security – Specialty guidance distinguishes between Cognito user pools (authentication) and identity pools (authorization to AWS resources). A user pool can authenticate a user and issue tokens, but an identity pool is required to obtain AWS credentials that can be used to sign AWS API requests, such as S3 API calls.

The correct mechanism is for the application to use AssumeRoleWithWebIdentity through STS (which is the underlying federation method used by identity pools) to receive temporary credentials for an IAM role that grants S3 permissions. GetId alone does not provide credentials; it returns an identity identifier that is used as part of the credential exchange flow. Options C and D are incorrect because user pool tokens are not AWS credentials and cannot directly sign S3 requests. The solution therefore must use identity pools to map users to IAM roles and retrieve temporary credentials, satisfying the requirement for authenticated API calls using short-lived credentials.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Cognito Identity Pools and STS Federation

AWS STS AssumeRoleWithWebIdentity

Question #:76 - [Security Foundations and Governance]

A company is using AWS Organizations with the default SCP. The company needs to restrict AWS usage for all AWS accounts that are in a specific OU. Except for some desired global services, the AWS usage must occur only in the eu-west-1 Region for all accounts in the OU. A security engineer must create an SCP that applies the restriction to existing accounts and any new accounts in the OU.

Which SCP will meet these requirements?

- A. Deny with NotAction, but uses StringEquals for aws:RequestedRegion = eu-west-1
- B. Allow with Action, scoped to desired global services in eu-west-1
- C. Deny with NotAction for desired global services, and StringNotEquals aws:RequestedRegion = eu-west-1
- D. Allow with NotAction and StringNotEquals aws:RequestedRegion = eu-west-1

Answer: C

Explanation

To restrict activity to a single Region in an OU using an SCP, the standard pattern is an explicit Deny for requests made outside the allowed Region, while carving out exceptions for global services that do not use aws:RequestedRegion in the same way (or that must remain usable regardless of Region). This is done with Effect: Deny, a Condition using StringNotEquals on aws:RequestedRegion for the allowed Region (here, eu-west-1), and NotAction listing the global services that should remain available.

This works because SCPs act as guardrails: an explicit Deny in an SCP overrides IAM Allow in member accounts, ensuring the restriction applies consistently to all existing and future accounts placed in the OU. The StringNotEquals condition ensures the deny triggers for any Region other than eu-west-1. The NotAction exception list ensures that the specified global services are not blocked by this deny statement.

Option A is wrong because `StringEquals` would deny actions in `eu-west-1` rather than outside it. Options B and D use `Allow` statements, which do not enforce “only this Region” safely in SCPs unless combined with a comprehensive deny strategy; they would not reliably restrict all other services/regions. Therefore, option C is the correct SCP structure.

Question #:77 - [Detection]

A company runs its microservices architecture in Kubernetes containers on AWS by using Amazon Elastic Kubernetes Service (Amazon EKS) and Amazon Aurora. The company has an organization in AWS Organizations to manage hundreds of AWS accounts that host different microservices.

The company needs to implement a monitoring solution for logs from all AWS resources across all accounts. The solution must include automatic detection of security-related issues.

Which solution will meet these requirements with the LEAST operational effort?

- A. Designate an Amazon GuardDuty administrator account in the organization’s management account. Enable GuardDuty for all accounts. Enable EKS Protection and RDS Protection in the GuardDuty administrator account.
- B. Designate a monitoring account. Share Amazon CloudWatch Logs from all accounts. Use Amazon Inspector to evaluate the logs.
- C. Centralize CloudTrail logs in Amazon S3 and analyze them with Amazon Athena.
- D. Stream CloudWatch Logs to Amazon Kinesis and analyze them with custom AWS Lambda functions.

Answer: A

Explanation

Amazon GuardDuty is a fully managed, organization-aware threat detection service that continuously analyzes AWS logs such as CloudTrail events, VPC Flow Logs, DNS logs, EKS audit logs, and RDS activity. According to the AWS Certified Security – Specialty Official Study Guide, GuardDuty is designed to operate at scale across AWS Organizations with minimal operational overhead.

By designating a GuardDuty administrator account in the organization’s management account and enabling GuardDuty organization-wide, the company can automatically enable threat detection across hundreds of AWS accounts. Enabling EKS Protection allows GuardDuty to analyze Kubernetes audit logs for suspicious activity, while RDS Protection provides anomaly detection for Amazon Aurora databases.

Options B, C, and D require custom log aggregation, processing, and analytics pipelines, which significantly increase operational effort and maintenance complexity. Amazon Inspector does not analyze logs, Athena-based analysis is manual, and Kinesis plus Lambda requires custom detection logic.

AWS documentation explicitly identifies GuardDuty with AWS Organizations integration as the recommended solution for centralized, automated threat detection across multi-account environments with minimal operational effort.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon GuardDuty User Guide
- ▶ GuardDuty Organization Administration Documentation

Question #:78 - [Infrastructure Security]

A company runs a global ecommerce website that is hosted on AWS. The company uses Amazon CloudFront to serve content to its user base. The company wants to block inbound traffic from a specific set of countries to comply with recent data regulation policies.

Which solution will meet these requirements MOST cost-effectively?

- A. Create an AWS WAF web ACL with an IP match condition to deny the countries ' IP ranges. Associate the web ACL with the CloudFront distribution.
- B. Create an AWS WAF web ACL with a geo match condition to deny the specific countries. Associate the web ACL with the CloudFront distribution.
- C. Use the geo restriction feature in CloudFront to deny the specific countries.
- D. Use geolocation headers in CloudFront to deny the specific countries.

Answer: C

Explanation

Amazon CloudFront includes a native geo restriction (geoblocking) capability that allows content owners to control access to their distributions based on the geographic location of the viewer. The viewer's country is determined using the IP address from which the request originates. According to the AWS Certified Security – Specialty Official Study Guide and the Amazon CloudFront Developer Guide, geo restriction is specifically designed for scenarios where organizations must comply with regional regulations, licensing requirements, or data sovereignty policies.

From a cost perspective, CloudFront geo restriction is the most cost-effective solution because it is configured directly within the CloudFront distribution and does not require AWS WAF. AWS WAF introduces additional costs for web ACLs, rules, and request processing, which is unnecessary when the requirement is limited strictly to blocking or allowing access based on country.

Option A is incorrect because maintaining IP ranges for entire countries is operationally complex, error-prone, and not scalable. Country-level IP ranges frequently change, making this approach unsuitable and inefficient. Option B, although technically valid, is not the most cost-effective choice because AWS WAF geo match rules incur additional charges and are intended for advanced Layer 7 security controls such as application-layer attacks. Option D is incorrect because geolocation headers provided by CloudFront are informational only and cannot independently enforce access control decisions.

AWS documentation explicitly recommends CloudFront geo restriction when the sole requirement is country-based access control, reserving AWS WAF for advanced security inspection and threat mitigation use cases.



AWS Certified Security – Specialty Official Study Guide

Amazon CloudFront Developer Guide – Geo Restriction

AWS Well-Architected Framework – Security Pillar

AWS Security Best Practices Documentation

Question #:79 - [Incident Response]

A company runs a web application on a fleet of Amazon EC2 instances that are in an Auto Scaling group. The EC2 instances are in the same VPC subnet as other workloads.

A security engineer deploys an Amazon GuardDuty detector in the same AWS Region as the EC2 instances and integrates GuardDuty with AWS Security Hub.

The security engineer needs to implement an automated solution to detect and appropriately respond to anomalous traffic patterns for the web application. The solution must comply with AWS best practices for initial response to security incidents and must minimize disruption to the web application.

Which solution will meet these requirements?

- A. Disable the EC2 instance profile credentials by using AWS Lambda.
- B. Create an Amazon EventBridge rule that invokes an AWS Lambda function when GuardDuty detects anomalous traffic. Configure the function to remove the affected instance from the Auto Scaling group and attach a restricted security group.
- C. Update the subnet network ACL to block traffic from the detected source IP addresses.
- D. Send GuardDuty findings to Amazon SNS for email notification.

Answer: B

Explanation

AWS incident response best practices emphasize rapid containment with minimal blast radius. According to the AWS Certified Security – Specialty Official Study Guide, isolating a compromised resource while allowing the application to continue running is the preferred initial response.

By using Amazon EventBridge to detect GuardDuty findings related to anomalous traffic and invoking a Lambda function, the security engineer can automatically remove the affected EC2 instance from the Auto Scaling group and attach a restricted security group. This immediately isolates the instance while allowing Auto Scaling to launch a replacement instance, ensuring application availability.

Option A is invalid because EC2 instance profiles do not use long-term access keys. Option C affects the entire subnet and could disrupt unrelated workloads. Option D provides notification only and does not meet the requirement for automated response.

AWS documentation explicitly recommends instance-level isolation using security groups as a best practice for initial incident containment.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon GuardDuty User Guide
- ▶ AWS Incident Response Best Practices

Question #:80 - [Data Protection]

A security engineer needs to implement a solution to create and control the keys that a company uses for cryptographic operations. The security engineer must create symmetric keys in which the key material is generated and used within a custom key store that is backed by an AWS CloudHSM cluster. The security engineer will use symmetric and asymmetric data key pairs for local use within applications. The security engineer also must audit the use of the keys.

How can the security engineer meet these requirements?

- A. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use Amazon Athena.
- B. To create the keys, use Amazon S3 and the custom key stores with the CloudHSM cluster. For auditing, use AWS CloudTrail.
- C. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use Amazon GuardDuty.
- D. To create the keys, use AWS Key Management Service (AWS KMS) and the custom key stores with the CloudHSM cluster. For auditing, use AWS CloudTrail.

Answer: D

Explanation

The requirement is to have key material generated and used inside a custom key store backed by an AWS CloudHSM cluster. This is exactly what AWS KMS Custom Key Stores provide: KMS manages the keys and policies, but the cryptographic operations for those KMS keys occur in the associated CloudHSM cluster, keeping the key material within HSM boundaries. For applications that need local-use data keys (both symmetric data keys and asymmetric data key pairs), KMS supports generating data keys and data key pairs that applications can use for envelope encryption and local cryptographic operations, while the master key protections remain within KMS (and within CloudHSM when using a custom key store).

For auditing, AWS best practice is AWS CloudTrail, which records KMS API calls (such as CreateKey, GenerateDataKey, GenerateDataKeyPair, Encrypt/Decrypt, etc.) and provides an immutable event history for compliance and investigation. Athena can query logs, but it is not the primary audit record source; GuardDuty is for threat detection, not authoritative key-usage auditing. Therefore, the correct combination is KMS with a CloudHSM-backed custom key store plus CloudTrail for auditability.

Question #:81 - [Incident Response]

A development team is creating an open source toolset to manage a company's software as a service (SaaS) application. The company stores the code in a public repository so that anyone can view and download the toolset's code. The company discovers that the code contains an IAM access key and secret key that provide access to internal resources in the company's AWS environment. A security engineer must implement a solution to identify whether unauthorized usage of the exposed credentials has occurred. The solution also must prevent any additional usage of the exposed credentials.

Which combination of steps will meet these requirements? (Select TWO.)

- A. Use AWS Identity and Access Management Access Analyzer to determine which resources the exposed credentials accessed and who used them.
- B. Deactivate the exposed IAM access key from the user's IAM account.
- C. Create a rule in Amazon GuardDuty to block the access key in the source code from being used.
- D. Create a new IAM access key and secret key for the user whose credentials were exposed.
- E. Generate an IAM credential report. Check the report to determine when the user that owns the access key last logged in.

Answer: B E

Explanation

The immediate containment step for exposed access keys is to disable (deactivate) the compromised IAM access key (Option B). This prevents any further use of the leaked credentials, which is essential once secrets are publicly exposed. Creating a new key (Option D) may be part of recovery later, but it does not stop abuse of the already exposed key unless the exposed key is first deactivated.

To determine whether the credentials were used, you need evidence of access activity. Among the provided options, the best fit is generating and reviewing the IAM credential report (Option E). The report includes metadata such as access key status and "last used" style details that help triage whether the user's credentials have been exercised recently. While deeper investigation would typically rely on CloudTrail "AccessKeyId" searches, the credential report is a quick AWS-native step aligned to the answer choices.

Option A is not correct: IAM Access Analyzer helps identify external access paths to resources and validate policies; it does not provide a definitive history of what a specific access key did. Option C is not a GuardDuty capability—GuardDuty generates findings; it does not "block" a specific access key. Therefore, deactivating the key and using credential reporting to assess recent usage best matches the requirements.

Question #:82 - [Infrastructure Security]

A public subnet contains two Amazon EC2 instances. The subnet has a custom network ACL. A security engineer is designing a solution to improve the subnet security. The solution must allow outbound traffic to an internet service that uses TLS through port 443. The solution also must deny inbound traffic that is destined for MySQL port 3306.



Which network ACL rule set meets these requirements?

- A. Use inbound rule 100 to allow traffic on TCP port 443. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.
- B. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port range 1024-65535. Use outbound rule 100 to allow traffic on TCP port 443.
- C. Use inbound rule 100 to allow traffic on TCP port range 1024-65535. Use inbound rule 200 to deny traffic on TCP port 3306. Use outbound rule 100 to allow traffic on TCP port 443.
- D. Use inbound rule 100 to deny traffic on TCP port 3306. Use inbound rule 200 to allow traffic on TCP port 443. Use outbound rule 100 to allow traffic on TCP port 443.

Answer: B

Explanation

Network ACLs are stateless, so you must allow both the outbound request and the inbound return traffic. For outbound TLS to an internet service on TCP 443, you need an outbound allow rule permitting destination port 443. The return traffic from the internet service will come back to the instance's ephemeral port (typically in the range 1024–65535) on the inbound path. Therefore, you must allow inbound TCP traffic on the ephemeral port range to support established outbound connections.

At the same time, the requirement is to deny inbound MySQL (TCP 3306). Because NACLs process rules in order (lowest rule number first), placing an explicit deny for port 3306 as a low-numbered inbound rule ensures that traffic destined for MySQL is blocked even if there are broader allow rules later.

Option B does exactly this: it denies inbound TCP 3306 first, then allows inbound ephemeral ports for return traffic, and allows outbound TCP 443. Option A/D incorrectly allow inbound 443 (not needed for outbound-only TLS) and fail to explicitly allow ephemeral return traffic correctly. Option C allows ephemeral inbound first, and then denies 3306 later; while 3306 is not in the ephemeral range, B is the clean, canonical ordering and matches the intended stateless-return-traffic pattern most directly.

Question #:83 - [Infrastructure Security]

A company hosts its public website on Amazon EC2 instances behind an Application Load Balancer (ALB). The website is experiencing a global DDoS attack by a specific IoT device brand that has a unique user agent.

A security engineer is creating an AWS WAF web ACL and will associate the web ACL with the ALB. The security engineer must implement a rule statement as part of the web ACL to block the requests. The rule statement must mitigate the current attack and future attacks from these IoT devices without blocking requests from customers.

Which rule statement will meet these requirements?

- A. Use an IP set match rule statement that includes the IP address for IoT devices from the user agent.

- B. Use a geographic match rule statement. Configure the statement to block countries that the IoT devices are located in.
- C. Use a rate-based rule statement. Set a rate limit that is equal to the number of requests that are coming from the IoT devices.
- D. Use a string match rule statement that includes details of the IoT device brand from the user agent.

Answer: D

Explanation

AWS WAF allows security engineers to create string match rule statements that inspect specific parts of web requests, including HTTP headers such as the User-Agent header. According to the AWS Certified Security – Specialty Study Guide and AWS WAF documentation, string match rules are ideal for blocking requests that contain known malicious identifiers, such as a distinctive user agent associated with a specific bot or IoT device brand.

In this scenario, the attack originates from a specific IoT device brand that uses a unique user agent. A string match rule that inspects the User-Agent header can precisely block malicious requests while allowing legitimate customer traffic to continue uninterrupted. This approach provides targeted mitigation for both current and future attacks originating from the same device signature.

Option A is incorrect because IP addresses cannot be derived from user agent strings, and IoT botnets frequently rotate IP addresses, making IP-based blocking ineffective. Option B is incorrect because geographic blocking is overly broad and risks blocking legitimate customers in the same regions as the attacking devices. Option C is incorrect because rate-based rules limit request volume per IP address and do not specifically identify malicious device signatures; legitimate high-traffic users could be unintentionally blocked.

AWS documentation emphasizes that header inspection with string match conditions is a best practice for mitigating attacks that use identifiable request characteristics such as custom user agents, especially in DDoS and bot mitigation scenarios.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Developer Guide – Rule Statements
- ▶ AWS DDoS Resiliency Best Practices
- ▶ AWS Well-Architected Framework – Security Pillar

Question #:84 - [Identity and Access Management]

A company uses an organization in AWS Organizations to manage multiple AWS accounts. The company uses AWS IAM Identity Center to manage access to the accounts. The company uses AWS Directory Service as an identity source. Employees access the AWS console and specific AWS accounts and permissions through the AWS access portal.

A security engineer creates a new permissions set in IAM Identity Center and assigns the permissions set to one of the member accounts in the organization. The security engineer assigns the permissions set to a user group for developers named DevOps in the member account. The security engineer expects all the developers to see the new permissions set listed for the member account in the AWS access portal. All the developers except for one can see the permissions set. The security engineer must ensure that the remaining developer can see the permissions set in the AWS access portal.

Which solution will meet this requirement?

- A. Add the remaining developer to the DevOps group in Directory Service.
- B. Remove and then re-add the permissions set in the member account.
- C. Add the service-linked role for organization to the member account.
- D. Update the permissions set to allow console access for the remaining developer.

Answer: A

Explanation

In IAM Identity Center, users see accounts and permission sets in the AWS access portal based on assignments. Here, the new permission set was assigned to the DevOps group for a specific member account. Since all developers except one can see the permission set, the permission set itself and the account assignment are working correctly. The most likely cause is that the remaining developer is not actually a member of the DevOps group in the identity source (AWS Directory Service / Active Directory), or their group membership is not reflected due to missing/incorrect directory group assignment.

The least disruptive fix is to ensure the developer's identity is correctly included in the DevOps group within the directory. Once the user is a member of the assigned group (and after normal identity sync/refresh behavior), IAM Identity Center will evaluate the user as entitled to that permission set, and it will appear in the access portal.

Option B is unnecessary because the assignment is already effective for others. Option C is unrelated; service-linked roles for Organizations do not determine portal entitlements. Option D would not explain why only one user cannot see the permission set; if console access were misconfigured, it would affect all users assigned that permission set.

Question #:85 - [Infrastructure Security]

A company is running a containerized application on an Amazon Elastic Container Service (Amazon ECS) cluster that uses AWS Fargate. The application runs as several ECS services.

The ECS services are in individual target groups for an internet-facing Application Load Balancer (ALB). The ALB is the origin for an Amazon CloudFront distribution. An AWS WAF web ACL is associated with the CloudFront distribution.

Web clients access the ECS services through the CloudFront distribution. The company learns that the web clients can bypass the web ACL and can access the ALB directly.

Which solution will prevent the web clients from directly accessing the ALB?

- A. Create an AWS PrivateLink endpoint and set it as the CloudFront origin.
- B. Create a new internal ALB and delete the internet-facing ALB.
- C. Modify the ALB listener rules to allow only CloudFront IP ranges.
- D. Add a custom X-Shared-Secret header in CloudFront and configure the ALB listener rules to allow requests only when the header value matches.

Answer: D

Explanation

When an internet-facing ALB is used as a CloudFront origin, it remains directly accessible unless additional access controls are enforced. According to AWS Certified Security – Specialty guidance, CloudFront IP allow lists alone are insufficient, because CloudFront IP ranges change and are not guaranteed to be exclusive.

The recommended and most secure approach is to configure CloudFront to send a custom origin header (such as X-Shared-Secret) with a secret value on every request to the origin. The ALB listener rules are then configured to forward traffic only when the header exists and matches the expected value. Requests that attempt to bypass CloudFront will not include this header and will be denied.

Option A is invalid because CloudFront does not support PrivateLink origins. Option B introduces unnecessary architectural changes and is not required. Option C is brittle and operationally risky due to changing IP ranges.

AWS documentation explicitly recommends custom origin headers as the best practice to ensure that only CloudFront can access an internet-facing ALB when AWS WAF is attached at the CloudFront layer.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon CloudFront Origin Security Documentation
- ▶ AWS WAF and ALB Integration Guidance

Question #:86 - [Security Foundations and Governance]

A company has configured an organization in AWS Organizations for its AWS accounts. AWS CloudTrail is enabled in all AWS Regions.

A security engineer must implement a solution to prevent CloudTrail from being disabled.

Which solution will meet this requirement?

- A. Enable CloudTrail log file integrity validation from the organization's management account.

- B. Enable server-side encryption with AWS KMS keys (SSE-KMS) for CloudTrail logs. Create a KMS key. Attach a policy to the key to prevent decryption of the logs.
- C. Create a service control policy (SCP) that includes an explicitDeny rule for the cloudtrail:StopLogging action and the cloudtrail:DeleteTrail action. Attach the SCP to the root OU.
- D. Create IAM policies for all the company 's users to prevent the users from performing the DescribeTrails action and the GetTrailStatus action.

Answer: C

Explanation

AWS CloudTrail is a foundational security service that records API activity and account events. According to the AWS Certified Security – Specialty Official Study Guide, the only way to centrally and reliably prevent CloudTrail from being disabled across multiple AWS accounts is by using AWS Organizations service control policies (SCPs).

SCPs define the maximum available permissions for all accounts in an organization or organizational unit. By creating an SCP with an explicitDeny for the cloudtrail:StopLogging and cloudtrail:DeleteTrail actions and attaching it to the root OU, the security engineer ensures that no principal in any member account—including administrators—can stop or delete CloudTrail trails. Explicit denies in SCPs cannot be overridden by IAM permissions.

Option A is incorrect because log file integrity validation only detects tampering after logs are delivered and does not prevent CloudTrail from being disabled. Option B protects log data at rest but does not prevent trail deletion or logging suspension. Option D removes read-only permissions and does not affect the ability to stop or delete CloudTrail.

AWS documentation explicitly states that SCPs are the recommended mechanism to enforce mandatory security controls such as CloudTrail logging across an organization, making this the correct and most secure solution.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Organizations SCP Documentation
- ▶ AWS CloudTrail Security Best Practices

Question #:87 - [Incident Response]

A company 's security engineer is designing an isolation procedure for Amazon EC2 instances as part of an incident response plan. The security engineer needs to isolate a target instance to block any traffic to and from the target instance, except for traffic from the company 's forensics team. Each of the company 's EC2 instances has its own dedicated security group. The EC2 instances are deployed in subnets of a VPC. A subnet can contain multiple instances.

The security engineer is testing the procedure for EC2 isolation and opens an SSH session to the target instance. The procedure starts to simulate access to the target instance by an attacker. The security engineer removes the existing security group rules and adds security group rules to give the forensics team access to the target instance on port 22.

After these changes, the security engineer notices that the SSH connection is still active and usable. When the security engineer runs a ping command to the public IP address of the target instance, the ping command is blocked.

What should the security engineer do to isolate the target instance?

- A. Add an inbound rule to the security group to allow traffic from 0.0.0.0/0 for all ports. Add an outbound rule to the security group to allow traffic to 0.0.0.0/0 for all ports. Then immediately delete these rules.
- B. Remove the port 22 security group rule. Attach an instance role policy that allows AWS Systems Manager Session Manager connections so that the forensics team can access the target instance.
- C. Create a network ACL that is associated with the target instance 's subnet. Add a rule at the top of the inbound rule set to deny all traffic from 0.0.0.0/0. Add a rule at the top of the outbound rule set to deny all traffic to 0.0.0.0/0.
- D. Create an AWS Systems Manager document that adds a host-level firewall rule to block all inbound traffic and outbound traffic. Run the document on the target instance.

Answer: C

Explanation

Amazon EC2 security groups are stateful, meaning that once a connection is established, return traffic is automatically allowed, even if the inbound rule that originally permitted the connection is later removed. According to the AWS Certified Security – Specialty Official Study Guide and Amazon EC2 security documentation, existing connections are not terminated when security group rules change. This explains why the SSH session remains active even after the security group rules were modified, while new traffic such as ICMP ping is blocked.

To immediately and fully isolate an EC2 instance during an incident response scenario, AWS recommends using stateless network controls. Amazon VPC network ACLs (NACLs) are stateless, which means that every packet is evaluated against the ACL rules regardless of whether the traffic is part of an existing connection. When a deny rule is added, all traffic is immediately blocked, including active sessions.

By creating a network ACL and associating it with the subnet that contains the target instance, and by adding explicit deny rules with the lowest rule numbers for both inbound and outbound traffic, the security engineer ensures that all network communication to and from the instance is immediately interrupted. This approach satisfies the requirement to isolate the instance while preserving its runtime state and memory for forensic analysis.

Other options fail to meet the requirement because security group modifications do not terminate existing sessions, Systems Manager does not enforce network isolation, and host-level firewall changes require instance-level access and do not provide immediate, network-enforced isolation.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon EC2 Security Groups Documentation
- ▶ Amazon VPC Network ACL Documentation
- ▶ AWS Incident Response Best Practices

Question #:88 - [Security Foundations and Governance]

A company needs a cloud-based, managed desktop solution for its workforce of remote employees. The company wants to ensure that the employees can access the desktops only by using company-provided devices. A security engineer must design a solution that will minimize cost and management overhead.

Which solution will meet these requirements?

- A. Deploy a custom virtual desktop infrastructure (VDI) solution with a restriction policy to allow access only from corporate devices.
- B. Deploy a fleet of Amazon EC2 instances. Assign an instance to each employee with certificate-based device authentication that uses Windows Active Directory.
- C. Deploy Amazon WorkSpaces. Set up a trusted device policy with IP blocking on the authentication gateway by using AWS Identity and Access Management (IAM).
- D. Deploy Amazon WorkSpaces. Create client certificates, and deploy them to trusted devices. Enable restricted access at the directory level.

Answer: D

Explanation

Amazon WorkSpaces is a fully managed desktop-as-a-service solution designed to minimize infrastructure and operational overhead. According to AWS Certified Security – Specialty documentation, WorkSpaces supports device trust by using client certificates to restrict access to approved devices.

By deploying client certificates only to company-managed devices and enforcing restricted access at the directory level, the organization ensures that only trusted endpoints can authenticate. This approach avoids the cost and complexity of building and maintaining a custom VDI or managing individual EC2 instances.

Option A and B significantly increase management overhead. Option C is incorrect because IAM does not manage WorkSpaces authentication gateway policies or device trust.

AWS best practices highlight Amazon WorkSpaces with certificate-based device trust as the most efficient solution for secure, managed desktops.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon WorkSpaces Security Controls

Amazon WorkSpaces Device Trust

Question #:89 - [Detection]

A security engineer wants to forward custom application-security logs from an Amazon EC2 instance to Amazon CloudWatch. The security engineer installs the CloudWatch agent on the EC2 instance and adds the path of the logs to the CloudWatch configuration file.

However, CloudWatch does not receive the logs. The security engineer verifies that the awslogs service is running on the EC2 instance.

What should the security engineer do next to resolve the issue?

- A. Add AWS CloudTrail to the trust policy of the EC2 instance. Send the custom logs to CloudTrail instead of CloudWatch.
- B. Add Amazon S3 to the trust policy of the EC2 instance. Configure the application to write the custom logs to an S3 bucket that CloudWatch can use to ingest the logs.
- C. Add Amazon Inspector to the trust policy of the EC2 instance. Use Amazon Inspector instead of the CloudWatch agent to collect the custom logs.
- D. Attach the CloudWatchAgentServerPolicy AWS managed policy to the EC2 instance role.

Answer: D

Explanation

The Amazon CloudWatch agent requires explicit IAM permissions to create log groups, create log streams, and put log events into Amazon CloudWatch Logs. According to the AWS Certified Security – Specialty Study Guide, the most common cause of CloudWatch agent log delivery failures is missing or insufficient IAM permissions on the EC2 instance role.

The CloudWatchAgentServerPolicy AWS managed policy provides the required permissions, including logs:CreateLogGroup, logs:CreateLogStream, and logs:PutLogEvents. Attaching this policy to the EC2 instance role enables the CloudWatch agent to successfully deliver custom application logs without requiring changes to the application or logging configuration.

Options A, B, and C are incorrect because CloudTrail, Amazon S3, and Amazon Inspector are not designed to ingest custom application logs from EC2 instances in this manner. AWS documentation clearly states that IAM permissions must be granted to the EC2 role for CloudWatch Logs ingestion.

This approach aligns with AWS best practices for least privilege while ensuring reliable detection and monitoring capabilities.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide



Amazon CloudWatch Logs Agent Configuration

AWS IAM Best Practices for Monitoring

Question #:90 - [Data Protection]

A company has a PHP-based web application that uses Amazon S3 as an object store for user files. The S3 bucket is configured for server-side encryption with Amazon S3 managed keys (SSE-S3). New requirements mandate full control of encryption keys.

Which combination of steps must a security engineer take to meet these requirements? (Select THREE.)

- A. Create a new customer managed key in AWS Key Management Service (AWS KMS).
- B. Change the SSE-S3 configuration on the S3 bucket to server-side encryption with customer-provided keys (SSE-C).
- C. Configure the PHP SDK to use the SSE-S3 key before upload.
- D. Create an AWS managed key for Amazon S3 in AWS KMS.
- E. Change the SSE-S3 configuration on the S3 bucket to server-side encryption with AWS KMS managed keys (SSE-KMS).
- F. Change all the S3 objects in the bucket to use the new encryption key.

Answer: A E F

Explanation

SSE-S3 uses AWS-managed keys and does not provide customer control. AWS Certified Security – Specialty documentation states that SSE-KMS with customer managed keys allows full control, auditing, and key rotation. The security engineer must first create a customer managed KMS key, then update the bucket to use SSE-KMS. Existing objects must be re-encrypted to ensure compliance.

SSE-C requires the application to manage keys, increasing complexity and risk. AWS managed keys do not meet the requirement for customer-controlled encryption.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Encryption Options

AWS KMS Customer Managed Keys

Question #:91 - [Security Foundations and Governance]

A company has the following security policy for its Amazon Aurora MySQL databases for a single AWS account:

- Database storage must be encrypted at rest.
- Deletion protection must be enabled.
- Databases must not be publicly accessible.
- Database audit logs must be published to Amazon CloudWatch Logs.

A security engineer must implement a solution that continuously monitors all Aurora MySQL resources for compliance with this policy. The solution must be able to display a database's compliance state for each part of the policy at any time.

Which solution will meet these requirements?

- A. Enable AWS Audit Manager. Configure Audit Manager to use a custom framework that matches the security requirements. Create an assessment report to view the compliance state.
- B. Enable AWS Config. Implement AWS Config managed rules that monitor all Aurora MySQL resources for the security requirements. View the compliance state in the AWS Config dashboard.
- C. Enable AWS Security Hub. Create a configuration policy that includes the security requirements. Apply the configuration policy to all Aurora MySQL resources. View the compliance state in Security Hub.
- D. Create an Amazon EventBridge rule that runs when an Aurora MySQL resource is created or modified. Create an AWS Lambda function to verify the security requirements and to send the compliance state to a CloudWatch custom metric.

Answer: B

Explanation

AWS Config is a fully managed service that provides continuous monitoring and evaluation of AWS resource configurations against desired configuration baselines. According to the AWS Certified Security – Specialty Official Study Guide, AWS Config is the primary service used to track configuration changes, evaluate compliance in near real time, and display compliance states for individual AWS resources.

AWS Config provides managed rules that directly map to the listed Aurora MySQL security requirements, including encryption at rest, public accessibility, deletion protection, and log exports to CloudWatch Logs. These managed rules continuously evaluate resources and mark them as compliant or noncompliant whenever a configuration change occurs.

The AWS Config dashboard enables security engineers to view per-resource and per-rule compliance states at any point in time, satisfying the requirement to display compliance status for each part of the policy.

AWS Audit Manager (Option A) is designed for audit evidence collection and reporting, not continuous monitoring. AWS Security Hub (Option C) aggregates findings from other services but relies on AWS Config for configuration compliance data. Option D introduces unnecessary custom logic and does not provide a native compliance dashboard.

AWS documentation explicitly identifies AWS Config as the authoritative service for continuous compliance monitoring and visibility.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Config Developer Guide
- ▶ Amazon Aurora Security Best Practices
- ▶ AWS Well-Architected Framework – Security Pillar

Question #:92 - [Data Protection]

A corporate cloud security policy states that communications between the company 's VPC and KMS must travel entirely within the AWS network and not use public service endpoints.

Which combination of the following actions MOST satisfies this requirement? (Select TWO.)

- A. Add the `aws:sourceVpce` condition to the AWS KMS key policy referencing the company 's VPC endpoint ID.
- B. Remove the VPC internet gateway from the VPC and add a virtual private gateway to the VPC to prevent direct, public internet connectivity.
- C. Create a VPC endpoint for AWS KMS with private DNS enabled.
- D. Use the KMS Import Key feature to securely transfer the AWS KMS key over a VPN.
- E. Add the following condition to the AWS KMS key policy: `"aws:SourceIp" : "10.0.0.0/16"`.

Answer: A C

Explanation

To ensure traffic from a VPC to AWS KMS stays on the AWS network and does not use public endpoints, you should use an interface VPC endpoint (AWS PrivateLink) for KMS. Creating a VPC endpoint for KMS with private DNS enabled (Option C) causes standard KMS DNS names (for example, `kms.<region>.amazonaws.com`) to resolve to the private endpoint IPs inside the VPC, routing requests over the AWS private network rather than through the internet. This is the core networking control that satisfies “no public service endpoints.”

To enforce that only calls that come through the intended VPC endpoint can use the key, add an authorization guardrail in the KMS key policy using the `aws:sourceVpce` condition (Option A). This ensures that even if a principal has credentials, KMS will deny usage unless the request is made via the specified VPC endpoint, preventing accidental or malicious use over public paths.

Option B is neither necessary nor sufficient: removing an internet gateway does not prevent all public endpoint use (NAT, other egress paths, or other VPCs could still be involved) and can break workloads. Option D is unrelated to runtime KMS API traffic. Option E is weaker because SourceIp checks can be bypassed via other AWS network paths and does not guarantee PrivateLink usage the way sourceVpce does.

Question #:93 - [Incident Response]

A security engineer needs to prepare for a security audit of an AWS account.

Select the correct AWS resource from the following list to meet each requirement. Select each resource one time or not at all. (Select THREE.)

- AWS Artifact reports
- AWS Audit Manager controls
- AWS Config conformance packs
- AWS Config rules
- Amazon Detective investigations
- AWS Identity and Access Management Access Analyzer internal access analyzers

Automatically collect evidence from AWS CloudTrail, AWS Config, and AWS Security Hub for an assessment report.

Select...
Select...
AWS Artifact reports
AWS Audit Manager controls
AWS Config conformance packs
AWS Config rules
Amazon Detective investigations
AWS Identity and Access Management Access Analyzer internal access analyzers

Determine which IAM principals within the AWS account have access to a specified resource.

Select...
Select...
AWS Artifact reports
AWS Audit Manager controls
AWS Config conformance packs
AWS Config rules
Amazon Detective investigations
AWS Identity and Access Management Access Analyzer internal access analyzers

Download AWS security and compliance documents on demand.

Select...
Select...
AWS Artifact reports
AWS Audit Manager controls
AWS Config conformance packs
AWS Config rules
Amazon Detective investigations
AWS Identity and Access Management Access Analyzer internal access analyzers

Answer:

Automatically collect evidence from AWS CloudTrail, AWS Config, and AWS Security Hub for an assessment report.

Select...

- Select...
- AWS Artifact reports
- AWS Audit Manager controls
- AWS Config conformance packs
- AWS Config rules
- Amazon Detective investigations
- AWS Identity and Access Management Access Analyzer internal access analyzers

Determine which IAM principals within the AWS account have access to a specified resource.

Select...

- Select...
- AWS Artifact reports
- AWS Audit Manager controls
- AWS Config conformance packs
- AWS Config rules
- Amazon Detective investigations
- AWS Identity and Access Management Access Analyzer internal access analyzers

Download AWS security and compliance documents on demand.

Select...

- Select...
- AWS Artifact reports
- AWS Audit Manager controls
- AWS Config conformance packs
- AWS Config rules
- Amazon Detective investigations
- AWS Identity and Access Management Access Analyzer internal access analyzers

Explanation

Requirements and Correct Selections

Automatically collect evidence from AWS CloudTrail, AWS Config, and AWS Security Hub for an assessment report.

Correct Answer:

AWS Audit Manager controls

Why:

AWS Audit Manager is specifically designed to automatically collect, map, and organize evidence from AWS services such as CloudTrail, AWS Config, and AWS Security Hub. Audit Manager controls are used within audit frameworks to continuously gather evidence and generate assessment reports for compliance audits.

Determine which IAM principals within the AWS account have access to a specified resource.

Correct Answer:

AWS Identity and Access Management Access Analyzer internal access analyzers

Why:

IAM Access Analyzer internal access analyzers are used to identify which IAM users, roles, or services within an account or organization have access to a specific resource. This is a core access visibility and audit requirement for IAM reviews.

Download AWS security and compliance documents on demand.

Correct Answer:

AWS Artifact reports

Why:

AWS Artifact provides on-demand access to AWS security, compliance, and audit reports, including SOC reports, ISO certifications, and compliance attestations. This service is explicitly intended for audit preparation and regulatory documentation.

Question #:94 - [Incident Response]

A company runs an application on a fleet of Amazon EC2 instances. The company can remove instances from the fleet without risk to the application. All EC2 instances use the same security group named ProdFleet. Amazon GuardDuty and AWS Config are active in the company's AWS account.

A security engineer needs to provide a solution that will prevent an EC2 instance from sending outbound traffic if GuardDuty generates a cryptocurrency finding event. The security engineer creates a new security group named Isolate that contains no outbound rules. The security engineer configures an AWS Lambda function to remove an EC2 instance from the ProdFleet security group and add it to the Isolate security group.

Which additional step will meet this requirement?

- A. Configure GuardDuty to directly invoke the Lambda function if GuardDuty generates a CryptoCurrency:EC2/* finding event.
- B. Configure an AWS Config rule that invokes the Lambda function if a CryptoCurrency:EC2/* configuration change event occurs for an EC2 instance.
- C. Configure an Amazon EventBridge rule that invokes the Lambda function if GuardDuty generates a CryptoCurrency:EC2/* finding event.
- D. Configure an Amazon EventBridge rule that invokes the Lambda function if AWS Config detects a CryptoCurrency:EC2/* configuration change event for an EC2 instance.

Answer: C

Explanation

Amazon GuardDuty generates security findings when it detects suspicious or malicious activity, including CryptoCurrency:EC2/* findings that indicate an EC2 instance may be involved in unauthorized cryptocurrency mining. According to AWS Certified Security – Specialty documentation, GuardDuty findings are published as events to Amazon EventBridge (formerly Amazon CloudWatch Events).

Amazon EventBridge is the recommended service for building automated incident response workflows. By creating an EventBridge rule that listens for GuardDuty findings of type CryptoCurrency:EC2/*, the security engineer can automatically invoke a Lambda function to isolate the affected EC2 instance by modifying its security group attachments.

Option A is incorrect because GuardDuty does not directly invoke Lambda functions. Option B and Option D are incorrect because AWS Config tracks configuration compliance and resource changes, not real-time threat detection events. Cryptocurrency findings are security detections, not configuration changes.

AWS documentation explicitly describes this pattern—GuardDuty # EventBridge # Lambda # remediation action—as a best practice for automated threat response and containment.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon GuardDuty User Guide – Findings
- ▶ Amazon EventBridge User Guide
- ▶ AWS Incident Response Best Practices

Question #:95 - [Infrastructure Security]

A security engineer has designed a VPC to segment private traffic from public traffic. The VPC includes two Availability Zones. The security engineer has provisioned each Availability Zone with one private subnet and one public subnet. The security engineer has created three route tables for use with the environment. One route table is for the public subnets, and two route tables are for the private subnets (one route table for the private subnet in each Availability Zone).

The security engineer discovers that all four subnets are attempting to route traffic out through the internet gateway that is attached to the VPC.

Which combination of steps should the security engineer take to remediate this scenario? (Select TWO.)

- A. Verify that a NAT gateway has been provisioned in the public subnet in each Availability Zone.
- B. Verify that a NAT gateway has been provisioned in the private subnet in each Availability Zone.
- C. Modify the route tables that are associated with each of the public subnets. Create a new route for local destinations to the VPC CIDR range.
- D. Modify the route tables that are associated with each of the private subnets. Create a new route for the destination 0.0.0.0/0. Specify the NAT gateway in the public subnet of the same Availability Zone as the target of the route.
- E. Modify the route tables that are associated with each of the private subnets. Create a new route for the destination 0.0.0.0/0. Specify the internet gateway as the target of the route.

Answer: A D

Explanation

In a properly segmented VPC architecture, public subnets route internet-bound traffic to an internet gateway, while private subnets route outbound internet traffic through a NAT gateway that resides in a public subnet. According to the AWS Certified Security – Specialty Official Study Guide and Amazon VPC documentation, private subnets must never have a direct route to an internet gateway.

The issue described indicates that private subnets are incorrectly routing traffic directly to the internet gateway. To remediate this, a NAT gateway must be provisioned in each public subnet to ensure high availability across Availability Zones. This satisfies the requirement that private resources can initiate outbound connections without being directly reachable from the internet.

Next, the route tables associated with the private subnets must be updated so that the default route (0.0.0.0/0) points to the NAT gateway in the same Availability Zone. This ensures proper traffic flow and prevents cross-AZ dependencies.

Option B is incorrect because NAT gateways must reside in public subnets. Option C is unnecessary because local routes to the VPC CIDR range are automatically created. Option E is explicitly insecure, as it would reintroduce direct internet gateway access from private subnets.

AWS documentation consistently identifies NAT gateways plus correct private subnet routing as the standard design for secure VPC segmentation.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon VPC Route Table Documentation
- ▶ AWS Well-Architected Framework – Security Pillar

Question #:96 - [Detection]

A company sends Apache logs from EC2 Auto Scaling instances to a CloudWatch Logs log group with 1-year retention. A suspicious IP address appears in logs. A security engineer needs to analyze the past week of logs to count requests from that IP and list requested URLs.

What should the engineer do with the LEAST effort?

- A. Export to S3 and use Macie.
- B. Stream to OpenSearch and analyze.
- C. Use CloudWatch Logs Insights with queries.
- D. Export to S3 and use AWS Glue.

Answer: C

Explanation

CloudWatch Logs Insights is a managed, on-demand query capability designed to search and analyze log data stored in CloudWatch Logs without moving the data elsewhere. AWS Certified Security – Specialty documentation highlights Logs Insights as the lowest-effort method for rapid investigations, because it supports filtering, parsing, aggregation, and time-range queries directly over existing log groups. In this scenario, the logs already exist in CloudWatch Logs with sufficient retention. The engineer can write a query that filters for the suspicious IP address, counts occurrences over the last 7 days, and extracts requested URLs using parsing functions. This satisfies both requirements (count and URLs) immediately, without building

pipelines or exporting data. Option B adds operational overhead by provisioning and maintaining OpenSearch ingestion and indexing. Options A and D require exporting data and additional services that are not necessary for a one-week forensic query. Therefore, Logs Insights is the most efficient and cost-effective approach.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon CloudWatch Logs Insights Querying and Investigation Workflows

Question #:97 - [Detection]

A company requires a specific software application to be installed on all new and existing Amazon EC2 instances across an AWS Organization. SSM Agent is installed and active.

How can the company continuously monitor deployment status of the software application?

- A. Use AWS Config organization-wide with the ec2-managedinstance-applications-required managed rule and specify the application name.
- B. Use approved AMIs rule organization-wide.
- C. Use Distributor package and review output.
- D. Use Systems Manager Application Manager inventory filtering.

Answer: A

Explanation

Continuous monitoring requires an always-on compliance service that evaluates resources over time. AWS Config provides managed rules that assess configuration state and compliance continuously. AWS Certified Security – Specialty guidance highlights AWS Config for continuous compliance across accounts and regions when used with AWS Organizations. The ec2-managedinstance-applications-required managed rule evaluates whether specified software is installed on managed instances, leveraging Systems Manager inventory /managed instance status. By enabling AWS Config organization-wide and deploying this managed rule across all accounts, the company can continuously evaluate both existing and newly launched instances for required application presence. This provides a consistent compliance dashboard and history of compliance changes. Option D can provide inventory lists, but it is not a compliance rule engine that flags noncompliance with the same governance reporting and remediation pathways. Options B and C are operational approaches but do not provide continuous compliance state across the organization.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Config Managed Rules for EC2 and SSM Managed Instances

AWS Organizations Integration with AWS Config

Question #:98 - [Security Foundations and Governance]

A company is running a new workload across accounts that are in an organization in AWS Organizations. All running resources must have a tag of CostCenter, and the tag must have one of three approved values. The company must enforce this policy and must prevent any changes of the CostCenter tag to a non-approved value.

Which solution will meet these requirements?

- A. Create an AWS Config Custom Policy rule by using AWS CloudFormation Guard. Include the tag key of CostCenter and the approved values. Create an SCP that denies the creation of resources when the value of the aws:RequestTag/CostCenter condition key is not one of the three approved values.
- B. Create an AWS CloudTrail trail. Create an Amazon EventBridge rule that includes a rule statement that matches the creation of new resources. Configure the EventBridge rule to invoke an AWS Lambda function that checks for the CostCenter tag. Program the Lambda function to block creation in case of a noncompliant value.
- C. Enable tag policies for the organization. Create a tag policy that specifies a tag key of CostCenter and the approved values. Configure the policy to enforce noncompliant operations. Create an SCP that denies the creation of resources when the aws:RequestTag/CostCenter condition key has a null value.
- D. Enable tag policies for the organization. Create a tag policy that specifies a tag key of CostCenter and the approved values. Create an Amazon EventBridge rule that invokes an AWS Lambda function when a noncompliant tag is created. Program the Lambda function to block changes to the tag.

Answer: A

Explanation

To enforce required tagging and approved values at scale, the strongest guardrail is an SCP because SCPs can prevent API calls across accounts/OUs before resources are created or tags are changed. By using the aws:RequestTag/CostCenter condition key and checking that the value is one of the approved values, an SCP can deny Create (and TagResource/UntagResource where supported)* when the request attempts to set a non-approved value. This prevents “bad” CostCenter values from being introduced.

AWS Config (including custom policy rules with CloudFormation Guard) is excellent for detecting noncompliance and reporting, but on its own it is not a hard preventative control. Pairing Config rule evaluation with an SCP guardrail gives both visibility and prevention. Option A is the only option that explicitly combines an enforceable preventive control (SCP deny based on aws:RequestTag/CostCenter) with compliance evaluation logic.

Option B cannot “block creation” reliably because EventBridge/Lambda is after-the-fact; by the time the function runs, the resource is already created. Option C relies on tag policies enforcement semantics; tag policies primarily standardize and report tag usage, and the provided SCP in C only checks for null/missing values, not for non-approved values or for preventing later changes. Option D is also reactive and not a guaranteed preventative control.

Question #:99 - [Security Foundations and Governance]

A company is running a new workload across accounts in an organization in AWS Organizations. All running resources must have a tag of CostCenter, and the tag must have one of three approved values. The company must enforce this policy and must prevent any changes of the CostCenter tag to a non-approved value.

Which solution will meet these requirements?

- A. Use AWS Config custom policy rule and an SCP to deny non-approved aws:RequestTag/CostCenter values.
- B. Use CloudTrail + EventBridge + Lambda to block creation.
- C. Enable tag policies, define allowed values, enforce noncompliant operations, and use an SCP to deny creation when aws:RequestTag/CostCenter is null.
- D. Enable tag policies and use EventBridge + Lambda to block changes.

Answer: C

Explanation

AWS Organizations tag policies are designed to standardize and govern tag keys and allowed values across accounts. AWS Certified Security – Specialty documentation describes tag policies as a governance mechanism that helps enforce consistent tagging by specifying required tag keys and permitted values. To ensure every resource has the CostCenter tag at creation time, an SCP can deny create actions when aws:RequestTag/CostCenter is missing (null). This prevents resources from being created without the required tag. Tag policies then define the three approved values and can be configured to enforce or report noncompliance depending on supported services, ensuring that tag values remain within the allowed set and preventing drift to unapproved values. Compared with custom Lambda-based enforcement, this approach minimizes operational overhead and keeps enforcement within AWS native governance services. Option A partially addresses allowed values at request time but does not address ongoing governance as cleanly across many services. Option B is not preventive because Lambda runs after events and cannot reliably block all creations. Option D still relies on custom logic and is not as operationally efficient as tag policies plus SCP guardrails.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Organizations Tag Policies

AWS Organizations SCP Condition Keys for Tag Enforcement

Question #:100 - [Detection]

A company's web application is hosted on Amazon EC2 instances running behind an Application Load Balancer (ALB) in an Auto Scaling group. An AWS WAF web ACL is associated with the ALB. AWS CloudTrail is enabled and stores logs in Amazon S3 and Amazon CloudWatch Logs.

The operations team has observed some EC2 instances reboot at random. After rebooting, all access logs on the instances have been deleted. During an investigation, the operations team found that each reboot happened

just after a PHP error occurred on the new-user-creation.php file. The operations team needs to view log information to determine if the company is being attacked.

Which set of actions will identify the suspect attacker 's IP address for future occurrences?

- A. Configure VPC Flow Logs on the subnet where the ALB is located and stream the data to CloudWatch. Search for the new-user-creation.php occurrences in CloudWatch.
- B. Configure the CloudWatch agent on the ALB and send application logs to CloudWatch Logs.
- C. Configure the ALB to export access logs to an Amazon OpenSearch Service cluster and search for the new-user-creation.php occurrences.
- D. Configure the web ACL to send logs to Amazon Data Firehose, which delivers the logs to an S3 bucket. Use Amazon Athena to query the logs and find the new-user-creation.php occurrences.

Answer: D

Explanation

AWS WAF logs captured detailed request-level information, including source IP address, request URI, headers, and rule evaluation results. According to the AWS Certified Security – Specialty documentation, AWS WAF logging is a critical detection control when application-level attacks are suspected, especially when host-based logs are unreliable or can be erased by attackers.

By configuring the AWS WAF web ACL to send logs to Amazon Data Firehose, the company ensures that all future requests are centrally captured and delivered to a durable storage service such as Amazon S3. Using Amazon Athena, the security team can query these logs to identify requests targeting specific application paths such as new-user-creation.php and extract the originating client IP addresses.

Option A is incorrect because VPC Flow Logs operate at the network layer and do not capture HTTP request paths. Option B is invalid because ALBs do not support CloudWatch agents. Option C is viable but introduces additional operational complexity and cost, making it less appropriate than the native WAF logging solution.

AWS documentation highlights AWS WAF logging combined with Athena as a best practice for forensic analysis and attacker identification.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Logging Documentation
- ▶ Amazon Athena User Guide
- ▶ AWS Detection and Monitoring Best Practices

Question #:101 - [Incident Response]

A company finds that one of its Amazon EC2 instances suddenly has a high CPU usage. The company does not know whether the EC2 instance is compromised or whether the operating system is performing background cleanup.

Which combination of steps should a security engineer take before investigating the issue? (Select THREE.)

- A. Disable termination protection for the EC2 instance if termination protection has not been disabled.
- B. Enable termination protection for the EC2 instance if termination protection has not been enabled.
- C. Take snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
- D. Remove all snapshots of the Amazon Elastic Block Store (Amazon EBS) data volumes that are attached to the EC2 instance.
- E. Capture the EC2 instance metadata, and then tag the EC2 instance as under quarantine.
- F. Immediately remove any entries in the EC2 instance metadata that contain sensitive information.

Answer: B C E

Explanation

Before beginning an investigation, incident response best practice is to preserve evidence, prevent accidental loss of the asset, and clearly mark and control the potentially affected resource. Enabling termination protection (Option B) helps ensure the instance is not accidentally terminated during triage, which would destroy volatile evidence and complicate forensics and recovery.

Taking EBS snapshots of all attached data volumes (Option C) preserves a point-in-time copy of disk evidence for later forensic analysis, malware scanning, or offline investigation. Snapshots allow responders to create forensic volumes or AMIs in an isolated environment without repeatedly touching the potentially compromised instance.

Capturing instance metadata and tagging the instance as under quarantine (Option E) supports both investigation and operational control. Metadata capture (instance ID, IAM role, network interfaces, security groups, user-data, tags, recent changes) provides context for responders. Quarantine tagging enables automated workflows (for example, incident runbooks that isolate the instance, restrict IAM, or move it to a quarantine security group) and signals to other teams/tools that the instance is under investigation.

Option A is the opposite of what you want. Option D destroys evidence. Option F is not an appropriate “before investigation” step; altering metadata risks losing evidence and is not the primary containment approach.

Question #:102 - [Infrastructure Security]

A company runs an application on a fleet of Amazon EC2 instances. The application is accessible to users around the world. The company associates an AWS WAF web ACL with an Application Load Balancer (ALB) that routes traffic to the EC2 instances.

A security engineer is investigating a sudden increase in traffic to the application. The security engineer discovers a significant amount of potentially malicious requests coming from hundreds of IP addresses in two countries. The security engineer wants to quickly limit the potentially malicious requests but does not want to prevent legitimate users from accessing the application.

Which solution will meet these requirements?

- A. Use AWS WAF to implement a rate-based rule for all incoming requests.
- B. Use AWS WAF to implement a geographical match rule to block all incoming traffic from the two countries.
- C. Edit the ALB security group to include a geographical match rule to block all incoming traffic from the two countries.
- D. Add deny rules to the ALB security group that prohibit incoming requests from the IP addresses.

Answer: A

Explanation

AWS WAF rate-based rules are specifically designed to protect applications from traffic floods and distributed attacks that originate from large numbers of IP addresses. According to the AWS Certified Security – Specialty Official Study Guide, rate-based rules automatically track the number of requests coming from individual IP addresses and temporarily block IPs that exceed a defined threshold.

In this scenario, the malicious traffic originates from hundreds of IP addresses across two countries, mixed with legitimate user traffic. A rate-based rule allows the security engineer to limit excessive request rates without fully blocking access from entire geographic regions, ensuring that legitimate users can still access the application.

Option B is incorrect because geographic match rules block all traffic from selected countries, which would deny access to legitimate users and violate the stated requirement. Option C is invalid because security groups do not support geographic filtering. Option D is not scalable, as manually blocking hundreds of IP addresses is operationally inefficient and ineffective against rapidly changing attacker IPs.

AWS documentation emphasizes that rate-based rules are the recommended first-line mitigation for sudden traffic spikes and potential application-layer DDoS attacks when business continuity must be preserved.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Developer Guide – Rate-Based Rules
- ▶ AWS DDoS Resiliency Best Practices

Question #:103 - [Detection]

A security engineer for a company is investigating suspicious traffic on a web application in the AWS Cloud. The web application is protected by an Application Load Balancer (ALB) behind an Amazon CloudFront

distribution. There is an AWS WAF web ACL associated with the ALB. The company stores AWS WAF logs in an Amazon S3 bucket.

The engineer notices that all incoming requests in the AWS WAF logs originate from a small number of IP addresses that correspond to CloudFront edge locations. The security engineer must identify the source IP addresses of the clients that are initiating the suspicious requests.

Which solution will meet this requirement?

- A. Enable VPC Flow Logs in the VPC where the ALB is deployed. Examine the source field to capture the client IP addresses.
- B. Inspect the X-Forwarded-For header in the AWS WAF logs to determine the original client IP addresses.
- C. Modify the CloudFront distribution to disable ALB connection reuse. Examine the clientIp field in the AWS WAF logs to identify the original client IP addresses.
- D. Configure CloudFront to add a custom header named Client-IP to origin requests that are sent to the ALB.

Answer: B

Explanation

When Amazon CloudFront is used in front of an Application Load Balancer, CloudFront becomes the immediate source of incoming requests to the ALB. As a result, AWS WAF logs record the CloudFront edge location IP addresses as the client IPs, not the original viewer IP addresses. This behavior is explicitly documented in the AWS Certified Security – Specialty Study Guide and the AWS WAF and CloudFront integration documentation.

To preserve the original client IP address, CloudFront automatically adds the X-Forwarded-For HTTP header, which contains the IP address of the originating client followed by any proxy addresses involved in forwarding the request. AWS WAF logs include this header, making it the authoritative source for identifying true client IP addresses when CloudFront is used.

Option A is incorrect because VPC Flow Logs capture network-level metadata and will only show CloudFront IP addresses, not the original client IPs. Option C is incorrect because disabling connection reuse does not change how client IPs are logged in AWS WAF. Option D is unnecessary and unsupported as a requirement because CloudFront already provides the required information through standard headers.

AWS documentation consistently states that X-Forwarded-For is the correct and supported mechanism for tracing client IPs in CloudFront-protected applications.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Developer Guide – Logging
- ▶ Amazon CloudFront Developer Guide – Request Headers

Question #:104 - [Infrastructure Security]

A company hosts its public website on Amazon EC2 instances behind an Application Load Balancer (ALB). The website is experiencing a global DDoS attack from a specific IoT device brand that uses a unique user agent. A security engineer is creating an AWS WAF web ACL and will associate it with the ALB.

Which rule statement will mitigate the current attack and future attacks from these IoT devices without blocking legitimate customers?

- A. Use an IP set match rule statement.
- B. Use a geographic match rule statement.
- C. Use a rate-based rule statement.
- D. Use a string match rule statement on the user agent.

Answer: D

Explanation

AWS WAF string match rule statements allow inspection of HTTP headers, including the User-Agent header. According to AWS Certified Security – Specialty guidance, when malicious traffic can be uniquely identified by a consistent request attribute, such as a device-specific user agent, a string match rule provides precise mitigation with minimal false positives.

IP-based blocking is ineffective for globally distributed botnets. Geographic blocking risks denying access to legitimate users. Rate-based rules limit request volume but do not prevent low-and-slow attacks.

By matching the unique IoT device brand in the User-Agent header, the security engineer can block only malicious requests while preserving customer access.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS WAF Rule Statements

AWS DDoS Mitigation Best Practices

Question #:105 - [Detection]

A company begins to use AWS WAF after experiencing an increase in traffic to the company's public web applications. A security engineer needs to determine if the increase in traffic is because of application-layer attacks. The security engineer needs a solution to analyze AWS WAF traffic.

Which solution will meet this requirement?



- A. Configure AWS WAF to send logs to a trail in AWS CloudTrail. Create an Amazon Data Firehose delivery stream to send the logs to Amazon OpenSearch Service. Use OpenSearch Dashboards and an Amazon Athena connector to query the logs.
- B. Configure AWS WAF to send logs to an Amazon S3 bucket. Configure an OpenSearch table with a partition projection of the S3 bucket. Use OpenSearch to query the data in the S3 bucket.
- C. Configure AWS WAF to send logs to an Amazon S3 bucket. Configure an Amazon Athena table with a partition projection of the S3 bucket. Use Athena to query the data in the S3 bucket.
- D. Configure AWS WAF to send logs to a trail in AWS CloudTrail. Create an Amazon Data Firehose delivery stream to send the logs to an Amazon S3 bucket. Use Amazon Athena to query the data in the S3 bucket.

Answer: C

Explanation

AWS WAF supports WAF logging as a dedicated feature that can deliver logs to destinations such as Amazon S3 (commonly via Kinesis Data Firehose). These logs contain rich request details (rule matches, action taken, headers, URI, source IP, etc.) that are essential for determining whether traffic spikes are due to application-layer attacks. For analysis with low operational overhead, storing logs in S3 and querying them with Amazon Athena is a standard pattern. Using partition projection further reduces administrative work by avoiding manual partition management and enabling efficient queries over time-based prefixes.

Options A and D incorrectly route WAF logs through CloudTrail; WAF request logs are not delivered “to a CloudTrail trail.” CloudTrail records AWS API activity, not per-request WAF inspection logs. Option B describes querying S3 data directly with OpenSearch using “partition projection,” which is an Athena/Glue concept; OpenSearch is typically used by ingesting data into an index (often via Firehose), not by directly querying S3 objects as a table in that manner.

Therefore, enabling WAF logs to S3 and analyzing them with Athena using partition projection is the correct solution.

Question #:106 - [Detection]

An AWS Lambda function was misused to alter data, and a security engineer must identify who invoked the function and what output was produced. The engineer cannot find any logs created by the Lambda function in Amazon CloudWatch Logs.

Which of the following explains why the logs are not available?

- A. The execution role for the Lambda function did not grant permissions to write log data to CloudWatch Logs.
- B. The Lambda function was invoked by using Amazon API Gateway, so the logs are not stored in CloudWatch Logs.

- C. The execution role for the Lambda function did not grant permissions to write to the Amazon S3 bucket where CloudWatch Logs stores the logs.
- D. The version of the Lambda function that was invoked was not current.

Answer: A

Explanation

AWS Lambda automatically sends function execution logs to Amazon CloudWatch Logs when logging is enabled in the function code. However, this logging capability depends on the Lambda execution role having the appropriate permissions. According to the AWS Certified Security – Specialty Study Guide, the execution role must include permissions such as logs:CreateLogGroup, logs:CreateLogStream, and logs:PutLogEvents.

If these permissions are missing, Lambda cannot create log groups or streams, and no execution logs will appear in CloudWatch Logs—even though the function was successfully invoked. This is the most common reason Lambda logs are unavailable during forensic investigations.

Option B is incorrect because Lambda logs are stored in CloudWatch Logs regardless of whether the invocation source is API Gateway, EventBridge, or another AWS service. Option C is incorrect because CloudWatch Logs does not require direct S3 permissions from the Lambda execution role. Option D is irrelevant because Lambda versions do not affect logging behavior.

AWS documentation emphasizes verifying execution role permissions as a first step when Lambda logs are missing.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Lambda Execution Roles

Amazon CloudWatch Logs Integration with Lambda

Question #:107 - [Identity and Access Management]

A company has a web application that reads from and writes to an Amazon S3 bucket. The company needs to authenticate all S3 API calls with AWS credentials.

Which solution will provide the application with AWS credentials?

- A. Use Amazon Cognito identity pools and the GetId API.
- B. Use Amazon Cognito identity pools and AssumeRoleWithWebIdentity.
- C. Use Amazon Cognito user pools with ID tokens.
- D. Use Amazon Cognito user pools with access tokens.

Answer: B



Explanation

Amazon Cognito identity pools provide temporary AWS credentials by exchanging web identity tokens with AWS STS using AssumeRoleWithWebIdentity. According to AWS Certified Security – Specialty documentation, this is the correct mechanism for granting applications AWS credentials.

User pools authenticate users but do not issue AWS credentials. Identity pools integrate with IAM roles and STS, enabling secure, temporary access to AWS services.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Cognito Identity Pools

AWS STS Web Identity Federation

Question #:108 - [Data Protection]

A company needs a solution to protect critical data from being permanently deleted. The data is stored in Amazon S3 buckets. The company needs to replicate the S3 objects from the company 's primary AWS Region to a secondary Region to meet disaster recovery requirements. The company must also ensure that users who have administrator access cannot permanently delete the data in the secondary Region.

Which solution will meet these requirements?

- A. Configure AWS Backup to perform cross-Region S3 backups. Select a backup vault in the secondary Region. Enable AWS Backup Vault Lock in governance mode for the backups in the secondary Region.
- B. Implement S3 Object Lock in compliance mode in the primary Region. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region.
- C. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Create an S3 bucket policy to deny the s3:ReplicateDelete action on the S3 bucket in the secondary Region.
- D. Configure S3 replication to replicate the objects to an S3 bucket in the secondary Region. Configure S3 object versioning on the S3 bucket in the secondary Region.

Answer: B

Explanation

The requirement is twofold: cross-Region replication for disaster recovery and immutability so that even administrators cannot permanently delete data in the secondary Region. The S3-native feature designed to prevent deletion (including version deletion) for a defined retention period is S3 Object Lock. When Object Lock is configured in compliance mode, no user, including the root user and administrators, can remove Object Lock protections or permanently delete protected object versions before retention expires. This meets the “admins cannot permanently delete” requirement far better than policy-based controls.

To replicate the data for DR, the company can configure S3 replication from the primary Region bucket to a bucket in the secondary Region. With Object Lock in place (and the destination bucket appropriately configured to support Object Lock and versioning), replicated objects can be retained immutably, providing a strongly protected copy for recovery.

Option D (versioning alone) prevents accidental overwrites but does not stop an admin from deleting all versions. Option C only blocks replication deletes; it does not prevent an admin from deleting objects directly in the secondary bucket. Option A uses AWS Backup vault lock in governance mode, which still allows privileged users with special permissions to override retention; it also creates backups rather than true object-level replication. Therefore, Object Lock in compliance mode combined with replication is the best match.

Question #:109 - [Detection]

A company is using Amazon Macie, AWS Firewall Manager, Amazon Inspector, and AWS Shield Advanced in its AWS account. The company wants to receive alerts if a DDoS attack occurs against the account.

Which solution will meet this requirement?

- A. Use Amazon Macie to detect an active DDoS event and create Amazon CloudWatch alarms that respond to Macie findings.
- B. Use Amazon Inspector to review resources and invoke Amazon CloudWatch alarms for any resources that are vulnerable to DDoS attacks.
- C. Create an Amazon CloudWatch alarm that monitors AWS Firewall Manager metrics for an active DDoS event.
- D. Create an Amazon CloudWatch alarm that monitors AWS Shield Advanced metrics for an active DDoS event.

Answer: D

Explanation

AWS Shield Advanced is the AWS-native managed service specifically designed to provide detection, mitigation, and visibility for Distributed Denial of Service (DDoS) attacks at both the network and application layers. Shield Advanced integrates directly with Amazon CloudWatch by publishing DDoS-related metrics such as DDoSDetected, AttackVolume, and AttackVector, which can be monitored using CloudWatch alarms to trigger alerts in near real time. This makes option D the correct and fully supported solution.

Amazon Macie focuses on discovering and protecting sensitive data (such as PII) in Amazon S3 using machine learning and does not provide DDoS detection capabilities, making option A incorrect. Amazon Inspector is a vulnerability management service that assesses EC2 instances, container images, and Lambda functions for software vulnerabilities and unintended network exposure; it does not detect live DDoS attacks, so option B is incorrect. AWS Firewall Manager is a centralized management service for configuring AWS WAF, Shield Advanced, and security groups across accounts, but it does not emit native DDoS detection metrics for alerting, which eliminates option C.

According to AWS Security Specialty documentation, the recommended best practice for DDoS detection and alerting is to enable AWS Shield Advanced and configure Amazon CloudWatch alarms on Shield metrics,

optionally integrating with Amazon SNS for notifications and AWS Incident Manager for response automation.

Question #:110 - [Data Protection]

A company's data scientists want to create artificial intelligence and machine learning (AI/ML) training models by using Amazon SageMaker. The training models will use large datasets in an Amazon S3 bucket. The datasets contain sensitive information.

On average, the data scientists need 30 days to train models. The S3 bucket has been secured appropriately. The company's data retention policy states that all data that is older than 45 days must be removed from the S3 bucket.

Which action should a security engineer take to enforce this data retention policy?

- A. Configure an S3 Lifecycle rule on the S3 bucket to delete objects after 45 days.
- B. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45 days. Create an S3 event notification to invoke the Lambda function for each PutObject operation.
- C. Create an AWS Lambda function to check the last-modified date of the S3 objects and delete objects that are older than 45 days. Create an Amazon EventBridge rule to invoke the Lambda function each month.
- D. Configure S3 Intelligent-Tiering on the S3 bucket to automatically transition objects to another storage class.

Answer: A

Explanation

Amazon S3 Lifecycle rules provide anative, fully managed mechanismto automatically transition or delete objects based on their age. According to the AWS Certified Security – Specialty Official Study Guide, S3 Lifecycle policies are therecommended and most secure methodfor enforcing data retention requirements because they operate automatically, consistently, and without custom code.

By configuring a lifecycle rule to delete objects after 45 days, the company ensures that sensitive datasets are retained long enough to support the 30-day model training process while remaining compliant with the data retention policy. Lifecycle rules are enforced by Amazon S3 itself and apply uniformly to all objects in the bucket or to objects that match specific prefixes or tags.

Option B and Option C introduce unnecessary operational complexity and risk by relying on custom Lambda code and scheduling. These approaches are more error-prone, harder to audit, and less reliable than a built-in S3 capability. Option D is incorrect because S3 Intelligent-Tiering manages storage cost optimization and does not delete data.

AWS documentation explicitly states thatS3 Lifecycle rules are the standard control for enforcing retention and deletion policies, particularly for sensitive data stored at scale.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon S3 Lifecycle Configuration Documentation
- ▶ AWS Data Protection Best Practices

Question #:111 - [Incident Response]

A security engineer received an Amazon GuardDuty alert indicating a finding involving the Amazon EC2 instance that hosts the company's primary website. The GuardDuty finding received read: UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration. The security engineer confirmed that a malicious actor used API access keys intended for the EC2 instance from a country where the company does not operate. The security engineer needs to deny access to the malicious actor.

What is the first step the security engineer should take?

- A. Open the EC2 console and remove any security groups that allow inbound traffic from 0.0.0.0/0.
- B. Install the AWS Systems Manager Agent on the EC2 instance and run an inventory report.
- C. Install the Amazon Inspector agent on the host and run an assessment with the CVE rules package.
- D. Open the IAM console and revoke all IAM sessions that are associated with the instance profile.

Answer: D

Explanation

The finding InstanceCredentialExfiltration indicates that credentials available to the EC2 instance (from the instance profile / IMDS) were likely stolen and then used from an unusual location. The fastest way to deny the malicious actor immediately is to invalidate the stolen, currently usable credentials. Because these are temporary credentials issued to the instance profile role, the correct first containment action is to revoke active sessions for that role so the stolen session credentials stop working. This directly blocks continued API use while you continue investigation and remediation.

Changing security groups (Option A) affects inbound network access to the website but does not stop an attacker from using stolen API credentials against AWS APIs. Installing agents and running assessments (Options B and C) are investigative steps that take time and do not immediately cut off the attacker's current access. After revoking sessions, best practice incident response typically continues with additional containment and eradication steps such as rotating credentials, reviewing CloudTrail for actions taken, checking for persistence (new IAM users/keys, modified policies), patching the instance, and restricting IMDS (for example, enforcing IMDSv2) to reduce risk of further credential theft.

Question #:112 - [Security Foundations and Governance]

A company is implementing new compliance requirements to meet customer needs. According to the new requirements, the company must not use any Amazon RDS DB instances or DB clusters that lack encryption

of the underlying storage. The company needs a solution that will generate an email alert when an unencrypted DB instance or DB cluster is created. The solution also must terminate the unencrypted DB instance or DB cluster.

Which solution will meet these requirements in the MOST operationally efficient manner?

- A. Create an AWS Config managed rule to detect unencrypted RDS storage. Configure an automatic remediation action to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic that includes an AWS Lambda function and an email delivery target as subscribers. Configure the Lambda function to delete the unencrypted resource.
- B. Create an AWS Config managed rule to detect unencrypted RDS storage. Configure a manual remediation action to invoke an AWS Lambda function. Configure the Lambda function to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic and to delete the unencrypted resource.
- C. Create an Amazon EventBridge rule that evaluates RDS event patterns and is initiated by the creation of DB instances or DB clusters. Configure the rule to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic that includes an AWS Lambda function and an email delivery target as subscribers. Configure the Lambda function to delete the unencrypted resource.
- D. Create an Amazon EventBridge rule that evaluates RDS event patterns and is initiated by the creation of DB instances or DB clusters. Configure the rule to invoke an AWS Lambda function. Configure the Lambda function to publish messages to an Amazon Simple Notification Service (Amazon SNS) topic and to delete the unencrypted resource.

Answer: A

Explanation

AWS Config provides managed rules that continuously evaluate resource configurations against compliance requirements. The AWS Certified Security – Specialty documentation highlights AWS Config managed rules as the preferred mechanism for enforcing configuration compliance at scale. The managed rule for encrypted RDS storage automatically detects DB instances and clusters that are created without encryption enabled.

By configuring automatic remediation, AWS Config can immediately invoke corrective actions without manual intervention. Integrating remediation with an Amazon SNS topic enables automated email notifications, while an AWS Lambda function can terminate the noncompliant resource. This creates a fully automated detect-alert-remediate workflow.

Option B requires manual remediation, which increases operational effort and delays enforcement. Options C and D rely on Amazon EventBridge, which evaluates events rather than configuration state and does not provide continuous compliance monitoring. AWS Config is explicitly designed for configuration compliance and governance use cases.

This solution aligns with AWS governance best practices by combining continuous monitoring, automated remediation, and centralized alerting with minimal operational overhead.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Config Managed Rules

AWS Config Automatic Remediation

Question #:113 - [Infrastructure Security]

A security engineer is designing a solution that will provide end-to-end encryption between clients and Docker containers running in Amazon Elastic Container Service (Amazon ECS). This solution must also handle volatile traffic patterns.

Which solution would have the MOST scalability and LOWEST latency?

- A. Configure a Network Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.
- B. Configure an Application Load Balancer to terminate the TLS traffic and then re-encrypt the traffic to the containers.
- C. Configure a Network Load Balancer with a TCP listener to pass through TLS traffic to the containers.
- D. Configure Amazon Route 53 to use multivalue answer routing to send traffic to the containers.

Answer: C

Explanation

Network Load Balancers operate at Layer 4 and are optimized for extreme performance, ultra-low latency, and handling sudden traffic spikes. According to AWS Certified Security – Specialty documentation, using a TCP listener on an NLB allows TLS traffic to pass through directly to backend containers without termination, preserving true end-to-end encryption.

This approach eliminates the overhead of decrypting and re-encrypting traffic at the load balancer, reducing latency and maximizing throughput. NLBs scale automatically to handle volatile traffic patterns and millions of requests per second.

Application Load Balancers operate at Layer 7 and introduce additional latency due to TLS termination and HTTP processing. Route 53 multivalue routing does not provide load balancing at the transport layer and does not ensure encryption handling.

AWS recommends NLB TCP pass-through for high-performance, end-to-end encrypted container workloads.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Elastic Load Balancing Architecture

Network Load Balancer Performance Characteristics



Question #:114 - [Detection]

A security engineer is designing security controls for a fleet of Amazon EC2 instances that run sensitive workloads in a VPC. The security engineer needs to implement a solution to detect and mitigate software vulnerabilities on the EC2 instances.

Which solution will meet this requirement?

- A. Scan the EC2 instances by using Amazon Inspector. Apply security patches and updates by using AWS Systems Manager Patch Manager.
- B. Install host-based firewall and antivirus software on each EC2 instance. Use AWS Systems Manager Run Command to update the firewall and antivirus software.
- C. Install the Amazon CloudWatch agent on the EC2 instances. Enable detailed logging. Use Amazon EventBridge to review the software logs for anomalies.
- D. Scan the EC2 instances by using Amazon GuardDuty Malware Protection. Apply security patches and updates by using AWS Systems Manager Patch Manager.

Answer: A

Explanation

To address software vulnerabilities, you need both (1) a vulnerability assessment capability and (2) a consistent patching mechanism. Amazon Inspector continuously scans EC2 instances for known software vulnerabilities and exposures (CVEs), package-level issues, and security misconfigurations relevant to the supported scan types. It provides prioritized findings and helps the security team understand which instances are exposed and why.

To mitigate those vulnerabilities, AWS Systems Manager Patch Manager provides automated, policy-driven patching for fleets of EC2 instances. Patch Manager can schedule patch windows, control reboots, enforce baselines, and report compliance, allowing the company to remediate issues at scale with controlled operational impact.

Option B focuses on firewall/AV tooling, which can be helpful, but it is not a complete vulnerability detection-and-patching solution and is heavier to manage across large fleets. Option C is centered on log anomaly detection, not vulnerability management. Option D mixes GuardDuty Malware Protection (malware detection) with patching; GuardDuty is not a vulnerability scanner and does not replace Inspector for CVE detection. Therefore, Inspector + Patch Manager is the correct combined solution to detect and mitigate software vulnerabilities.

Question #:115 - [Detection]

A company is developing an application that runs across a combination of Amazon EC2 On-Demand Instances and Spot Instances. A security engineer needs to provide a logging solution that makes logs for all instances available from a single location. The solution must allow only a specific set of users to analyze the logs for events patterns. The users must be able to use SQL queries on the logs to perform root cause analysis.

Which solution will meet these requirements?

- A. Configure the EC2 instances to send application logs to a single Amazon CloudWatch Logs log group. Allow only specific users to access the log group. Use CloudWatch Logs Insights to query the log group.
- B. Configure the EC2 instances to send application logs to a single Amazon S3 bucket. Allow only specific users to access the S3 bucket. Use Amazon CloudWatch Logs Insights to query the log files in the S3 bucket.
- C. Configure each EC2 instance to send its application logs to its own specific Amazon CloudWatch Logs log group. Allow only specific users to access the log groups. Use Amazon Athena to query all the log groups.
- D. Configure the EC2 instances to send application logs to a single Amazon CloudWatch Logs log group. Grant Amazon Detective access to the log group. Allow only specific users to use Detective to query the log group.

Answer: A

Explanation

Option A satisfies all requirements with the most direct, purpose-built AWS logging workflow. By using the CloudWatch Agent (or fluent-bit / unified logging configuration) on each EC2 instance—regardless of whether it is On-Demand or Spot—the application logs can be centralized into a single Amazon CloudWatch Logs log group. Centralization ensures the logs remain available even as Spot Instances are interrupted and replaced. Access control is handled with IAM policies (and optionally resource policies/KMS encryption) so that only a specific set of users can read/query the log group.

For analysis, CloudWatch Logs Insights provides an interactive query language that is SQL-like and commonly treated as “SQL queries” for troubleshooting. It enables fast filtering, aggregation, and pattern detection across large log volumes without building a separate data lake pipeline. This supports event-pattern analysis and root cause investigation directly from the centralized log group.

Option B is incorrect because Logs Insights queries CloudWatch Logs data, not arbitrary log files sitting in S3. Option C is inefficient (many log groups) and Athena cannot directly query CloudWatch log groups as a native data source. Option D is incorrect because Amazon Detective is for security investigations across supported data sources and is not the primary service for ad-hoc SQL-style querying of application logs.

Question #:116 - [Security Foundations and Governance]

A company has security requirements for Amazon Aurora MySQL databases regarding encryption, deletion protection, public access, and audit logging. The company needs continuous monitoring and real-time visibility into compliance status.

Which solution will meet these requirements?

- A. Use AWS Audit Manager with a custom framework.
- B. Enable AWS Config and use managed rules to monitor Aurora MySQL compliance.

- C. Use AWS Security Hub configuration policies.
- D. Use EventBridge and Lambda with custom metrics.

Answer: B

Explanation

AWS Config is the AWS service designed to continuously evaluate resource configurations against defined rules. According to the AWS Certified Security – Specialty Study Guide, AWS Config managed rules exist specifically to check database encryption, public accessibility, deletion protection, and log exports for Amazon RDS and Aurora.

AWS Config provides a real-time compliance timeline and displays the compliance state of each resource against each rule at any point in time. This granular visibility is required to assess ongoing compliance with security policies.

Audit Manager generates reports but does not provide continuous compliance monitoring. Security Hub aggregates findings but does not track configuration drift. EventBridge and Lambda introduce unnecessary complexity.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Config Managed Rules for RDS

AWS Continuous Compliance Monitoring

Question #:117 - [Infrastructure Security]

A company is migrating one of its legacy systems from an on-premises data center to AWS. The application server will run on AWS, but the database must remain in the on-premises data center for compliance reasons. The database is sensitive to network latency. Additionally, the data that travels between the on-premises data center and AWS must have IPsec encryption.

Which combination of AWS solutions will meet these requirements? (Select TWO.)

- A. AWS Site-to-Site VPN
- B. AWS Direct Connect
- C. AWS VPN CloudHub
- D. VPC peering
- E. NAT gateway

Answer: A B

Explanation

The database is latency-sensitive, so the connectivity option should minimize jitter and provide more consistent performance than traversing the public internet. AWS Direct Connect provides a dedicated network connection from the on-premises environment into AWS, typically delivering more stable throughput and lower/consistent latency characteristics compared with internet-based paths. However, Direct Connect by itself does not automatically provide IPsec encryption.

To satisfy the explicit requirement that traffic must have IPsec encryption, the common AWS pattern is to run an AWS Site-to-Site VPN (IPsec tunnels) in conjunction with Direct Connect. This can be done as “VPN over Direct Connect” to encrypt the traffic while still taking advantage of Direct Connect’s private, predictable connectivity. This combination meets both requirements: improved latency characteristics (Direct Connect) and IPsec encryption (Site-to-Site VPN).

The other options do not fit. VPN CloudHub (Option C) is for connecting multiple remote sites together via AWS as a hub-and-spoke, not a primary low-latency private link. VPC peering (Option D) is only for VPC-to-VPC connectivity and does not connect to on-premises. NAT gateway (Option E) is for outbound internet / NAT translation and does not provide private encrypted connectivity to on-premises.

Question #:118 - [Data Protection]

A company wants to store all objects that contain sensitive data in an Amazon S3 bucket. The company will use server-side encryption to encrypt the S3 bucket. The company's operations team manages access to the company's S3 buckets. The company's security team manages access to encryption keys. The company wants to separate the duties of the two teams to ensure that configuration errors by only one of these teams will not compromise the data by granting unauthorized access to plaintext data.

Which solution will meet this requirement?

- A. Ensure that the operations team configures default bucket encryption on the S3 bucket to use server-side encryption with Amazon S3 managed encryption keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to use the encryption keys.
- B. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with AWS KMS keys (SSE-KMS) that are customer managed. Ensure that the security team creates a key policy that controls access to the encryption keys.
- C. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with Amazon S3 managed keys (SSE-S3). Ensure that the security team creates an IAM policy that controls access to the encryption keys.
- D. Ensure that the operations team creates a bucket policy that requires requests to use server-side encryption with customer-provided encryption keys (SSE-C). Ensure that the security team stores the customer-provided keys in AWS Key Management Service (AWS KMS). Ensure that the security team creates a key policy that controls access to the encryption keys.

Answer: B

Explanation

To achieve true separation of duties, the company needs a design where S3 access alone is not sufficient to read plaintext data. SSE-KMS with a customer managed KMS key provides that separation because successful object reads require both: (1) S3 permissions to read the object and (2) permission to use the KMS key to decrypt it. This enables the operations team to manage bucket and object permissions while the security team independently controls key usage through the KMS key policy (and grants). If either team misconfigures only their part, the data is still protected: an overly permissive bucket policy won't expose plaintext unless KMS decrypt is also allowed; similarly, KMS permissions alone are not sufficient without S3 read access.

Option B also adds a bucket policy requirement enforcing SSE-KMS so objects are consistently protected with the customer managed key. SSE-S3 options (A and C) do not provide the same separation because S3 manages the keys and decryption is not independently controlled by a separate team via KMS policies. Option D is invalid because SSE-C uses customer-provided keys that are supplied with each request and are not stored / managed in KMS as described. Therefore, SSE-KMS with customer managed keys plus restrictive key policy is the correct solution.

Question #:119 - [Detection]

A company has a web-based application that runs behind an Application Load Balancer (ALB). The application is experiencing a credential stuffing attack that is producing many failed login attempts. The attack is coming from many IP addresses. The login attempts are using a user agent string of a known mobile device emulator. A security engineer needs to implement a solution to mitigate the credential stuffing attack. The solution must still allow legitimate logins to the application.

Which solution will meet these requirements?

- A. Create an Amazon CloudWatch alarm that reacts to login attempts that contain the specified user agent string. Add an Amazon Simple Notification Service (Amazon SNS) topic to the alarm.
- B. Modify the inbound security group on the ALB to deny traffic from the IP addresses that are involved in the attack.
- C. Create an AWS WAF web ACL for the ALB. Create a custom rule that blocks requests that contain the user agent string of the device emulator.
- D. Create an AWS WAF web ACL for the ALB. Create a custom rule that allows requests from legitimate user agent strings.

Answer: C

Explanation

A credential stuffing attack at the ALB is a Layer 7 problem and is best mitigated with AWS WAF. The attacker is distributed across many IPs, so blocking by IP in a security group (Option B) is ineffective and operationally heavy. A CloudWatch alarm (Option A) only alerts; it does not block or mitigate requests.

Because the malicious traffic uses a distinctive, known User-Agent string associated with a mobile device emulator, AWS WAF can quickly reduce the attack by inspecting the User-Agent header and blocking matching requests. This approach is targeted: it blocks the identified automated attack pattern while allowing legitimate users who do not present that emulator User-Agent to continue logging in. The WAF rule can be deployed immediately on the existing ALB-associated web ACL and can be further refined (for example,

applied only to /login paths, combined with rate-based rules, or integrated with Bot Control) to minimize false positives.

Option D is risky because “allow only legitimate user agents” is brittle: user agents are diverse and change frequently, and a strict allow-list can accidentally block real users. Therefore, a WAF custom block rule for the known malicious User-Agent string is the correct solution.

Question #:120 - [Incident Response]

A company runs an internet-accessible application on several Amazon EC2 instances that run Windows Server. The company used an instance profile to configure the EC2 instances. A security team currently accesses the VPC that hosts the EC2 instances by using an AWS Site-to-Site VPN tunnel from an on-premises office. The security team issues a policy that requires all external access to the VPC to be blocked in the event of a security incident. However, during an incident, the security team must be able to access the EC2 instances to obtain forensic information on the instances.

Which solution will meet these requirements?

- A. Install EC2 Instance Connect on the EC2 instances. Update the IAM policy for the IAM role to grant the required permissions. Use the AWS CLI to open a tunnel to connect to the instances.
- B. Install EC2 Instance Connect on the EC2 instances. Configure the instances to permit access to the ec2-instance-connect command user. Use the AWS Management Console to connect to the EC2 instances.
- C. Create an EC2 Instance Connect endpoint in the VPC. Configure an appropriate security group to allow access between the EC2 instances and the endpoint. Use the AWS CLI to open a tunnel to connect to the instances.
- D. Create an EC2 Instance Connect endpoint in the VPC. Configure an appropriate security group to allow access between the EC2 instances and the endpoint. Use the AWS Management Console to connect to the EC2 instances.

Answer: D

Explanation

During an incident, the company wants to block “external access to the VPC” (for example, shutting down VPN ingress or internet-exposed paths) yet still allow the security team to access instances for forensics. An EC2 Instance Connect Endpoint (EIC Endpoint) provides a managed, private connectivity path that lets authorized users connect to instances in a VPC without requiring inbound access from the internet or from on-premises. The endpoint lives inside the VPC, and access is controlled by IAM permissions plus security group rules between the endpoint and the instances. This supports incident containment (no external network entry) while preserving controlled administrative access for investigation.

Options A and B require installing Instance Connect on the instances and typically rely on network reachability patterns that may be blocked when external access is cut off; they also do not provide the same VPC-resident endpoint model. With an EIC endpoint, the security team can use the AWS Management Console to initiate connections (Option D) even while the VPC is isolated from on-prem and the public internet, because the connectivity is mediated through AWS control plane and the endpoint inside the VPC.

Option C mentions using the CLI to open a tunnel, but the most straightforward and commonly used operational method for responders is console-based access via the EIC endpoint. Therefore, creating an Instance Connect Endpoint and using the console meets the requirement.

Question #:121 - [Security Foundations and Governance]

A security engineer needs to build a solution to turn AWS CloudTrail back on in multiple AWS Regions in case it is ever turned off.

What is the MOST efficient way to implement this solution?

- A. Use AWS Config with a managed rule to initiate the AWS-EnableCloudTrail remediation.
- B. Create an Amazon EventBridge event with a cloudtrail.amazonaws.com event source and a StartLogging event name to invoke an AWS Lambda function to call the StartLogging API.
- C. Create an Amazon CloudWatch alarm with a cloudtrail.amazonaws.com event source and a StopLogging event name to invoke an AWS Lambda function to call the StartLogging API.
- D. Monitor AWS Trusted Advisor to ensure CloudTrail logging is enabled.

Answer: A

Explanation

The most efficient approach is to use AWS Config because Config is designed for continuous compliance evaluation and can automatically trigger managed remediation when a resource drifts from the desired state. A managed Config rule that detects when CloudTrail is not logging, combined with the AWS-EnableCloudTrail remediation action, provides an automated way to re-enable CloudTrail without building and maintaining custom event processing code. This is especially valuable in multi-Region environments because Config can evaluate configurations across Regions and enforce the intended posture consistently.

Option B is illogical: triggering on StartLogging does not help when CloudTrail is turned off. Option C is not as operationally efficient because CloudWatch alarms are not the standard mechanism for reacting to CloudTrail API events; EventBridge is the proper event bus for API call events, but you would still be writing and maintaining Lambda logic and multi-Region plumbing. Option D is manual and delayed, not automated remediation.

Therefore, AWS Config with a managed rule and the AWS-provided remediation to enable CloudTrail is the most maintainable and efficient solution.

Question #:122 - [Detection]

A company is investigating an increase in its AWS monthly bill. The company discovers that bad actors compromised some Amazon EC2 instances and served webpages for a large email phishing campaign. A security engineer must implement a solution to monitor for cost increases in the future to help detect malicious activity.

Which solution will offer the company the EARLIEST detection of cost increases?

- A. Create an Amazon EventBridge rule that invokes an AWS Lambda function hourly. Program the Lambda function to download an AWS usage report from AWS Data Exports about usage of all services. Program the Lambda function to analyze the report and to send a notification when anomalies are detected.
- B. Create a cost monitor in AWS Cost Anomaly Detection. Configure an individual alert to notify an Amazon Simple Notification Service (Amazon SNS) topic when the percentage above the expected cost exceeds a threshold.
- C. Review AWS Cost Explorer daily to detect anomalies in cost from prior months. Review the usage of any services that experience a significant cost increase from prior months.
- D. Capture VPC flow logs from the VPC where the EC2 instances run. Use a third-party network analysis tool to analyze the flow logs and to detect anomalies in network traffic that might increase cost.

Answer: B

Explanation

For the earliest detection of abnormal spend, the most direct and purpose-built capability is AWS Cost Anomaly Detection. It continuously evaluates spend patterns and uses machine learning to identify unexpected cost increases soon after they begin, then sends alerts based on the configured thresholds. By creating a cost monitor (for example, for linked accounts, services, or cost categories) and configuring an alert to publish to SNS, the security team can receive near-real-time notifications when costs deviate beyond an expected baseline. This is well suited for detecting compromise-driven spend (such as abused EC2 instances serving phishing pages, crypto-mining, or data exfiltration patterns that raise transfer costs).

Option A introduces significant operational overhead and delays because billing/usage exports are not guaranteed to be updated on an hourly cadence in a way that consistently outperforms the native anomaly detector, and the company would be maintaining custom analytics logic. Option C is explicitly slower (daily manual review). Option D may detect suspicious traffic but is indirect for “earliest cost increase” detection and depends on building/operating a separate analytics pipeline; also, not all cost anomalies are visible from flow logs. Therefore, Cost Anomaly Detection provides the fastest and lowest-overhead alerting for unexpected spend.

Question #:123 - [Incident Response]

An application is running on an Amazon EC2 instance that has an IAM role attached. The IAM role provides access to an AWS Key Management Service (AWS KMS) customer managed key and an Amazon S3 bucket. The key is used to access 2 TB of sensitive data that is stored in the S3 bucket. A security engineer discovers a potential vulnerability on the EC2 instance that could result in the compromise of the sensitive data. Due to other critical operations, the security engineer cannot immediately shut down the EC2 instance for vulnerability patching.

What is the FASTEST way to prevent the sensitive data from being exposed?

- A. Download the data from the existing S3 bucket to a new EC2 instance. Then delete the data from the S3 bucket. Re-encrypt the data with a client-based key. Upload the data to a new S3 bucket.

- B. Block access to the public range of S3 endpoint IP addresses by using a host-based firewall. Ensure that internet-bound traffic from the affected EC2 instance is routed through the host-based firewall.
- C. Revoke the IAM role's active session permissions. Update the S3 bucket policy to deny access to the IAM role. Remove the IAM role from the EC2 instance profile.
- D. Disable the current key. Create a new KMS key that the IAM role does not have access to, and re-encrypt all the data with the new key. Schedule the compromised key for deletion.

Answer: C

Explanation

AWS incident response best practices emphasize rapid containment to prevent further data exposure. According to the AWS Certified Security – Specialty Study Guide, the fastest and least disruptive containment method for compromised compute resources is to immediately revoke credentials and permissions rather than modifying data or infrastructure.

Revoking the IAM role's active sessions prevents the EC2 instance from continuing to access AWS services. Updating the S3 bucket policy to explicitly deny access to the IAM role ensures immediate enforcement, even if temporary credentials remain cached. Removing the IAM role from the instance profile further prevents new credentials from being issued.

Option A and D involve large-scale data movement or re-encryption, which is time-consuming and operationally expensive. Option B relies on network-level controls that do not prevent access through private AWS endpoints.

AWS guidance explicitly recommends credential revocation and policy-based denial as the fastest containment step during active incidents.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Incident Response Best Practices

AWS IAM Role Session Management

Question #:124 - [Infrastructure Security]

A company is operating an open-source software platform that is internet facing. The legacy software platform no longer receives security updates. The software platform operates using Amazon Route 53 weighted load balancing to send traffic to two Amazon EC2 instances that connect to an Amazon RDS cluster. A recent report suggests this software platform is vulnerable to SQL injection attacks, with samples of attacks provided. The company's security engineer must secure this system against SQL injection attacks within 24 hours. The solution must involve the least amount of effort and maintain normal operations during implementation.

What should the security engineer do to meet these requirements?

- A. Create an Application Load Balancer with the existing EC2 instances as a target group. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the ALB. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to the ALB. Update security groups on the EC2 instances to prevent direct access from the internet.
- B. Create an Amazon CloudFront distribution specifying one EC2 instance as an origin. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the distribution. Test to ensure the vulnerability has been mitigated, then redirect the Route 53 records to point to CloudFront.
- C. Obtain the latest source code for the platform and make the necessary updates. Test the updated code to ensure that the vulnerability has been mitigated, then deploy the patched version of the platform to the EC2 instances.
- D. Update the security group that is attached to the EC2 instances, removing access from the internet to the TCP port used by the SQL database. Create an AWS WAF web ACL containing rules that protect the application from this attack, then apply it to the EC2 instances.

Answer: A

Explanation

AWS WAF provides managed and custom rules that can immediately mitigate common web exploits such as SQL injection without modifying application code. According to AWS Certified Security – Specialty documentation, placing AWS WAF in front of an Application Load Balancer is a recommended rapid-response control for legacy applications with known vulnerabilities.

Creating an ALB in front of the existing EC2 instances allows seamless traffic migration. AWS WAF SQL injection rules can be deployed and tested without downtime. Updating Route 53 to point to the ALB preserves normal operations. Restricting EC2 security groups afterward prevents bypassing the WAF.

Option B introduces CloudFront changes and single-origin testing, increasing complexity. Option C cannot be completed within 24 hours and risks downtime. Option D is invalid because AWS WAF cannot be attached directly to EC2 instances.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS WAF Web ACL Architecture

AWS Application Load Balancer Security

Question #:125 - [Incident Response]

A security engineer receives a notice about suspicious activity from a Linux-based Amazon EC2 instance that uses Amazon Elastic Block Store (Amazon EBS)-based storage. The instance is making connections to known malicious addresses.

The instance is in a development account within a VPC that is in the us-east-1 Region. The VPC contains an internet gateway and has a subnet in us-east-1a and us-east-1b. Each subnet is associated with a route table that uses the internet gateway as a default route. Each subnet also uses the default network ACL. The suspicious EC2 instance runs within the us-east-1b subnet. During an initial investigation, a security engineer discovers that the suspicious instance is the only instance that runs in the subnet.

Which response will immediately mitigate the attack and help investigate the root cause?

- A. Log in to the suspicious instance and use the netstat command to identify remote connections. Use the IP addresses from these remote connections to create deny rules in the security group of the instance. Install diagnostic tools on the instance for investigation. Update the outbound network ACL for the subnet in us-east-1b to explicitly deny all connections as the first rule during the investigation of the instance.
- B. Update the outbound network ACL for the subnet in us-east-1b to explicitly deny all connections as the first rule. Replace the security group with a new security group that allows connections only from a diagnostics security group. Update the outbound network ACL for the us-east-1b subnet to remove the deny all rule. Launch a new EC2 instance that has diagnostic tools. Assign the new security group to the new EC2 instance. Use the new EC2 instance to investigate the suspicious instance.
- C. Ensure that the Amazon Elastic Block Store (Amazon EBS) volumes that are attached to the suspicious EC2 instance will not delete upon termination. Terminate the instance. Launch a new EC2 instance in us-east-1a that has diagnostic tools. Mount the EBS volumes from the terminated instance for investigation.
- D. Create an AWS WAF web ACL that denies traffic to and from the suspicious instance. Attach the AWS WAF web ACL to the instance to mitigate the attack. Log in to the instance and install diagnostic tools to investigate the instance.

Answer: C

Explanation

AWS incident response best practices emphasize immediate containment, preservation of evidence, and safe forensic investigation. According to the AWS Certified Security – Specialty Study Guide, when an EC2 instance is suspected of compromise, security teams should avoid logging in to the instance or installing additional tools, as these actions can alter evidence and increase risk.

Terminating the compromised instance after ensuring that its Amazon EBS volumes are preserved prevents further malicious activity immediately. By setting the EBS volumes to not delete on termination, all disk data is retained for forensic analysis. Launching a new, clean EC2 instance in a different subnet or Availability Zone with preinstalled diagnostic tools allows investigators to safely attach and analyze the compromised volumes without executing potentially malicious code.

Option A introduces significant risk by logging in to the compromised instance and modifying security controls during active compromise. Option B delays containment and allows continued outbound traffic during investigation steps. Option D is invalid because AWS WAF cannot be attached directly to Amazon EC2 instances and does not control outbound traffic.

AWS documentation strongly recommends isolating or terminating compromised resources and performing offline analysis using detached storage volumes. This approach ensures immediate mitigation, preserves forensic integrity, and aligns with AWS incident response frameworks.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Incident Response Best Practices

Amazon EC2 and EBS Forensics Guidance

AWS Well-Architected Framework – Security Pillar

Question #:126 - [Data Protection]

A company needs to follow security best practices to deploy resources from an AWS CloudFormation template. The CloudFormation template must be able to configure sensitive database credentials. The company already uses AWS Key Management Service (AWS KMS) and AWS Secrets Manager.

Which solution will meet the requirements?

- A. Use a dynamic reference in the CloudFormation template to reference the database credentials in Secrets Manager.
- B. Use a parameter in the CloudFormation template to reference the database credentials. Encrypt the CloudFormation template by using AWS KMS.
- C. Use a SecureString parameter in the CloudFormation template to reference the database credentials in Secrets Manager.
- D. Use a SecureString parameter in the CloudFormation template to reference an encrypted value in AWS KMS.

Answer: A

Explanation

AWS CloudFormation dynamic references provide a secure mechanism for retrieving sensitive values from AWS Secrets Manager at stack creation or update time. According to the AWS Certified Security – Specialty documentation, dynamic references ensure that sensitive data such as database credentials are never stored in plaintext in CloudFormation templates, parameters, stack metadata, or logs.

When a dynamic reference to Secrets Manager is used, CloudFormation retrieves the secret value at runtime and passes it securely to the resource that requires it. The secret value is not exposed to users who view the template, stack, or change sets.

Option B is insecure because parameters can be exposed through the CloudFormation console and APIs. Option C is incorrect because SecureString parameters are a feature of AWS Systems Manager Parameter

Store, not Secrets Manager. Option D is invalid because KMS encrypts data but does not store secrets or manage secret rotation.

AWS best practices clearly state that CloudFormation dynamic references to Secrets Manager are the recommended solution for securely handling sensitive configuration values.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS CloudFormation Security Best Practices
- ▶ AWS Secrets Manager Documentation

Question #:127 - [Data Protection]

A company is running an application in the eu-west-1 Region. The application uses an AWS Key Management Service (AWS KMS) customer managed key to encrypt sensitive data. The company plans to deploy the application in the eu-north-1 Region. A security engineer needs to implement a key management solution for the application deployment in the new Region. The security engineer must minimize changes to the application code.

Which change should the security engineer make to the AWS KMS configuration to meet these requirements?

- A. Update the key policies in eu-west-1. Point the application in eu-north-1 to use the same customer managed key as the application in eu-west-1.
- B. Allocate a new customer managed key to eu-north-1 to be used by the application that is deployed in that Region.
- C. Allocate a new customer managed key to eu-north-1. Create the same alias name for both keys. Configure the application deployment to use the key alias.
- D. Allocate a new customer managed key to eu-north-1. Create an alias for eu--1. Change the application code to point to the alias for eu--1.

Answer: C

Explanation

AWS KMS keys are regional resources and cannot be used across Regions. According to AWS Certified Security – Specialty documentation, applications that are deployed in multiple Regions should use region-specific customer managed keys while referencing keys by alias instead of key ID.

By creating a new customer managed key in eu-north-1 and assigning it the same alias as the key in eu-west-1, the application code can continue to reference the alias without modification. Each Region resolves the alias to the correct local key, ensuring encryption continues to function correctly.

Option A is invalid because KMS keys are regional. Option B requires application changes. Option D introduces unsupported alias patterns.

AWS best practices recommend alias-based key references for multi-Region deployments.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Regional Keys and Aliases

AWS KMS Best Practices

Question #:128 - [Identity and Access Management]

A company uses an organization in AWS Organizations and AWS IAM Identity Center to manage its AWS environment. The company configures IAM Identity Center to access the company's on-premises Active Directory through a properly configured AD Connector. All the company's employees are in an Active Directory group named Cloud.

The employees can view and access nearly all the AWS accounts in the organization, and the employees have the permissions that they require. However, the employees cannot access an account named Account A. The company verifies that Account A exists in the organization.

What is the likely reason that the employees are unable to access Account A?

- A. The company did not add Account A to an organizational unit (OU) within the organization.
- B. The company has not synchronized the Cloud Active Directory group with the on-premises Active Directory.
- C. The company did not assign the Cloud Active Directory group to Account A in IAM Identity Center with a valid permission set.
- D. The company applied an IAM permissions boundary to Account A that is denying access to the account.

Answer: C

Explanation

In AWS IAM Identity Center (formerly AWS Single Sign-On), users and groups do not automatically gain access to all accounts in an AWS Organization simply because the accounts exist. Access is explicitly granted by assigning a principal (user or group) to a specific AWS account along with a permission set. Permission sets define the IAM policies that are provisioned into the target account as IAM roles.

In this scenario, employees in the Cloud Active Directory group can access nearly all AWS accounts, which confirms that AD Connector synchronization is functioning correctly, eliminating option B. The fact that Account A exists but is inaccessible strongly indicates that the required account assignment is missing. Without explicitly assigning the Cloud group to Account A with a valid permission set, IAM Identity Center will not provision the necessary IAM role, and users will not see or access the account in the AWS access portal.

Option A is incorrect because accounts do not need to be placed in an OU to be accessible through IAM Identity Center. Option D is incorrect because IAM permissions boundaries do not control access to entire accounts and are not applied at the account level to block IAM Identity Center access.

AWS Security Specialty documentation emphasizes that account assignments are mandatory for IAM Identity Center access, making option C the correct answer.

Question #:129 - [Identity and Access Management]

A security engineer is troubleshooting an AWS Lambda function that is named `MyLambdaFunction`. The function is encountering an error when the function attempts to read the objects in an Amazon S3 bucket that is named `DOC-EXAMPLE-BUCKET`. The S3 bucket has the following bucket policy:

```
{
  "Effect": "Allow",
  "Principal": { "Service": "lambda.amazonaws.com" },
  "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::DOC-EXAMPLE-BUCKET",
  "Condition": {
    "ArnLike": {
      "aws:SourceArn": "arn:aws:lambda:::function:MyLambdaFunction"
    }
  }
}
```

Which change should the security engineer make to the policy to ensure that the Lambda function can read the bucket objects?

- A. Remove the Condition element. Change the Principal element to the following: { "AWS": "arn:aws:lambda:::function:MyLambdaFunction" }
- B. Change the Action element to the following: ["s3:GetObject*", "s3:GetBucket*"]
- C. Change the Resource element to "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*" .
- D. Change the Resource element to "arn:aws:lambda:::function:MyLambdaFunction" . Change the Principal element to the following: { "Service": "s3.amazonaws.com" }

Answer: C

Explanation

The policy currently grants `s3:GetObject` but targets the bucket ARN (`arn:aws:s3:::DOC-EXAMPLE-BUCKET`). For Amazon S3, object-level actions such as `GetObject` must reference object ARNs, not the bucket ARN. The correct resource pattern is the bucket ARN with `/*` appended (for example, `arn:aws:s3:::DOC-EXAMPLE-BUCKET/*`) so the permission applies to objects within the bucket. Without this, S3 evaluates the request against a resource that does not match the requested object, resulting in an access denial even though the action appears correct.

The other options do not address the root cause. Expanding actions (Option B) is unnecessary and overly permissive, and it still would not fix the incorrect resource ARN for object reads. Changing principals or removing conditions (Option A) is not required just to allow reads—Lambda typically accesses S3 using the function's execution role, and bucket policies are commonly used for cross-account or service-based access control, but the immediate failure here is the mismatch between `s3:GetObject` and the bucket-only resource. Option D is invalid because it inverts principal/service usage and sets an incorrect resource type for S3 authorization.

Question #:130 - [Data Protection]

A company is running its application on AWS. The company has a multi-environment setup, and each environment is isolated in a separate AWS account. The company has an organization in AWS Organizations to manage the accounts. There is a single dedicated security account for the organization. The company must create an inventory of all sensitive data that is stored in Amazon S3 buckets across the organization's accounts. The findings must be visible from a single location.

Which solution will meet these requirements?

- A. Set the security account as the delegated administrator for Amazon Macie and AWS Security Hub. Enable and configure Macie to publish sensitive data findings to Security Hub.
- B. Set the security account as the delegated administrator for AWS Security Hub. In each account, configure Amazon Inspector to scan the S3 buckets for sensitive data. Publish sensitive data findings to Security Hub.
- C. In each account, configure Amazon Inspector to scan the S3 buckets for sensitive data. Enable Amazon Inspector integration with AWS Trusted Advisor. Publish sensitive data findings to Trusted Advisor.
- D. In each account, enable and configure Amazon Macie to detect sensitive data. Enable Macie integration with AWS Trusted Advisor. Publish sensitive data findings to Trusted Advisor.

Answer: A

Explanation

Amazon Macie is the AWS service purpose-built to discover and classify sensitive data in S3 (PII, financial data, credentials, etc.) and produce findings that can be aggregated centrally. In a multi-account organization, the recommended centralized model is to designate a delegated administrator account for Macie so the security team can manage discovery across member accounts from one place.

To make the findings visible from a single location and integrate them with broader security visibility, AWS Security Hub provides centralized aggregation of security findings across accounts and services. By also configuring the security account as the delegated administrator for Security Hub, the company can aggregate findings across the organization. Macie integrates with Security Hub so that sensitive data discovery findings flow into Security Hub's centralized view, giving the security team a single console and API surface to build an "inventory" of sensitive data locations and severity.

Inspector (options B and C) is focused on vulnerability management (EC2, ECR, and related scanning use cases), not sensitive data classification in S3. Trusted Advisor is not the primary destination for sensitive data discovery findings at organizational scale. Therefore, Macie + Security Hub with delegated administration in the security account is the correct solution.

Question #:131 - [Data Protection]

A security engineer needs to implement AWS IAM Identity Center with an external identity provider (IdP).

Select and order the correct steps from the following list to meet this requirement. Select each step one time or not at all. (Select and order THREE.)

- . Configure the external IdP as the identity source in IAM Identity Center.
- . Create an IAM role that has a trust policy that specifies the IdP 's API endpoint.
- . Enable automatic provisioning in IAM Identity Center settings.
- . Enable automatic provisioning in the external IdP.
- . Obtain the SAML metadata from IAM Identity Center.
- . Obtain the SAML metadata from the external IdP.

Step 1: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center.
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP.
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP.

Step 2: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center.
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP.
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP.

Step 3: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center.
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP.
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP.

Answer:

Step 1: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center.
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP. 1
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP.

Step 2: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center.
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP.
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP. 1

Step 3: Select...
 Select...
 Configure the external IdP as the identity source in IAM Identity Center. 1
 Create an IAM role that has a trust policy that specifies the IdP's API endpoint.
 Enable automatic provisioning in IAM Identity Center settings.
 Enable automatic provisioning in the external IdP.
 Obtain the SAML metadata from IAM Identity Center.
 Obtain the SAML metadata from the external IdP.

Explanation

Step 1: Obtain the SAML metadata from IAM Identity Center.

Step 2: Obtain the SAML metadata from the external IdP.

Step 3: Configure the external IdP as the identity source in IAM Identity Center.

When integrating AWS IAM Identity Center (formerly AWS SSO) with an external identity provider (IdP) using SAML 2.0, AWS requires a specific sequence of steps to establish trust and federation correctly.

Step 1: Obtain the SAML metadata from IAM Identity Center

IAM Identity Center acts as the service provider (SP) in the SAML trust. The external IdP must trust IAM Identity Center, so the IdP needs IAM Identity Center's SAML metadata first. This metadata contains critical information such as the SP entity ID, ACS (Assertion Consumer Service) URL, and signing certificate. Without this metadata, the external IdP cannot be configured to send assertions to AWS.

Step 2: Obtain the SAML metadata from the external IdP

After the external IdP is configured to trust IAM Identity Center, the IdP generates its own SAML metadata. This metadata includes the IdP entity ID, SSO endpoint, and signing certificate. IAM Identity Center requires this information to validate authentication assertions coming from the external IdP.

Step 3: Configure the external IdP as the identity source in IAM Identity Center

Once both metadata files are available, the security engineer configures the external IdP as the identity source in IAM Identity Center. At this stage, IAM Identity Center imports the IdP metadata and establishes the SAML trust relationship. After this configuration, users authenticated by the external IdP can be federated into AWS accounts and applications via IAM Identity Center.

Why the other options are incorrect:

- ▶ Creating an IAM role with an IdP API endpoint is used for IAM federation, not IAM Identity Center.
- ▶ Automatic provisioning (SCIM) is optional and is configured after SAML federation is established.
- ▶ Automatic provisioning must be enabled on both sides, but it is not required to complete the core IdP integration.

This sequence follows AWS best practices for SAML-based federation with IAM Identity Center.

Question #:132 - [Detection]

A company begins to use AWS WAF after experiencing an increase in traffic to the company's public web applications. A security engineer needs to determine if the increase in traffic is because of application-layer attacks. The security engineer needs a solution to analyze AWS WAF traffic.

Which solution will meet this requirement?



- A. Send AWS WAF logs to AWS CloudTrail and analyze them with OpenSearch.
- B. Send AWS WAF logs to Amazon S3 and query them directly with OpenSearch.
- C. Send AWS WAF logs to Amazon S3. Create an Amazon Athena table with partition projection. Use Athena to query the logs.
- D. Send AWS WAF logs to AWS CloudTrail and analyze them with Amazon Athena.

Answer: C

Explanation

AWS WAF supports logging of detailed HTTP request information, including source IP addresses, request URIs, headers, and rule evaluation results. According to the AWS Certified Security – Specialty documentation, Amazon S3 combined with Amazon Athena is the recommended and most cost-effective solution for ad hoc and forensic analysis of AWS WAF logs.

By configuring AWS WAF to deliver logs to Amazon S3 and using Athena with partition projection, the security engineer can efficiently query large volumes of log data without maintaining partitions manually. This enables rapid identification of application-layer attacks such as SQL injection, cross-site scripting, and bot activity.

Options A and D are incorrect because AWS WAF logs are not delivered to CloudTrail. Option B is invalid because OpenSearch cannot directly query data stored in S3 without ingestion or additional tooling.

AWS documentation highlights S3 + Athena as a best practice for scalable, serverless analysis of AWS WAF logs.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS WAF Logging Documentation
- ▶ Amazon Athena Best Practices

Question #:133 - [Data Protection]

A company uploads data files as objects into an Amazon S3 bucket. A vendor downloads the objects to perform data processing.

A security engineer must implement a solution that prevents objects from residing in the S3 bucket for longer than 72 hours.

- A. Configure S3 Versioning to expire object versions that have been in the bucket for 72 hours.
- B. Configure an S3 Lifecycle configuration rule on the bucket to expire objects after 72 hours.
- C. Use the S3 Intelligent-Tiering storage class and configure expiration after 72 hours.
- D. Generate presigned URLs that expire after 72 hours.

Answer: B

Explanation

Amazon S3 Lifecycle configuration rules are the native, automated mechanism for managing object retention and deletion. According to AWS Certified Security – Specialty documentation, lifecycle rules can be configured to expire objects based on the number of days since object creation. Once the expiration time is reached, Amazon S3 permanently deletes the objects without manual intervention.

This solution directly enforces a maximum retention period of 72 hours and ensures compliance regardless of whether the vendor downloads the data or not. Lifecycle rules are evaluated continuously by Amazon S3 and do not require scripts, cron jobs, or additional services, making them the most operationally efficient and cost-effective solution.

S3 Versioning controls versions but does not enforce object deletion timelines. S3 Intelligent-Tiering optimizes storage cost but does not delete objects. Presigned URLs only control access duration and do not remove objects from storage.

AWS explicitly recommends lifecycle policies for automated data retention enforcement.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Lifecycle Management

Question #:134 - [Data Protection]

A company has a VPC that has no internet access and has the private DNS hostnames option enabled. An Amazon Aurora database is running inside the VPC. A security engineer wants to use AWS Secrets Manager to automatically rotate the credentials for the Aurora database. The security engineer configures the Secrets Manager default AWS Lambda rotation function to run inside the same VPC that the Aurora database uses. However, the security engineer determines that the password cannot be rotated properly because the Lambda function cannot communicate with the Secrets Manager endpoint.

What is the MOST secure way that the security engineer can give the Lambda function the ability to communicate with the Secrets Manager endpoint?

- A. Add a NAT gateway to the VPC to allow access to the Secrets Manager endpoint.
- B. Add a gateway VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.
- C. Add an interface VPC endpoint to the VPC to allow access to the Secrets Manager endpoint.
- D. Add an internet gateway for the VPC to allow access to the Secrets Manager endpoint.

Answer: C

Explanation

AWS Secrets Manager is a regional service that is accessed through private AWS endpoints. In a VPC without internet access, AWS recommends using AWS PrivateLink through interface VPC endpoints to enable secure, private connectivity to supported AWS services. According to AWS Certified Security – Specialty documentation, interface VPC endpoints allow resources within a VPC to communicate with AWS services without traversing the public internet, NAT devices, or internet gateways.

An interface VPC endpoint for Secrets Manager creates elastic network interfaces (ENIs) within the VPC subnets and assigns private IP addresses that route traffic directly to the Secrets Manager service. Because the VPC has private DNS enabled, the standard Secrets Manager DNS hostname resolves to the private IP addresses of the interface endpoint, allowing the Lambda rotation function to communicate securely and transparently.

Option A introduces unnecessary complexity and expands the attack surface by allowing outbound internet access. Option B is incorrect because gateway VPC endpoints are supported only for Amazon S3 and Amazon DynamoDB. Option D violates the security requirement by exposing the VPC to the internet.

AWS security best practices explicitly recommend interface VPC endpoints as the most secure connectivity method for private VPC workloads accessing AWS managed services.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Secrets Manager Security Architecture

AWS PrivateLink and Interface VPC Endpoints Documentation

Question #:135 - [Detection]

A company needs to identify the root cause of security findings and investigate IAM roles involved in those findings. The company has enabled VPC Flow Logs, Amazon GuardDuty, and AWS CloudTrail.

Which solution will meet these requirements?

- A. Use Amazon Detective to investigate IAM roles and visualize findings.
- B. Use Amazon Inspector and CloudWatch dashboards.
- C. Export GuardDuty findings to S3 and analyze with Athena.
- D. Use Security Hub custom actions to investigate IAM roles.

Answer: A

Explanation

Amazon Detective is specifically designed to help security teams investigate and visualize the root cause of security findings. According to AWS Certified Security – Specialty documentation, Detective automatically aggregates and correlates data from GuardDuty, CloudTrail, and VPC Flow Logs to provide interactive visualizations and timelines.

Detective enables investigators to pivot from GuardDuty findings to IAM roles, API calls, network traffic, and resource behavior. This makes it the most efficient tool for understanding how IAM roles were used during suspicious activity.

Amazon Inspector focuses on vulnerability assessment, not behavioral investigation. Security Hub aggregates findings but does not provide deep investigation graphs. Manual analysis with Athena requires significantly more effort.

AWS guidance explicitly recommends Amazon Detective for root cause analysis and visualization of security incidents.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Detective Investigation Capabilities

AWS Threat Detection and Analysis

Question #:136 - [Security Foundations and Governance]

A company is expanding its group of stores. On the day that each new store opens, the company wants to launch a customized web application for that store. Each store 's application will have a non-production environment and a production environment. Each environment will be deployed in a separate AWS account. The company uses AWS Organizations and has an OU that is used only for these accounts.

The company distributes most of the development work to third-party development teams. A security engineer needs to ensure that each team follows the company 's deployment plan for AWS resources. The security engineer also must limit access to the deployment plan to only the developers who need access. The security engineer already has created an AWS CloudFormation template that implements the deployment plan.

What should the security engineer do next to meet the requirements in the MOST secure way?

- A. Create an AWS Service Catalog portfolio in the organization 's management account. Upload the CloudFormation template. Add the template to the portfolio 's product list. Share the portfolio with the OU.
- B. Use the CloudFormation CLI to create a module from the CloudFormation template. Register the module as a private extension in the CloudFormation registry. Publish the extension. Create an SCP that allows access to the extension.
- C. Create an AWS Service Catalog portfolio and create an IAM role for cross-account access. Attach the AWSServiceCatalogEndUserFullAccess managed policy to the role.

D. Use the CloudFormation CLI to create a module and share the extension directly with the OU.

Answer: A

Explanation

AWS Service Catalog is specifically designed to help organizations govern and control how AWS resources are provisioned at scale. According to the AWS Certified Security – Specialty Official Study Guide, Service Catalog enables administrators to define approved CloudFormation templates as products and to control which accounts, users, or organizational units can deploy those products.

By creating a Service Catalog portfolio in the management account and sharing it with a specific OU, the security engineer ensures that only accounts within that OU can deploy the approved infrastructure. Third-party developers can deploy resources only by using the predefined CloudFormation template and cannot alter the deployment plan, which enforces consistency and compliance.

This approach also limits access to the deployment plan itself, because developers interact with the Service Catalog product rather than the raw template. No cross-account IAM roles or excessive permissions are required, which reduces the attack surface.

CloudFormation modules and extensions (Options B and D) provide reuse but do not enforce deployment governance or access control. Option C introduces unnecessary cross-account IAM roles, which is less secure than native Service Catalog sharing.

AWS documentation explicitly identifies AWS Service Catalog + AWS Organizations as the recommended pattern for secure, standardized multi-account deployments.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Service Catalog Administrator Guide
- ▶ AWS Organizations Best Practices

Question #:137 - [Identity and Access Management]

A company's security engineer receives an alert that indicates that an unexpected principal is accessing a company-owned Amazon Simple Queue Service (Amazon SQS) queue. All the company's accounts are within an organization in AWS Organizations. The security engineer must implement a mitigation solution that minimizes compliance violations and investment in tools that are outside of AWS.

What should the security engineer do to meet these requirements?

- A. Create security groups that only accept inbound traffic from the CIDR blocks of all the VPCs in the organization. Attach the security groups to all the SQS queues in all the VPCs in the organization.
- B. In all the VPCs in the organization, adjust the network ACLs to only accept inbound traffic from the CIDR blocks of all the VPCs in the organization. Attach the network ACLs to all the subnets in all the VPCs in the organization.

- C. Create interface VPC endpoints for Amazon SQS in all the VPCs in the organization. Set the aws:SourceVpce condition to the VPC endpoint identifier on the SQS policy. Add the aws:PrincipalOrgId condition to the VPC endpoint policy.
- D. Use a cloud access security broker (CASB) to maintain a list of managed resources. Configure the CASB to check the API and console access against that list on a web proxy.

Answer: C

Explanation

Amazon SQS is an AWS-managed service and does not operate within customer VPCs. Therefore, security groups and network ACLs cannot be used to control access to SQS, making options A and B invalid. According to AWS Certified Security – Specialty documentation, the recommended approach to securely access AWS services from within a VPC is through interface VPC endpoints (AWS PrivateLink).

By creating interface VPC endpoints for Amazon SQS, the company ensures that traffic to SQS stays within the AWS network and does not traverse the public internet. Adding an SQS resource policy with the aws:SourceVpce condition restricts access so that only requests originating from the specified VPC endpoint are allowed. Additionally, using the aws:PrincipalOrgId condition ensures that only principals belonging to the same AWS Organization can access the queue.

Option D introduces an external tool, increasing cost and compliance complexity, which directly violates the requirement to minimize investment outside AWS.

AWS documentation clearly identifies VPC endpoints combined with IAM condition keys as a best practice for securing service access in multi-account environments.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon SQS Security Best Practices
- ▶ AWS Organizations Documentation
- ▶ AWS PrivateLink User Guide

Question #:138 - [Data Protection]

A company is building a secure solution that relies on an AWS Key Management Service (AWS KMS) customer managed key. The company wants to allow AWS Lambda to use the KMS key. However, the company wants to prevent Amazon EC2 from using the key.

Which solution will meet these requirements?

- A. Use IAM explicit deny for EC2 instance profiles and allow for Lambda roles.
- B. Use a KMS key policy with kms:ViaService conditions to allow Lambda usage and deny EC2 usage.

- C. Use aws:SourceIp and aws:AuthorizedService condition keys in the KMS key policy.
- D. Use an SCP to deny EC2 and allow Lambda.

Answer: B

Explanation

AWS KMS access control is primarily enforced through key policies (and optionally grants), and AWS recommends using key policy condition keys to restrict how keys can be used. The kms:ViaService condition key is specifically designed to restrict KMS API usage to requests that come through a particular AWS service endpoint in a specific Region. This is the most robust way to ensure a key can be used only via AWS Lambda (for example, lambda. < region > .amazonaws.com) and not via Amazon EC2 (ec2. < region > .amazonaws.com), even if IAM permissions exist elsewhere. By writing a key policy that uses the Lambda execution role as the principal and conditions on kms:ViaService, the company can tightly bind key usage to Lambda-originated cryptographic operations while preventing use through EC2 service paths. Option A is weaker because EC2 is not the only way an IAM principal might use KMS, and relying on attaching explicit deny policies broadly is harder to manage and can miss principals. Option C is incorrect because aws:AuthorizedService is not the typical mechanism for KMS service restriction, and SourceIp is unreliable for service-to-service calls. Option D is not ideal because SCPs do not provide fine-grained service-path restrictions for KMS usage and cannot “allow” beyond IAM; key policy controls still apply.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS KMS Key Policies and Condition Keys

AWS KMS Best Practices for Service-Scoped Key Usage

Question #:139 - [Incident Response]

A company 's security team wants to receive email notification from AWS about any abuse reports regarding DoS attacks. A security engineer needs to implement a solution that will provide a near-real-time alert for any abuse reports that AWS sends for the account. The security engineer already has created an Amazon Simple Notification Service (Amazon SNS) topic and has subscribed the security team 's email address to the topic.

What should the security engineer do next to meet these requirements?

- A. Use the AWS Trusted Advisor API and a scheduled Lambda function to detect AWS_ABUSE_DOS_REPORT notifications.
- B. Create an Amazon EventBridge rule that uses AWS Health and identifies a specific event for AWS_ABUSE_DOS_REPORT. Configure the rule action to publish a message to the SNS topic.
- C. Use the AWS Support API and a scheduled Lambda function to detect abuse report cases.
- D. Use AWS CloudTrail logs with metric filters to detect AWS_ABUSE_DOS_REPORT events.

Answer: B

Explanation

AWS Health provides real-time visibility into events that affect AWS accounts, including abuse notifications such as `AWS_ABUSE_DOS_REPORT`. According to the AWS Certified Security – Specialty Study Guide, AWS Health events are natively integrated with Amazon EventBridge, enabling automated, near-real-time responses without polling or custom code.

By creating an EventBridge rule that listens for AWS Health events related to abuse reports and configuring the rule to publish messages to an SNS topic, the security engineer ensures immediate notification to the security team whenever AWS issues a DoS-related abuse report for the account.

Option A and C rely on periodic polling using Lambda functions, which introduces latency and operational complexity. Option D is incorrect because CloudTrail does not log AWS abuse notifications.

AWS documentation explicitly identifies AWS Health + EventBridge + SNS as the recommended architecture for near-real-time operational and security alerts originating from AWS.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Health User Guide
- ▶ Amazon EventBridge Documentation
- ▶ AWS Incident Response Best Practices

Question #:140 - [Security Foundations and Governance]

A company uses AWS Organizations to manage an organization that consists of three workload OUs: Production, Development, and Testing. The company uses AWS CloudFormation templates to define and deploy workload infrastructure in AWS accounts that are associated with the OUs. Different SCPs are attached to each workload OU.

The company successfully deployed a CloudFormation stack update to workloads in the Development OU and the Testing OU. When the company uses the same CloudFormation template to deploy the stack update in an account in the Production OU, the update fails. The error message reports insufficient IAM permissions.

What is the FIRST step that a security engineer should take to troubleshoot this issue?

- A. Review the AWS CloudTrail logs in the account in the Production OU. Search for any failed API calls from CloudFormation during the deployment attempt.
- B. Remove all the SCPs that are attached to the Production OU. Rerun the CloudFormation stack update to determine if the SCPs were preventing the CloudFormation API calls.
- C. Confirm that the role used by CloudFormation has sufficient permissions to create, update, and delete the resources that are referenced in the CloudFormation template.
- D. Make all the SCPs that are attached to the Production OU the same as the SCPs that are attached to the Testing OU.

Answer: A

Explanation

AWS CloudTrail provides a record of all API calls made in an AWS account, including calls initiated by AWS CloudFormation. According to the AWS Certified Security – Specialty Study Guide, CloudTrail is the primary source for troubleshooting authorization failures because it records denied actions and the policy type that caused the denial, including service control policies.

Reviewing CloudTrail logs allows a security engineer to identify which specific API calls failed during the CloudFormation deployment and whether the denial was caused by an SCP, an IAM policy, or a permission boundary. This evidence-based approach is the recommended first step before making any configuration changes.

Option B is unsafe and violates governance best practices by removing SCPs in production. Option C may be necessary later, but it does not identify whether SCPs are the root cause. Option D introduces unnecessary risk and bypasses the purpose of differentiated controls across OUs.

AWS documentation emphasizes observing and validating before modifying security controls, making CloudTrail log analysis the correct initial troubleshooting step.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Organizations Service Control Policies

AWS CloudTrail Authorization Failure Analysis

Question #:141 - [Incident Response]

A company runs a web application on a fleet of Amazon EC2 instances in an Auto Scaling group. Amazon GuardDuty and AWS Security Hub are enabled. The security engineer needs an automated response to anomalous traffic that follows AWS best practices and minimizes application disruption.

Which solution will meet these requirements?

- A. Use EventBridge to disable the instance profile access keys.
- B. Use EventBridge to invoke a Lambda function that removes the affected instance from the Auto Scaling group and isolates it with a restricted security group.
- C. Use Security Hub to update the subnet network ACL to block traffic.
- D. Send GuardDuty findings to Amazon SNS for email notification.

Answer: B

Explanation

AWS incident response best practices emphasize isolating compromised resources rather than immediately terminating them. According to AWS Certified Security – Specialty documentation, removing an instance from an Auto Scaling group prevents replacement loops, while applying a restrictive security group isolates the instance for forensic analysis.

Using Amazon EventBridge to trigger an AWS Lambda function enables automated, consistent responses to GuardDuty findings. This approach minimizes disruption to the application because healthy instances continue serving traffic while the affected instance is isolated.

Disabling credentials or modifying network ACLs can have broader impact on unrelated workloads. SNS notifications alone do not provide response automation.

AWS recommends isolate-and-investigate patterns for EC2 incident response.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty Automated Responses

AWS Incident Response Playbooks

Question #:142 - [Infrastructure Security]

A company's security engineer receives an alert that indicates that an unexpected principal is accessing a company-owned Amazon Simple Queue Service (Amazon SQS) queue. All the company's accounts are within an organization in AWS Organizations. The security engineer must implement a mitigation solution that minimizes compliance violations and investment in tools outside of AWS.

What should the security engineer do to meet these requirements?

- A. Create security groups and attach them to all SQS queues.
- B. Modify network ACLs in all VPCs to restrict inbound traffic.
- C. Create interface VPC endpoints for Amazon SQS. Restrict access using `aws:SourceVpce` and `aws:PrincipalOrgId` conditions.
- D. Use a third-party cloud access security broker (CASB).

Answer: C

Explanation

Amazon SQS is a regional service that supports AWS PrivateLink through interface VPC endpoints. According to AWS Certified Security – Specialty documentation, the most secure and compliant way to restrict access to AWS services is by using VPC endpoints combined with resource-based policies.

By creating interface VPC endpoints for Amazon SQS in all VPCs, traffic to SQS remains on the AWS network and does not traverse the public internet. Using the `aws:SourceVpce` condition in the SQS queue

policy ensures that only requests originating from approved VPC endpoints can access the queue. Adding the `aws:PrincipalOrgId` condition further restricts access to principals that belong to the same AWS Organization.

Security groups and network ACLs do not apply to SQS because SQS is not deployed inside a VPC. Third-party CASB tools add cost and operational overhead.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon SQS Security and VPC Endpoints

AWS Organizations Condition Keys

Question #:143 - [Detection]

A company creates AWS Lambda functions from container images that are stored in Amazon Elastic Container Registry (Amazon ECR). The company needs to identify any software vulnerabilities in the container images and any code vulnerabilities in the Lambda functions.

Which solution will meet these requirements?

- A. Enable Amazon GuardDuty. Configure Amazon ECR scanning and Lambda code scanning in GuardDuty.
- B. Enable Amazon GuardDuty. Configure Runtime Monitoring and Lambda Protection in GuardDuty.
- C. Enable Amazon Inspector. Configure Amazon ECR enhanced scanning and Lambda code scanning in Amazon Inspector.
- D. Enable AWS Security Hub. Configure Runtime Monitoring and Lambda Protection in Security Hub.

Answer: C

Explanation

Amazon Inspector is the AWS service designed specifically for vulnerability management across compute workloads, including Amazon ECR container images and AWS Lambda functions. According to the AWS Certified Security – Specialty documentation, Amazon Inspector provides automated vulnerability assessments for container images stored in ECR by performing enhanced image scanning that identifies common vulnerabilities and exposures (CVEs) in operating systems and application dependencies.

Inspector also supports Lambda code scanning to analyze function packages and container-based Lambda images for known software vulnerabilities. Findings include severity ratings and remediation guidance, allowing security teams to identify and prioritize risks efficiently.

Amazon GuardDuty focuses on threat detection using behavioral analysis and does not perform static vulnerability scanning of container images or Lambda code. AWS Security Hub aggregates findings from other services but does not perform scanning itself.

AWS best practices recommend Amazon Inspector for vulnerability detection in container images and serverless workloads.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Inspector for ECR and Lambda

AWS Vulnerability Management Best Practices

Question #:144 - [Data Protection]

A company stores sensitive data in an Amazon S3 bucket. The company encrypts the data at rest by using server-side encryption with Amazon S3 managed keys (SSE-S3). A security engineer must prevent any modifications to the data in the S3 bucket.

Which solution will meet this requirement?

- A. Configure S3 bucket policies to deny DELETE and PUT object permissions.
- B. Configure S3 Object Lock in compliance mode with S3 bucket versioning enabled.
- C. Change the encryption on the S3 bucket to use AWS Key Management Service (AWS KMS) customer managed keys.
- D. Configure the S3 bucket with multi-factor authentication (MFA) delete protection.

Answer: B

Explanation

Amazon S3 Object Lock in compliance mode provides write-once-read-many (WORM) protection, which prevents objects from being modified or deleted for a specified retention period. According to the AWS Certified Security – Specialty Study Guide, compliance mode enforces immutability even for the root user and cannot be overridden.

Enabling S3 Object Lock requires S3 bucket versioning and ensures that once an object is written, it cannot be changed or removed until the retention period expires. This is the strongest protection against data modification and is commonly used for regulatory and legal retention requirements.

Option A can be bypassed by administrators. Option D only protects against deletions, not overwrites. Option C changes encryption but does not prevent modification.

AWS documentation explicitly identifies S3 Object Lock in compliance mode as the correct solution for immutable data storage.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon S3 Object Lock

Amazon S3 Data Protection and Compliance

Question #:145 - [Infrastructure Security]

A company is planning to migrate its applications to AWS in a single AWS Region. The company's applications will use a combination of Amazon EC2 instances, Elastic Load Balancing (ELB) load balancers, and Amazon S3 buckets. The company wants to complete the migration as quickly as possible. All the applications must meet the following requirements:

- Data must be encrypted at rest.
- Data must be encrypted in transit.
- Endpoints must be monitored for anomalous network traffic.

Which combination of steps should a security engineer take to meet these requirements with the LEAST effort? (Select THREE.)

- A. Install the Amazon Inspector agent on EC2 instances by using AWS Systems Manager Automation.
- B. Enable Amazon GuardDuty in all AWS accounts.
- C. Create VPC endpoints for Amazon EC2 and Amazon S3. Update VPC route tables to use only the secure VPC endpoints.
- D. Configure AWS Certificate Manager (ACM). Configure the load balancers to use certificates from ACM.
- E. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-meta-side-encryption.
- F. Use AWS Key Management Service (AWS KMS) for key management. Create an S3 bucket policy to deny any PutObject command with a condition for x-amz-server-side-encryption.

Answer: B D F

Explanation

Amazon GuardDuty provides continuous monitoring for anomalous and malicious network activity by analyzing VPC Flow Logs, DNS logs, and CloudTrail events. Enabling GuardDuty across accounts requires minimal configuration and immediately satisfies the requirement to monitor endpoints for anomalous network traffic, as described in the AWS Certified Security – Specialty Study Guide.

Encrypting data in transit for applications behind Elastic Load Balancing is most efficiently achieved by using AWS Certificate Manager (ACM). ACM provisions and manages TLS certificates automatically, and integrating ACM with ELB enables encrypted communication without manual certificate management.

For encryption at rest in Amazon S3, AWS best practices recommend enforcing server-side encryption using AWS KMS. An S3 bucket policy that denies PutObject requests unless the x-amz-server-side-encryption condition is present ensures that all uploaded objects are encrypted at rest using KMS-managed keys. This provides strong encryption guarantees with minimal operational effort.

Option A is unnecessary because Amazon Inspector focuses on vulnerability assessment, not encryption or network anomaly detection. Option C adds network complexity and is not required to meet the stated requirements. Option E is incorrect because x-amz-meta-side-encryption is not a valid enforcement mechanism.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty Threat Detection

AWS Certificate Manager and ELB Integration

Amazon S3 Encryption Best Practices

Question #:146 - [Infrastructure Security]

A company has a platform that is divided into 12 AWS accounts under the same organization in AWS Organizations. Many of these accounts use Amazon API Gateway to expose APIs to the company 's frontend applications. The company needs to protect the existing APIs and any resources that will be deployed in the future against common SQL injection and bot attacks.

Which solution will meet these requirements with the LEAST operational overhead?

- A. Create an AWS WAF web ACL for each API. Include managed rules to block SQL injection and bot attacks. Use AWS Config to detect new resources that do not have a web ACL. Configure a remediation action to provision a web ACL for these resources.
- B. Use AWS Firewall Manager to create an AWS WAF policy. Configure the policy to include the AWS Bot Control and SQL database managed rule groups. Set the policy scope to include the API Gateway stage as the resource type.
- C. Create an AWS Service Catalog product for an AWS WAF web ACL that includes rules to block SQL injection and bot attacks. Use AWS Config to detect new resources that do not have this product applied. Configure a remediation action to provision a web ACL for these resources.
- D. Use AWS Security Hub to detect unprotected resources and to send the findings as custom action events to Amazon EventBridge. Create an AWS Lambda function for these events to provision an AWS WAF web ACL for the unprotected resources. Include managed rules to block SQL injection and bot attacks.

Answer: B

Explanation

The company needs centralized, scalable protection across many accounts for both existing and future API Gateway resources, with minimal ongoing effort. AWS Firewall Manager is specifically designed for this: it can centrally deploy and enforce AWS WAF protections across AWS Organizations. By creating a Firewall Manager WAF policy, the security team defines a single set of controls (for example, AWS Managed Rules for SQL injection protection and AWS Bot Control) and applies them automatically to in-scope resources across member accounts.

Critically, Firewall Manager can be configured to auto-remediate noncompliant resources, ensuring that if new API Gateway stages are created later, they are automatically brought under the policy without manual per-account work. This directly meets the “existing and future resources” requirement.

Options A, C, and D introduce higher operational overhead: per-API ACL creation plus AWS Config remediation (A) is more moving parts; Service Catalog plus detection/remediation (C) is indirect and heavy; and Security Hub + EventBridge + Lambda automation (D) is custom engineering and maintenance. Firewall Manager is the AWS-native centralized governance solution for multi-account WAF rollout and enforcement.

Question #:147 - [Incident Response]

A company's security engineer receives an abuse notification from AWS. The notification indicates that someone is hosting malware from the company's AWS account. After investigation, the security engineer finds a new Amazon S3 bucket that an IAM user created without authorization.

Which combination of steps should the security engineer take to MINIMIZE the consequences of this compromise? (Select THREE.)

- A. Encrypt all AWS CloudTrail logs.
- B. Turn on Amazon GuardDuty.
- C. Change the password for all IAM users.
- D. Rotate or delete all AWS access keys.
- E. Take snapshots of all Amazon Elastic Block Store (Amazon EBS) volumes.
- F. Delete any resources that are unrecognized or unauthorized.

Answer: B D F

Explanation

AWS incident response best practices emphasize rapid containment, credential revocation, and threat detection to minimize the blast radius of a compromise. According to the AWS Certified Security – Specialty Official Study Guide, when unauthorized resources such as an Amazon S3 bucket hosting malware are discovered, immediate action must be taken to stop further misuse of the account and to prevent recurrence.

Rotating or deleting all AWS access keys (Option D) is a critical containment step. If an IAM user has been compromised, any long-term credentials associated with that user must be revoked immediately to prevent continued unauthorized access. AWS guidance explicitly lists access key rotation or deletion as a first-response action for suspected credential compromise.

Deleting unrecognized or unauthorized resources (Option F) directly removes the malicious infrastructure that is being abused. In this case, deleting the unauthorized S3 bucket immediately stops malware distribution and reduces reputational and compliance impact.

Turning on Amazon GuardDuty (Option B) enables continuous threat detection by analyzing CloudTrail events, VPC Flow Logs, and DNS logs. GuardDuty can identify additional malicious activity, compromised credentials, or persistence mechanisms that the attacker may have established. AWS documentation recommends enabling GuardDuty during or immediately after an incident to detect ongoing or future threats.

Option A does not reduce the impact of the current compromise. Option C is overly disruptive and not recommended; credential rotation should be targeted. Option E is unnecessary because there is no indication that EBS-backed compute resources are involved.

AWS incident response guidance clearly prioritizes credential revocation, malicious resource removal, and threat detection to minimize consequences.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Incident Response Best Practices
- ▶ Amazon GuardDuty User Guide
- ▶ AWS IAM Security Best Practices

Question #:148 - [Identity and Access Management]

A company is using AWS CloudTrail and Amazon CloudWatch to monitor resources in an AWS account. The company's developers have been using an IAM role in the account for the last 3 months.

A security engineer needs to refine the customer managed IAM policy attached to the role to ensure that the role provides least privilege access.

Which solution will meet this requirement with the LEAST effort?

- A. Implement AWS IAM Access Analyzer policy generation on the role.
- B. Implement AWS IAM Access Analyzer policy validation on the role.
- C. Search CloudWatch logs to determine the actions the role invoked and to evaluate the permissions.
- D. Use AWS Trusted Advisor to compare the policies assigned to the role against AWS best practices.

Answer: A

Explanation

AWS IAM Access Analyzer policy generation is specifically designed to help security engineers generate least-privilege IAM policies based on actual usage recorded in AWS CloudTrail. According to the AWS Certified Security – Specialty documentation, policy generation analyzes historical CloudTrail data to identify the exact API actions and resources that a role has accessed over a specified time period.

Because the role has been actively used for three months, there is sufficient CloudTrail data for IAM Access Analyzer to generate a refined customer managed policy automatically. This significantly reduces manual effort and eliminates the need to analyze logs or infer permissions. The generated policy can be reviewed and attached directly to the role, ensuring least privilege access with minimal engineering effort.

Option B only validates existing policies for security warnings and does not reduce permissions. Option C requires manual analysis of CloudWatch logs, which is time-consuming and error-prone. Option D does not analyze real usage and cannot generate role-specific least privilege policies.

AWS documentation explicitly recommends IAM Access Analyzer policy generation as the fastest and most accurate method to refine IAM permissions based on observed behavior.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Access Analyzer Policy Generation

AWS IAM Least Privilege Best Practices

Question #:149 - [Incident Response]

A healthcare company stores more than 1 million patient records in an Amazon S3 bucket. The patient records include personally identifiable information (PII). The S3 bucket contains hundreds of terabytes of data.

A security engineer receives an alert that was triggered by an Amazon GuardDuty Exfiltration:S3/AnomalousBehavior finding. The security engineer confirms that an attacker is using temporary credentials that were obtained from a compromised Amazon EC2 instance that has s3:GetObject permissions for the S3 bucket. The attacker has begun downloading the contents of the bucket. The security engineer contacts a development team. The development team will require 4 hours to implement and deploy a fix.

The security engineer must take immediate action to prevent the attacker from downloading more data from the S3 bucket.

Which solution will meet this requirement?

- A. Revoke the temporary session that is associated with the instance profile that is attached to the EC2 instance.
- B. Quarantine the EC2 instance by replacing the existing security group with a new security group that has no rules applied.
- C. Enable Amazon Macie on the S3 bucket. Configure the managed data identifiers for personally identifiable information (PII). Enable S3 Object Lock on objects that Macie flags.

- D. Apply an S3 bucket policy temporarily. Configure the policy to deny read access for all principals to block downloads while the development team address the vulnerability.

Answer: A

Explanation

Amazon GuardDuty Exfiltration:S3/AnomalousBehavior findings indicate that S3 data access patterns are consistent with data exfiltration. In this scenario, the attacker is using temporary credentials obtained from an EC2 instance profile, which are issued by AWS Security Token Service (STS).

According to AWS Certified Security – Specialty documentation, the fastest and most targeted remediation is to revoke the temporary session credentials associated with the compromised instance profile. This can be accomplished by removing or modifying the IAM role permissions, detaching the instance profile, or stopping the instance, which immediately invalidates the temporary credentials and prevents further S3 access.

Option B may limit outbound traffic but does not invalidate already issued credentials. Option C is a detection and classification service and does not prevent active exfiltration. Option D would block all access to the bucket, including legitimate access, and is considered overly disruptive for incident containment.

AWS incident response best practices emphasize credential revocation as the first containment step when compromise of temporary credentials is confirmed.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon GuardDuty User Guide – S3 Protection
- ▶ AWS STS and IAM Role Security Documentation
- ▶ AWS Incident Response Best Practices

Question #:150 - [Detection]

A security engineer configured VPC Flow Logs to publish to Amazon CloudWatch Logs. After 10 minutes, no logs appear. The issue is isolated to the IAM role associated with VPC Flow Logs.

What could be the reason?

- A. logs:GetLogEvents is missing.
- B. The engineer cannot assume the role.
- C. The vpc-flow-logs.amazonaws.com principal cannot assume the role.
- D. The role cannot tag the log stream.

Answer: C

Explanation

VPC Flow Logs require an IAM role that CloudWatch Logs can use to publish flow log records. AWS documentation and AWS Certified Security – Specialty materials explain that the VPC Flow Logs service must be able to assume the IAM role through its trust policy. The trust relationship must include the service principal `vpc-flow-logs.amazonaws.com`. If the trust policy does not allow this principal to assume the role, flow logs cannot be delivered and no records will appear in the CloudWatch Logs log group even when traffic exists. `logs:GetLogEvents` is not required for delivery; it is used for reading logs. The security engineer's ability to assume the role is not relevant because the service, not the engineer, assumes it. Tagging permissions are not required for basic log delivery. Therefore, the most likely cause is an incorrect trust policy that prevents the VPC Flow Logs service principal from assuming the role.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon VPC Flow Logs IAM Role Requirements

IAM Trust Policies for AWS Services

Question #:151 - [Identity and Access Management]

A security engineer discovers that a company's user passwords have no required minimum length. The company is using the following two identity providers (IdPs):

- AWS Identity and Access Management (IAM) federated with on-premises Active Directory
- Amazon Cognito user pools that contain the user database for an AWS Cloud application that the company developed

Which combination of actions should the security engineer take to implement a required minimum length for the passwords? (Select TWO.)

- A. Update the password length policy in the IAM configuration.
- B. Update the password length policy in the Cognito configuration.
- C. Update the password length policy in the on-premises Active Directory configuration.
- D. Create an SCP in AWS Organizations. Configure the SCP to enforce a minimum password length for IAM and Cognito.
- E. Create an IAM policy that includes a condition for minimum password length. Enforce the policy for IAM and Cognito.

Answer: B C

Explanation

The company uses two different identity systems, and password policy must be enforced at the system that actually stores and manages the passwords. For users authenticating through IAM federation with on-premises

Active Directory, IAM is not storing the users' passwords; the password policy is enforced by Active Directory. Therefore, the minimum password length must be configured in the on-premises AD password policy so federated users are subject to the requirement during password creation/changes.

For the cloud application that uses Amazon Cognito user pools as its user database, Cognito does store and manage user passwords for those users. Cognito user pools include a configurable password policy (minimum length and complexity requirements). Updating the Cognito user pool password policy enforces the required minimum length for the application's users going forward.

Options D and E are not applicable. Service control policies (SCPs) restrict AWS API actions; they cannot enforce end-user password-length rules inside AD or Cognito. Similarly, IAM policies control authorization to AWS resources and APIs, not password complexity/length requirements across external IdPs or Cognito user databases. Updating IAM password policy (Option A) would apply only to IAM users (local users in AWS), which is not the authentication model described for the federated workforce.

Question #:152 - [Detection]

A company's security team wants to receive near-real-time email notifications about AWS abuse reports related to DoS attacks. An Amazon SNS topic already exists and is subscribed to by the security team.

What should the security engineer do next?

- A. Poll Trusted Advisor for abuse notifications by using a Lambda function.
- B. Create an Amazon EventBridge rule that matches AWS Health events for AWS_ABUSE_DOS_REPORT and publishes to SNS.
- C. Poll the AWS Support API for abuse cases by using a Lambda function.
- D. Detect abuse reports by using CloudTrail logs and CloudWatch alarms.

Answer: B

Explanation

AWS abuse notifications are delivered as AWS Health events. According to the AWS Certified Security – Specialty Study Guide, Amazon EventBridge integrates natively with AWS Health and can be used to detect specific event types such as AWS_ABUSE_DOS_REPORT in near real time.

By creating an EventBridge rule that filters for the abuse report event type and publishes directly to Amazon SNS, the solution remains fully managed, low latency, and cost effective.

Polling APIs introduces delay and complexity. CloudTrail does not log abuse notifications. EventBridge with AWS Health is the recommended mechanism for reacting to AWS service events.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Health and EventBridge Integration

AWS Abuse Notification Handling

Question #:153 - [Incident Response]

A company recently experienced a malicious attack on its cloud-based environment. The company successfully contained and eradicated the attack. A security engineer is performing incident response work. The security engineer needs to recover an Amazon RDS database cluster to the last known good version. The database cluster is configured to generate automated backups with a retention period of 14 days. The initial attack occurred 5 days ago at exactly 3:15 PM.

Which solution will meet this requirement?

- A. Identify the Regional cluster ARN for the database. Use the ARN to restore the Regional cluster by using the restore to point in time feature. Set a target time 5 days ago at 3:14 PM.
- B. Identify the Regional cluster ARN for the database. List snapshots that have been taken of the cluster. Restore the database by using the snapshot that has a creation time that is closest to 5 days ago at 3:14 PM.
- C. List all snapshots that have been taken of all the company 's RDS databases. Identify the snapshot that was taken closest to 5 days ago at 3:14 PM and restore it.
- D. Identify the Regional cluster ARN for the database. Use the ARN to restore the Regional cluster by using the restore to point in time feature. Set a target time 14 days ago.

Answer: A

Explanation

Amazon RDS supports point-in-time recovery (PITR) using automated backups within the configured retention window. According to the AWS Certified Security – Specialty Study Guide, PITR allows recovery to any second within the retention period, making it the most precise recovery method following a security incident.

By restoring the database cluster to a point just before the attack occurred, such as 3:14 PM, the security engineer ensures that the restored database reflects the last known good state without including malicious changes. This method is more accurate than restoring from snapshots, which are created at fixed intervals and may not align with the exact recovery time.

Options B and C rely on snapshot timing and may reintroduce compromised data. Option D restores to an arbitrary time and does not meet the requirement to recover to the last known good version.

AWS documentation explicitly recommends point-in-time recovery for incident response scenarios that require precise restoration.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon RDS Automated Backups and PITR

AWS Incident Response and Recovery Guidance

Question #:154 - [Incident Response]

A company must immediately disable compromised IAM users across all AWS accounts and collect all actions performed by the user in the last 7 days.

Which solution will meet these requirements?

- A. Disable the IAM user and query CloudTrail logs in Amazon S3 using Athena.
- B. Remove IAM policies and query logs in Security Hub.
- C. Remove permission sets and query logs using CloudWatch Logs Insights.
- D. Disable the user in IAM Identity Center and query the organizational event data store.

Answer: D

Explanation

AWS IAM Identity Center centrally manages user access across an AWS Organization. Disabling the user in Identity Center immediately revokes access to all AWS accounts. According to AWS Certified Security – Specialty documentation, organizational CloudTrail event data stores provide centralized, queryable access to all events across accounts.

Using CloudTrail Lake enables direct querying of activity without exporting logs. Disabling the user at the Identity Center level ensures full containment.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Identity Center Incident Response

AWS CloudTrail Lake

Question #:155 - [Security Foundations and Governance]

A company uses AWS to run a web application that manages ticket sales in several countries. The company recently migrated the application to an architecture that includes Amazon API Gateway, AWS Lambda, and Amazon Aurora Serverless. The company needs the application to comply with Payment Card Industry Data Security Standard (PCI DSS) v4.0. A security engineer must generate a report that shows the effectiveness of the PCI DSS v4.0 controls that apply to the application. The company 's compliance team must be able to add manual evidence to the report.

Which solution will meet these requirements?



- A. Enable AWS Trusted Advisor. Configure all the Trusted Advisor checks. Manually map the checks against the PCI DSS v4.0 standard to generate the report.
- B. Enable and configure AWS Config. Deploy the Operational Best Practices for PCI DSS conformance pack in AWS Config. Use AWS Config to generate the report.
- C. Enable AWS Security Hub. Enable the Security Hub PCI DSS security standard. Use the AWS Management Console to download the report from the security standard.
- D. Create an AWS Audit Manager assessment that uses the AWS managed PCI DSS v4.0 standard framework. Add all evidence to the assessment. Generate the report in Audit Manager for download.

Answer: D

Explanation

AWS Audit Manager is specifically designed to help organizations continuously audit their AWS usage against compliance frameworks and generate audit-ready reports. According to AWS Certified Security – Specialty documentation, Audit Manager includes AWS managed frameworks for compliance standards, including PCI DSS v4.0.

Audit Manager automatically collects evidence from AWS services such as API Gateway, Lambda, RDS, CloudTrail, and Config, and maps the evidence directly to PCI DSS controls. Importantly, Audit Manager allows compliance teams to upload and attach manual evidence, which is a key requirement in this scenario.

Option C provides visibility into control status but does not support adding manual evidence. Option B evaluates configuration compliance but does not generate formal compliance reports. Option A requires extensive manual effort and is not aligned with PCI reporting workflows.

AWS documentation positions Audit Manager as the authoritative service for compliance reporting and audit evidence management.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Audit Manager PCI DSS Framework

AWS Compliance Reporting Best Practices

Question #:156 - [Incident Response]

A company has an AWS account that hosts a production application. The company receives an email notification that Amazon GuardDuty has detected an `Impact:IAMUser/AnomalousBehavior` finding in the account. A security engineer needs to run the investigation playbook for this security incident and must collect and analyze the information without affecting the application.

Which solution will meet these requirements MOST quickly?

- A. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding for details about the IAM credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.
- B. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls initiated the finding. Use Amazon Detective to review the API calls in context.
- C. Log in to the AWS account by using administrator credentials. Review the GuardDuty finding for details about the IAM credentials that were used. Use the IAM console to add a DenyAll policy to the IAM principal.
- D. Log in to the AWS account by using read-only credentials. Review the GuardDuty finding to determine which API calls initiated the finding. Use AWS CloudTrail Insights and AWS CloudTrail Lake to review the API calls in context.

Answer: B

Explanation

Amazon GuardDuty findings provide high-level detection of suspicious activity but are not designed for deep investigation on their own. The AWS Certified Security – Specialty documentation explains that Amazon Detective is purpose-built to support rapid investigations by automatically collecting, correlating, and visualizing data from GuardDuty, AWS CloudTrail, and VPC Flow Logs. Detective enables security engineers to analyze API calls, user behavior, and resource interactions in context without making any changes to the environment.

Using read-only credentials ensures that the investigation does not impact the production application. Amazon Detective allows investigators to pivot directly from a GuardDuty finding into a detailed activity graph, showing which IAM user made anomalous calls, what resources were accessed, and how behavior deviated from the baseline. This significantly accelerates incident investigation.

Options A and C involve applying DenyAll policies, which are containment actions and could affect application availability. Option D requires manual analysis and setup and is slower than using Amazon Detective, which is designed for immediate investigative workflows.

AWS incident response guidance recommends using Detective for rapid, non-intrusive analysis after GuardDuty findings.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty and Amazon Detective Integration

AWS Incident Response Investigation Best Practices

Question #:157 - [Security Foundations and Governance]

A company uses AWS Organizations and has an SCP at the root that prevents sharing resources with external accounts. The company now needs to allow only the marketing account to share resources externally while preventing all other accounts from doing so. All accounts are in the same OU.

Which solution will meet these requirements?

- A. Create a new SCP in the marketing account to explicitly allow sharing.
- B. Edit the existing SCP to add a condition that excludes the marketing account.
- C. Edit the SCP to include an Allow statement for the marketing account.
- D. Use a permissions boundary in the marketing account.

Answer: B

Explanation

Service control policies (SCPs) define the maximum available permissions for accounts and are evaluated as guardrails. AWS Certified Security – Specialty documentation states SCPs are typically used to apply organization-wide restrictions, and exceptions are commonly handled by using conditions (for example, excluding specific accounts) or by structuring OUs differently. Because all accounts are in the same OU and the company must continue blocking external sharing for everyone except one account, modifying the existing SCP to exclude the marketing account is the most direct solution. An SCP attached at the root affects all accounts unless conditions narrow its scope. Adding a condition that excludes the marketing account allows that account to retain the ability to share resources externally while the SCP continues to block sharing for other accounts. Option A is not feasible because account-level SCPs cannot override a deny applied by a parent SCP; explicit denies always win. Option C misunderstands SCP behavior because SCPs do not grant permissions; they only limit. Option D is an IAM control that cannot override an organization-level deny. Therefore, the only secure, scalable option is to modify the existing SCP with an exception condition for the marketing account.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Organizations SCP Evaluation Logic

SCP Deny Precedence and Exception Patterns

Question #:158 - [Identity and Access Management]

A company has a large fleet of Amazon Linux 2 Amazon EC2 instances that run an application. The application processes sensitive data and has the following compliance requirements:

- No remote access management ports to the EC2 instances can be exposed internally or externally.
- All remote session activity must be recorded in an audit log.

- All remote access to the EC2 instances must be authenticated and authorized by AWS IAM Identity Center.

The company's DevOps team occasionally needs to connect to one of the EC2 instances to troubleshoot issues.

Which solution will provide remote access to the EC2 instances while meeting the compliance requirements?

- A. Grant access to the EC2 serial console at the account level.
- B. Enable EC2 Instance Connect and configure security group rules.
- C. Assign an EC2 instance role that allows access to AWS Systems Manager. Create an IAM policy that grants access to Systems Manager Session Manager. Assign the policy to an IAM role of the DevOps team.
- D. Use AWS Systems Manager Automation runbooks to open remote access ports.

Answer: C

Explanation

AWS Systems Manager Session Manager provides secure, auditable, and portless access to EC2 instances. According to the AWS Certified Security – Specialty Study Guide, Session Manager allows administrators to connect to instances without opening inbound SSH or RDP ports, fully satisfying strict compliance requirements.

Session Manager integrates directly with AWS IAM Identity Center, ensuring that all access is authenticated and authorized using centralized identity management. Additionally, Session Manager automatically records session activity and can send logs to Amazon CloudWatch Logs or Amazon S3, providing a complete audit trail of all commands executed during a session.

Option A (EC2 serial console) does not provide comprehensive auditing and is intended for recovery scenarios. Option B requires inbound network access and security group rules, violating the “no exposed management ports” requirement. Option D explicitly opens ports, which directly violates compliance constraints.

AWS documentation clearly identifies Systems Manager Session Manager as the recommended solution for secure, auditable, and identity-integrated instance access in regulated environments.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Systems Manager Session Manager Documentation
- ▶ AWS IAM Identity Center Best Practices

Question #:159 - [Infrastructure Security]

A company runs a global ecommerce website using Amazon CloudFront. The company must block traffic from specific countries to comply with data regulations.

Which solution will meet these requirements MOST cost-effectively?

- A. Use AWS WAF IP match rules.
- B. Use AWS WAF geo match rules.
- C. Use CloudFront geo restriction to deny the countries.
- D. Use geolocation headers in CloudFront.

Answer: C

Explanation

Amazon CloudFront includes a built-in geo restriction feature that allows content to be allowed or denied based on the viewer's country. According to AWS Certified Security – Specialty documentation, CloudFront geo restriction is the most cost-effective method for country-based blocking because it does not require AWS WAF or additional rule processing.

AWS WAF geo match rules incur additional cost and are more appropriate when advanced inspection or layered security controls are required. IP-based blocking is impractical due to frequent IP changes. Geolocation headers do not enforce access control.

CloudFront geo restriction is evaluated at the edge and efficiently blocks disallowed countries with minimal latency and cost.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon CloudFront Geo Restriction

AWS Edge Security Best Practices

Question #:160 - [Incident Response]

A company is attempting to conduct forensic analysis on an Amazon EC2 instance, but the company is unable to connect to the instance by using AWS Systems Manager Session Manager. The company has installed AWS Systems Manager Agent (SSM Agent) on the EC2 instance.

The EC2 instance is in a subnet in a VPC that does not have an internet gateway attached. The company has associated a security group with the EC2 instance. The security group does not have inbound or outbound rules. The subnet's network ACL allows all inbound and outbound traffic.

Which combination of actions will allow the company to conduct forensic analysis on the EC2 instance without compromising forensic data? (Select THREE.)

- A. Update the EC2 instance security group to add a rule that allows outbound traffic on port 443 for 0.0.0.0/0.

- B. Update the EC2 instance security group to add a rule that allows inbound traffic on port 443 to the VPC 's CIDR range.
- C. Create an EC2 key pair. Associate the key pair with the EC2 instance.
- D. Create a VPC interface endpoint for Systems Manager in the VPC where the EC2 instance is located.
- E. Attach a security group to the VPC interface endpoint. Allow inbound traffic on port 443 to the VPC 's CIDR range.
- F. Create a VPC interface endpoint for the EC2 instance in the VPC where the EC2 instance is located.

Answer: A D E

Explanation

AWS Systems Manager Session Manager requires secure outbound HTTPS connectivity from the EC2 instance to Systems Manager endpoints. In a VPC without internet access, AWS Certified Security – Specialty documentation recommends using interface VPC endpoints to enable private connectivity without exposing the instance to the internet.

Creating a VPC interface endpoint for Systems Manager allows the SSM Agent to communicate securely with the Systems Manager service. The endpoint must have an attached security group that allows inbound traffic on port 443 from the VPC CIDR range. Additionally, the EC2 instance security group must allow outbound HTTPS traffic on port 443 so the agent can initiate connections.

Option C is incorrect because creating or associating key pairs enables SSH access, which can alter forensic evidence and violates forensic best practices. Option B is unnecessary because Session Manager does not require inbound rules on the EC2 instance. Option F is invalid because EC2 does not use interface endpoints for management connectivity.

This combination ensures secure, private access for forensic investigation while preserving evidence integrity and adhering to AWS incident response best practices.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS Systems Manager Session Manager Architecture

AWS Incident Response and Forensics Best Practices

Question #:161 - [Incident Response]

A company has installed a third-party application that is distributed on several Amazon EC2 instances and on-premises servers. Occasionally, the company 's IT team needs to use SSH to connect to each machine to perform software maintenance tasks. Outside these time slots, the machines must be completely isolated from the rest of the network. The company does not want to maintain any SSH keys. Additionally, the company wants to pay only for machine hours when there is an SSH connection.

Which solution will meet these requirements?

- A. Create a bastion host with port forwarding to connect to the machines.
- B. Set up AWS Systems Manager Session Manager to allow temporary connections.
- C. Use AWS CloudShell to create serverless connections.
- D. Set up an interface VPC endpoint for each machine for private connection.

Answer: B

Explanation

AWS Systems Manager Session Manager provides interactive shell access to managed instances without inbound SSH, without bastion hosts, and without managing SSH keys. Access is controlled through IAM policies, and every session can be logged to CloudWatch Logs/S3 for auditability. This directly satisfies the “no SSH keys” requirement and reduces the network exposure surface because you can keep port 22 closed and still obtain shell access when needed.

To meet the isolation requirement, the instances can be placed in private subnets with no inbound access, and you can use Systems Manager connectivity (via SSM endpoints/agents) for administrative sessions only when required. On-premises servers can also be managed by Systems Manager by registering them as managed instances (hybrid activations), allowing the same no-SSH-key operational model across EC2 and on-prem environments.

Options A and D still require network paths and do not eliminate key management; a bastion host is additional infrastructure that must be secured and maintained. CloudShell (Option C) is an AWS-managed shell environment but does not provide a direct, managed, keyless session channel into arbitrary EC2/on-prem hosts by itself. Therefore, Session Manager is the best solution.

Question #:162 - [Data Protection]

A security engineer uses Amazon Macie to scan a company's Amazon S3 buckets for sensitive data. The company has many S3 buckets and many objects stored in the S3 buckets. The security engineer must identify S3 buckets that contain sensitive data and must perform additional scanning on those S3 buckets.

Which solution will meet these requirements with the LEAST administrative overhead?

- A. Configure S3 Cross-Region Replication (CRR) on the S3 buckets to replicate the objects to a second AWS Region. Configure Macie in the second Region to scan the replicated objects daily.
- B. Create an AWS Lambda function as an S3 event destination for the S3 buckets. Configure the Lambda function to start a Macie scan of an object when the object is uploaded to an S3 bucket.
- C. Configure Macie automated discovery to continuously sample data from the S3 buckets. Perform full scans of the S3 buckets where Macie discovers sensitive data.
- D. Configure Macie scans to run on the S3 buckets. Aggregate the results of the scans in an Amazon DynamoDB table. Use the DynamoDB table for queries.

Answer: C

Explanation

Amazon Macie's automated sensitive data discovery is designed for exactly this: at scale, Macie continuously evaluates and samples objects across S3 buckets to identify where sensitive data (PII, financial data, credentials, etc.) is likely present. This gives the security engineer a low-touch way to identify which buckets contain sensitive data without having to orchestrate per-bucket scanning workflows. Once Macie flags buckets with sensitive data findings, the engineer can then prioritize and run additional, more targeted scanning (for example, deeper classification jobs on those specific buckets) rather than scanning everything exhaustively all the time.

The other options increase operational burden significantly. CRR to another Region (A) doubles storage / transfer complexity and is not needed for discovery. An event-driven Lambda scan per object (B) is expensive and complex at high object volumes and is not how Macie classification is intended to be orchestrated. Aggregating results into DynamoDB (D) adds an extra system to maintain when Macie already provides centralized findings, dashboards, and integrations.

Therefore, enabling Macie automated discovery and then performing deeper scans only on buckets where Macie detects sensitive data provides the least administrative overhead.

Question #:163 - [Data Protection]

A company has a compliance requirement to encrypt all data in transit. The company recently discovered an Amazon Aurora cluster that does not meet this requirement.

How can the company enforce encryption for all connections to the Aurora cluster?

- A. In the Aurora cluster configuration, set the `require_secure_transport` DB cluster parameter to ON.
- B. Use AWS Directory Service for Microsoft Active Directory to create a user directory and to enforce Kerberos authentication with Aurora.
- C. Configure the Aurora cluster to use AWS Certificate Manager (ACM) to provide encryption certificates.
- D. Create an Amazon RDS proxy. Connect the proxy to the Aurora cluster to enable encryption.

Answer: A

Explanation

To enforce encryption in transit to Aurora, you must require clients to use TLS/SSL when connecting to the database. Aurora (depending on engine flavor) supports a parameter that enforces secure transport by rejecting non-TLS connections. Setting the DB (cluster/instance) parameter such as `require_secure_transport` to ON forces clients to negotiate SSL/TLS; otherwise the server refuses the connection, ensuring all data in transit is encrypted. This directly enforces the compliance requirement at the database endpoint itself, independent of client behavior.

Kerberos authentication (Option B) provides centralized authentication and can be useful for IAM/AD integration, but it does not by itself guarantee that the network session is encrypted. Option C is incorrect because Aurora/RDS uses RDS-provided certificates for TLS; you don't attach ACM certificates to Aurora the way you would for ALB/CloudFront. Option D is not the right enforcement mechanism: RDS Proxy can help with connection pooling and IAM auth patterns, but it does not inherently force all client-to-proxy or proxy-to-db connections to be encrypted in the way a DB parameter enforcement does (and you'd still need to ensure clients use TLS). Therefore, enabling the parameter that requires secure transport is the correct solution.

Question #:164 - [Detection]

A company uses Amazon API Gateway to present REST APIs to users. An API developer wants to analyze API access patterns without the need to parse the log files.

Which combination of steps will meet these requirements with the LEAST effort? (Select TWO.)

- A. Configure access logging for the required API stage.
- B. Configure an AWS CloudTrail trail destination for API Gateway events. Configure filters on the `userIdentity`, `userAgent`, and `sourceIPAddress` fields.
- C. Configure an Amazon S3 destination for API Gateway logs. Run Amazon Athena queries to analyze API access information.
- D. Use Amazon CloudWatch Logs Insights to analyze API access information.
- E. Select the Enable Detailed CloudWatch Metrics option on the required API stage.

Answer: D E

Explanation

To analyze API access patterns with minimal effort and without parsing raw log files, the best approach is to rely on metrics and built-in query tooling. Enabling Detailed CloudWatch Metrics for an API Gateway stage (Option E) provides near-real-time, aggregated visibility into usage and performance patterns (such as request counts, latency, error rates like 4XX/5XX) that are ideal for identifying trends and spikes without handling logs.

For deeper pattern exploration when needed, CloudWatch Logs Insights (Option D) provides an interactive query experience over logs that are already in CloudWatch Logs, allowing quick filtering and aggregation. In practice, developers use metrics to understand access patterns at a high level and Logs Insights to slice and dice request data without building a separate parsing pipeline.

Options A and C still rely on enabling access logs and shipping them to S3/Athena, which is more setup and operational overhead (and still involves managing log storage/format). CloudTrail (Option B) records control-plane API calls to AWS services, not end-user access requests to your API methods, so it won't provide the desired access pattern view for API consumers. Therefore, Detailed CloudWatch Metrics plus CloudWatch Logs Insights is the least-effort combination for access pattern analysis.

Question #:165 - [Security Foundations and Governance]

A company is running an application on Amazon EC2 instances in an Auto Scaling group. The application stores logs locally. A security engineer noticed that logs were lost after a scale-in event. The security engineer needs to recommend a solution to ensure the durability and availability of log data. All logs must be kept for a minimum of 1 year for auditing purposes.

What should the security engineer recommend?

- A. Within the Auto Scaling lifecycle, add a hook to create and attach an Amazon Elastic Block Store (Amazon EBS) log volume each time an EC2 instance is created. When the instance is terminated, the EBS volume can be reattached to another instance for log review.
- B. Create an Amazon Elastic File System (Amazon EFS) file system and add a command in the user data section of the Auto Scaling launch template to mount the EFS file system during EC2 instance creation. Configure a process on the instance to copy the logs once a day from an instance Amazon Elastic Block Store (Amazon EBS) volume to a directory in the EFS file system.
- C. Add an Amazon CloudWatch agent into the AMI used in the Auto Scaling group. Configure the CloudWatch agent to send the logs to Amazon CloudWatch Logs for review.
- D. Within the Auto Scaling lifecycle, add a lifecycle hook at the terminating state transition and alert the engineering team by using a lifecycle notification to Amazon Simple Notification Service (Amazon SNS). Configure the hook to remain in the Terminating:Wait state for 1 hour to allow manual review of the security logs prior to instance termination.

Answer: C

Explanation

In an Auto Scaling group, instances are ephemeral—local disks and instance-level log files can disappear during scale-in or replacement. The most durable, operationally simple pattern is to stream logs off-host continuously to a managed log service. Installing and configuring the CloudWatch agent (or unified agent) to ship application logs to Amazon CloudWatch Logs ensures logs are centralized and remain available regardless of instance lifecycle events. This directly solves the “logs lost after scale-in” problem and provides high availability for audit and investigation.

CloudWatch Logs also supports retention controls. The security engineer can set the log group retention to at least 1 year (or longer), meeting the audit requirement without building custom storage workflows. Access can be controlled with IAM to restrict who can view or export logs, and CloudWatch logs can be further integrated with Athena/OpenSearch/SIEM tools if needed.

Option A adds complexity and still ties durability to managing volumes across instance churn, with operational risk and scaling challenges. Option B requires daily copy jobs and can still lose logs between copy intervals; it also adds shared filesystem management overhead. Option D is manual and does not ensure durability, and it introduces operational friction during scale-in. Therefore, centralized log shipping to CloudWatch Logs is the best recommendation.

Question #:166 - [Incident Response]

A security engineer needs to prepare a company's Amazon EC2 instances for quarantine during a security incident. The AWS Systems Manager Agent (SSM Agent) has been deployed to all EC2 instances. The security engineer has developed a script to install and update forensics tools on the EC2 instances.

Which solution will quarantine EC2 instances during a security incident?

- A. Create a rule in AWS Config to track SSM Agent versions.
- B. Configure Systems Manager Session Manager to deny all connection requests from external IP addresses.
- C. Store the script in Amazon S3 and grant read access to the instance profile.
- D. Configure IAM permissions for the SSM Agent to run the script as a predefined Systems Manager Run Command document.

Answer: D

Explanation

AWS Systems Manager Run Command enables security engineers to remotely and securely execute scripts on EC2 instances without requiring SSH or inbound network access. According to AWS Certified Security – Specialty incident response guidance, Run Command is a foundational tool for instance quarantine and forensic preparation.

By configuring IAM permissions that allow the SSM Agent to execute a predefined Run Command document, the security engineer can rapidly deploy forensic tools, disable services, or modify system configurations across affected EC2 instances during an incident. This approach aligns with AWS best practices for containment and evidence preservation, while maintaining auditability through Systems Manager logs.

Option A only provides visibility, not quarantine capability. Option B restricts access but does not allow forensic tooling. Option C enables access to the script but does not execute it.

AWS documentation emphasizes that Systems Manager Run Command is the recommended mechanism for incident response automation and quarantine actions on EC2 instances.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS Systems Manager Run Command Documentation
- ▶ AWS Incident Response Best Practices

Question #:167 - [Security Foundations and Governance]

A startup company is using a single AWS account that has resources in a single AWS Region. A security engineer configures an AWS CloudTrail trail in the same Region to deliver log files to an Amazon S3 bucket by using the AWS CLI. Because of expansion, the company adds resources in multiple Regions. The security engineer notices that the logs from the new Regions are not reaching the S3 bucket.

What should the security engineer do to fix this issue with the LEAST amount of operational overhead?

- A. Create a new CloudTrail trail. Select the new Regions where the company added resources.
- B. Change the S3 bucket to receive notifications to track all actions from all Regions.
- C. Create a new CloudTrail trail that applies to all Regions.
- D. Change the existing CloudTrail trail so that it applies to all Regions.

Answer: D

Explanation

CloudTrail trails can be configured as either single-Region or multi-Region. A single-Region trail delivers events only for the Region in which it is created; when the company begins using additional Regions, those events will not be logged to the existing S3 destination unless the trail is updated. The least operational overhead is to modify the existing trail and enable multi-Region logging (that is, configure the trail to “apply to all Regions”). This preserves the current S3 bucket destination, encryption settings, log file validation configuration, IAM roles, and any integrations that already depend on the existing trail name and S3 prefix structure.

Creating a new trail (Options A or C) increases overhead because the engineer would need to manage multiple trails or migrate downstream processes (alerting, Athena tables, SIEM ingestion, retention policies, and lifecycle rules). Option B is not how CloudTrail works—S3 notifications do not cause CloudTrail to collect events from other Regions; CloudTrail must be configured to generate and deliver those logs. Therefore, updating the existing trail to be multi-Region is the simplest and most maintainable fix.

Question #:168 - [Identity and Access Management]

A company uses an organization in AWS Organizations to manage multiple AWS accounts. The company wants to centrally give users the ability to access Amazon Q Developer.

Which solution will meet this requirement?

- A. Enable AWS IAM Identity Center and set up Amazon Q Developer as an AWS managed application.
- B. Enable Amazon Cognito and create a new identity pool for Amazon Q Developer.
- C. Enable Amazon Cognito and set up Amazon Q Developer as an AWS managed application.
- D. Enable AWS IAM Identity Center and create a new identity pool for Amazon Q Developer.

Answer: A

Explanation

For centralized, organization-wide user access to AWS services and supported applications, AWS best practice is to use AWS IAM Identity Center (successor to AWS SSO). IAM Identity Center provides a single place to manage workforce identities, permission sets, and account assignments across AWS Organizations.

Amazon Q Developer is integrated for centralized access using IAM Identity Center, where you can assign the relevant permissions to users and groups and enable access consistently across multiple AWS accounts. Setting Amazon Q Developer up as an AWS managed application aligns with IAM Identity Center's model for centrally provisioning and controlling access with minimal operational overhead.

Amazon Cognito is primarily intended for customer identity and application sign-up/sign-in scenarios, not for workforce access to AWS managed developer tools across multiple AWS accounts. "Identity pools" are a Cognito concept for exchanging identities for AWS credentials, which adds unnecessary complexity and is not the standard approach for centrally granting employees access to Amazon Q Developer in an organization. Therefore, enabling IAM Identity Center and configuring Amazon Q Developer as an AWS managed application is the correct solution.

Question #:169 - [Identity and Access Management]

A security team manages a company's AWS Key Management Service (AWS KMS) customer managed keys. Only members of the security team can administer the KMS keys. The company's application team has a software process that needs temporary access to the keys occasionally. The security team needs to provide the application team's software process with access to the keys.

Which solution will meet these requirements with the LEAST operational overhead?

- A. Export the KMS key material to an on-premises hardware security module (HSM). Give the application team access to the key material.
- B. Edit the key policy that grants the security team access to the KMS keys by adding the application team as principals. Revert this change when the application team no longer needs access.
- C. Create a key grant to allow the application team to use the KMS keys. Revoke the grant when the application team no longer needs access.
- D. Create a new KMS key by generating key material on premises. Import the key material to AWS KMS whenever the application team needs access. Grant the application team permissions to use the key.

Answer: C

Explanation

KMS grants are purpose-built for giving temporary, scoped permissions to use a customer managed key without continually editing key policies. A grant can allow only the specific cryptographic operations the application process needs (for example, Encrypt/Decrypt/GenerateDataKey) and can be constrained to a particular AWS principal and (optionally) conditions. When access is no longer required, the security team can revoke the grant immediately, returning the key to its previous access posture. This meets the "temporary access occasionally" requirement with minimal operational work and lower risk than policy churn.

Option B requires repeated key policy edits and rollbacks, which is operationally noisy and increases the chance of misconfiguration or leaving access in place longer than intended. Option A is not supported in the way described—KMS key material for standard KMS customer managed keys is not something you "export" for sharing, and exposing key material breaks managed key controls. Option D introduces significant overhead and complexity by generating/importing key material repeatedly and is not the intended model for occasional access. Grants are the standard AWS pattern for delegating KMS key usage temporarily and safely.

Question #:170 - [Detection]

A company has a single AWS account and uses an Amazon EC2 instance to test application code. The company recently discovered that the instance was compromised and was serving malware. Analysis showed that the instance was compromised 35 days ago. A security engineer must implement a continuous monitoring solution that automatically notifies the security team by email for high severity findings as soon as possible.

Which combination of steps should the security engineer take to meet these requirements? (Select THREE.)

- A. Enable AWS Security Hub in the AWS account.
- B. Enable Amazon GuardDuty in the AWS account.
- C. Create an Amazon Simple Notification Service (Amazon SNS) topic. Subscribe the security team 's email distribution list to the topic.
- D. Create an Amazon Simple Queue Service (Amazon SQS) queue. Subscribe the security team 's email distribution list to the queue.
- E. Create an Amazon EventBridge rule for GuardDuty findings of high severity. Configure the rule to publish a message to the topic.
- F. Create an Amazon EventBridge rule for Security Hub findings of high severity. Configure the rule to publish a message to the queue.

Answer: B C E

Explanation

Amazon GuardDuty provides continuous threat detection for compromised instances by analyzing VPC Flow Logs, DNS logs, and CloudTrail events. According to AWS Certified Security – Specialty guidance, GuardDuty is the fastest service to enable for detecting malware and compromised EC2 instances.

To notify the security team, Amazon SNS provides a native email notification mechanism with minimal setup. Amazon EventBridge integrates directly with GuardDuty findings and can filter based on severity. Creating an EventBridge rule that matches high severity GuardDuty findings and publishes to SNS ensures immediate notification.

Security Hub is not required for this use case and adds additional setup time. Amazon SQS does not support email subscriptions.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon GuardDuty Findings and Severity

Amazon EventBridge Integration with GuardDuty

Question #:171 - [Identity and Access Management]

A company in France uses Amazon Cognito with the Cognito Hosted UI as an identity broker for sign-in and sign-up processes. The company is marketing an application and expects that all the application 's users will come from France. When the company launches the application, the company 's security team observes fraudulent sign-ups for the application. Most of the fraudulent registrations are from users outside of France. The security team needs a solution to perform custom validation at sign-up. Based on the results of the validation, the solution must accept or deny the registration request.

Which combination of steps will meet these requirements? (Select TWO.)

- A. Create a pre sign-up AWS Lambda trigger. Associate the Amazon Cognito function with the Amazon Cognito user pool.
- B. Use a geographic match rule statement to configure an AWS WAF web ACL. Associate the web ACL with the Amazon Cognito user pool.
- C. Configure an app client for the application 's Amazon Cognito user pool. Use the app client ID to validate the requests in the hosted UI.
- D. Update the application 's Amazon Cognito user pool to configure a geographic restriction setting.
- E. Use Amazon Cognito to configure a social identity provider (IdP) to validate the requests on the hosted UI.

Answer: A B

Explanation

To perform custom validation at sign-up and explicitly accept or deny registrations, Amazon Cognito provides Lambda triggers. A Pre sign-up trigger runs synchronously during the sign-up flow (including the Hosted UI) and can implement custom checks (for example, IP reputation checks, email/domain validation, velocity checks, allow/deny lists, or geo checks using an external service). Based on the trigger logic, the function can allow the sign-up to proceed or reject it, meeting the “custom validation” and “accept/deny” requirement directly.

Because the observed fraud largely originates outside France, adding a front-door geographic control reduces unwanted traffic before it reaches Cognito. AWS WAF supports Geo match conditions in a web ACL to allow /deny requests by country, which is a common mitigation for region-scoped applications. Associating a WAF web ACL to protect the Hosted UI endpoint helps block sign-up requests from non-French locations early, reducing fraud attempts and load.

The other options do not meet the requirement: Cognito user pools do not provide a native “geographic restriction setting” for sign-up (D), app client ID validation does not stop fraudulent sign-ups (C), and using a social IdP does not provide custom accept/deny validation for all sign-ups (E).

Question #:172 - [Detection]



A company must capture AWS CloudTrail data events and must retain the logs for 7 years. The logs must be immutable and must be available to be searched by complex queries. The company also needs to visualize the data from the logs.

Which solution will meet these requirements MOST cost-effectively?

- A. Create a CloudTrail Lake data store. Implement CloudTrail Lake dashboards to visualize and query the results.
- B. Use the CloudTrail Event History feature in the AWS Management Console. Visualize and query the results in the console.
- C. Send the CloudTrail logs to an Amazon S3 bucket. Provision a persistent Amazon EMR cluster that has access to the S3 bucket. Enable S3 Object Lock on the S3 bucket. Use Apache Spark to perform queries. Use Amazon QuickSight for visualizations.
- D. Send the CloudTrail logs to a log group in Amazon CloudWatch Logs. Set the CloudWatch Logs stream to send the data to an Amazon OpenSearch Service domain. Enable cold storage for the OpenSearch Service domain. Use OpenSearch Dashboards for visualizations and queries.

Answer: A

Explanation

AWS CloudTrail Lake is purpose-built to store, query, and analyze CloudTrail events, including data events, without requiring additional infrastructure. The AWS Certified Security – Specialty documentation explains that CloudTrail Lake provides immutable event storage with configurable retention periods, including multi-year retention, which satisfies long-term compliance requirements such as 7-year retention. Events are stored in an append-only, immutable format managed by AWS, reducing operational complexity.

CloudTrail Lake supports SQL-based queries for complex analysis directly against the event data, eliminating the need to export logs to other services for querying. Additionally, CloudTrail Lake includes built-in dashboards and integrations that enable visualization of event trends and patterns without standing up separate analytics or visualization platforms.

Option B is invalid because CloudTrail Event History only retains events for up to 90 days and does not support long-term retention or advanced querying. Option C introduces high operational overhead and cost by requiring persistent Amazon EMR clusters and additional services. Option D incurs ongoing ingestion, indexing, and storage costs for OpenSearch Service over a 7-year period, making it less cost-effective than CloudTrail Lake.

AWS documentation positions CloudTrail Lake as the most cost-effective and operationally efficient solution for long-term, queryable CloudTrail event storage and visualization.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS CloudTrail Lake Architecture and Retention

AWS CloudTrail Data Events Overview

Question #:173 - [Detection]

A company uses an organization in AWS Organizations to manage its 250 member accounts. The company also uses AWS IAM Identity Center with a SAML external identity provider (IdP). IAM Identity Center has been delegated to a member account. The company's security team has access to the delegated account.

The security team has been investigating a malicious internal user who might be accessing sensitive accounts. The security team needs to know when the user logged into the organization during the last 7 days.

Which solution will quickly identify the access attempts?

- A. In the delegated account, use Amazon CloudWatch Logs to search for events that match the user details for all successful attempts.
- B. In each member account, use the IAM Identity Center console to search for events that match the user details for all attempts.
- C. In the external IdP, use Amazon EventBridge to search for events that match the user details for all attempts.
- D. In the organization's management account, use AWS CloudTrail to search for events that match the user details for all successful attempts.

Answer: D

Explanation

AWS CloudTrail is the authoritative source for identity-related activity across an AWS Organization. According to the AWS Certified Security – Specialty Official Study Guide, CloudTrail records all AWS API calls and authentication events, including federated sign-ins that occur through AWS IAM Identity Center with an external SAML identity provider.

When IAM Identity Center is used, successful federated login events are logged in CloudTrail as ConsoleLogin and AssumeRoleWithSAML events. These events are recorded in the organization's management account when CloudTrail is configured as an organization trail. This allows security teams to centrally search and correlate authentication activity across all member accounts.

Option A is incorrect because CloudWatch Logs do not natively aggregate authentication events across an organization unless custom pipelines are built. Option B is not scalable and does not provide historical, organization-wide visibility. Option C is invalid because AWS does not ingest external IdP logs into EventBridge automatically, and IdP logs do not reflect AWS-side role assumptions.

AWS documentation explicitly states that CloudTrail organization trails provide centralized visibility into user authentication and access activity across all accounts, making this the fastest and most reliable way to identify when a user logged in during a specific time window.

- ▶ AWS CloudTrail User Guide
- ▶ AWS IAM Identity Center Documentation
- ▶ AWS Organizations Best Practices

Question #:174 - [Security Foundations and Governance]

CloudFormation stack deployments fail for some users due to permission inconsistencies.

Which combination of steps will ensure consistent deployments MOST securely? (Select THREE.)

- A. Create a composite principal service role.
- B. Create a service role with cloudformation.amazonaws.com as the principal.
- C. Attach scoped policies to the service role.
- D. Attach service ARNs in policy resources.
- E. Update each stack to use the service role.
- F. Allow iam:PassRole to the service role.

Answer: B E F

Explanation

AWS best practices require CloudFormation to assume a dedicated service role. This ensures consistent permissions regardless of the user. Users must have iam:PassRole permission to pass the role. Updating stacks to use the service role enforces uniform deployment behavior.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS CloudFormation Service Roles

Question #:175 - [Detection]

A company detects bot activity targeting Amazon Cognito user pool endpoints. The solution must block malicious requests while maintaining access for legitimate users.

Which solution meets these requirements?

- A. Enable Amazon Cognito threat protection.
- B. Restrict access to authenticated users only.

- C. Associate AWS WAF with the Cognito user pool.
- D. Monitor requests with CloudWatch.

Answer: A

Explanation

Amazon Cognito threat protection is purpose-built to detect and mitigate malicious authentication activity such as credential stuffing and bot traffic. It uses adaptive risk-based analysis without disrupting legitimate users.

AWS WAF cannot be directly associated with Cognito user pools.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

Amazon Cognito Threat Protection

Question #:176 - [Identity and Access Management]

A security engineer discovers that a company 's user passwords have no required minimum length. The company uses the following identity providers (IdPs):

- AWS Identity and Access Management (IAM) federated with on-premises Active Directory
- Amazon Cognito user pools that contain the user database for an AWS Cloud application

Which combination of actions should the security engineer take to implement a required minimum password length? (Select TWO.)

- A. Update the password length policy in the IAM configuration.
- B. Update the password length policy in the Amazon Cognito configuration.
- C. Update the password length policy in the on-premises Active Directory configuration.
- D. Create an SCP in AWS Organizations to enforce minimum password length.
- E. Create an IAM policy with a minimum password length condition.

Answer: B C

Explanation

Password policies are enforced at the identity provider where authentication occurs. According to the AWS Certified Security – Specialty Study Guide, when IAM is federated with an external identity provider such as on-premises Active Directory, IAM does not manage or enforce password policies. Instead, password requirements such as minimum length must be enforced directly in Active Directory Group Policy Objects.

Amazon Cognito user pools maintain their own user directory and authentication logic. Cognito provides configurable password policies, including minimum length, complexity, and expiration. To enforce a minimum password length for application users, the Cognito user pool password policy must be updated.

IAM password policies apply only to IAM users that authenticate directly with IAM and do not affect federated users or Cognito users. SCPs and IAM policies cannot enforce password length requirements.

Referenced AWS Specialty Documents:

AWS Certified Security – Specialty Official Study Guide

AWS IAM Federation and Password Policies

Amazon Cognito User Pool Security Settings

Question #:177 - [Detection]

A company needs the ability to identify the root cause of security findings in an AWS account. The company has enabled VPC Flow Logs, Amazon GuardDuty, and AWS CloudTrail. The company must investigate any IAM roles that are involved in the security findings and must visualize the findings.

Which solution will meet these requirements?

- A. Use Amazon Detective to run investigations on the IAM roles and to visualize the findings.
- B. Use Amazon Inspector to run investigations on the IAM roles and visualize the findings.
- C. Export GuardDuty findings to Amazon S3 and analyze them with Amazon Athena.
- D. Enable AWS Security Hub and use custom actions to investigate IAM roles.

Answer: A

Explanation

Amazon Detective is a managed service designed specifically to investigate and analyze security findings by automatically correlating data from Amazon GuardDuty, AWS CloudTrail, and VPC Flow Logs. According to the AWS Certified Security – Specialty Official Study Guide, Detective enables security teams to identify root causes, anomalous behavior, and indicators of compromise through interactive visualizations.

Amazon Detective allows investigators to pivot directly to IAM roles, users, and resources that are involved in GuardDuty findings. Detective builds behavior graphs and timelines that show API activity, network traffic, and historical context, making it easier to understand how and why a security incident occurred.

Amazon Inspector (Option B) focuses on vulnerability scanning of compute resources and does not investigate IAM behavior. Option C requires manual analysis and lacks native visualization. AWS Security Hub (Option D) aggregates findings but does not perform root-cause investigation or behavioral analysis.

AWS documentation explicitly states that Amazon Detective is the recommended service for deep-dive investigations following GuardDuty alerts, especially when IAM roles are involved.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ Amazon Detective User Guide
- ▶ Amazon GuardDuty Integration Documentation

Question #:178 - [Identity and Access Management]

A company uses several AWS CloudFormation stacks to handle the deployment of a suite of applications. The leader of the company's application development team notices that the stack deployments fail with permission errors when some team members try to deploy the stacks. However, other team members can deploy the stacks successfully.

The team members access the account by assuming a role that has a specific set of permissions. All team members have permissions to perform operations on the stacks.

Which combination of steps will ensure consistent deployment of the stacks MOST securely? (Select THREE.)

- A. Create a service role that has a composite principal that contains each service that needs the necessary permissions.
- B. Create a service role that has cloudformation.amazonaws.com as the service principal.
- C. Add policies that reference each CloudFormation stack ARN.
- D. Add policies that reference the ARNs of each AWS service that requires permissions.
- E. Update each stack to use the service role.
- F. Add a policy to each member role to allow the iam:PassRole action for the service role.

Answer: B E F

Explanation

AWS CloudFormation supports the use of a service role, which allows CloudFormation to assume a dedicated IAM role to create and manage resources on behalf of users. According to the AWS Certified Security – Specialty Study Guide, using a service role is the most secure and consistent way to ensure predictable stack deployments when users have varying permission sets.

By creating a service role with cloudformation.amazonaws.com as the trusted service principal (Option B), CloudFormation—not individual users—assumes responsibility for resource creation. Updating each stack to explicitly use this service role (Option E) ensures that all deployments use the same permission set, eliminating inconsistencies.

Granting the team members permission to pass the service role via `iam:PassRole` (Option F) is required so that CloudFormation can assume the role during stack operations. This approach adheres to the principle of least privilege and prevents users from gaining direct access to elevated permissions.

Composite principals (Option A) are unnecessary and insecure. Referencing stack ARNs (Option C) does not solve the root cause. While Option D reflects good policy design, it is implicit in creating the service role and is not a required standalone step.

AWS documentation clearly identifies CloudFormation service roles combined with `iam:PassRole` as best practice for secure, consistent infrastructure deployments.

- ▶ AWS Certified Security – Specialty Official Study Guide
- ▶ AWS CloudFormation Service Role Documentation
- ▶ AWS IAM Best Practices

Question #:179 - [Data Protection]

A company sends Amazon RDS snapshots to two accounts as part of its disaster recovery (DR) plan. The snapshots must be encrypted. However, each account needs to be able to decrypt the snapshots in case of a DR event.

Which solution will meet these requirements?

- A. Use the default AWS Key Management Service (AWS KMS) key to generate the snapshots. Create an AWS Lambda function that copies the KMS encryption key to the two accounts.
- B. Use an AWS Key Management Service (AWS KMS) customer managed key to generate the snapshots. Create an AWS Lambda function that imports the KMS key in the two accounts.
- C. Use the default AWS Key Management Service (AWS KMS) key to generate the snapshots. Share the KMS key with the two accounts by using an IAM principal that has the proper KMS permissions in each account.
- D. Use an AWS Key Management Service (AWS KMS) customer managed key to generate the snapshots. Share the KMS key with the two accounts by using an IAM principal that has the proper KMS permissions in each account.

Answer: D

Explanation

For encrypted RDS snapshots that must be shared across accounts and still be decryptable in the target accounts, you should use a customer managed KMS key and explicitly grant cross-account use of that key. AWS-managed default keys (Option A/C) generally cannot be shared for cross-account decryption in the same flexible way as customer managed keys, and you cannot “copy” an AWS-managed key to another account. Likewise, you cannot “import” an existing KMS key into another account via Lambda as described in Option B; KMS keys are account-scoped resources and are not copied between accounts like that.

With a customer managed key (CMK), the key policy (and/or grants) can allow principals in the DR accounts to use the key for the required cryptographic operations (for example, kms:Decrypt, kms:CreateGrant, and relevant describe permissions). Then, when the snapshot is shared and copied/used in the destination account during a DR event, the destination account can decrypt it because it has been granted permission to use the same CMK. This approach is the standard AWS pattern for cross-account encrypted snapshot sharing and meets both encryption and recoverability requirements with strong governance and auditability through CloudTrail.

店铺：IT认证考试服务

